Fpt University

TRƯỜNG ĐẠI HỌC FPT

CAPSTONE PROJECT REPORT

Report 4 – Software Design Specification

OMTS – Oyster Management and Traceability System

Hợp tác xã Thủy sản Trung Nam

Software Design Specification v1.2 – 07/10/2026

Phạm vi chi tiết: AUTH (UC01–UC08), COOP (UC09–UC12)

– Hanoi, Oct 2026 –

Table of Contents

Change Log 5
I. High Level Design 7
1. Software Architecture 7
2. Package Diagram 10
3. Database Design 12
3.1 sys.status 15
3.2 sys.status_transition 15
3.3 sys.audit_event 15
3.4 sys.outbox_message 16
3.5 auth.account 16
3.6 auth.account_notification_pref 17
3.7 auth.push_device 17
3.8 auth.auth_session 17
3.9 auth.otp_verification 18
3.10 coop.cooperative 18
3.11 coop.cooperative_business_line 19
3.12 coop.employee 19
3.13 coop.role 19
3.14 coop.app_feature 20
3.15 coop.role_permission 20
3.16 coop.access_grant 20
3.17 Chỉ mục và view 21
II. Detailed Code Design 21
1. Quy ước thiết kế chung cho các package 21
1.1 Cấu trúc module và trách nhiệm của từng layer 21
1.2 Quy ước API 22
1.3 Mô hình lỗi và ánh xạ thông điệp 23
1.4 Xác thực, phân quyền và phạm vi dữ liệu 23
1.5 Giao dịch, đồng thời, audit và outbox 24
1.6 Cấu hình (Options) và giá trị chính sách 24
2. AUTH – Xác thực và tài khoản cá nhân (UC01–UC08) 25
2.1 Phạm vi, module và phụ thuộc 25
2.2 Class Diagram 27
2.3 API Endpoints 29
2.4 Request/Response DTO và validation 31

2.5 Authorization, transaction và xử lý lỗi theo lệnh 32
2.6 Data Design 33
2.7 Sequence Diagram – Đăng nhập (UC02) 35
2.8 Sequence Diagram – Đăng ký tài khoản khách hàng và xác minh mã (UC01, UC08) 36
2.9 Sequence Diagram – Khôi phục tài khoản tự phục vụ (UC03) 37
2.10 Thiết kế tương tác của UC04–UC07 39
2.11 External integration 39
2.12 Thiết kế phía client (Web Next.js, Mobile React Native) 40
2.13 Traceability 40
3. COOP – Hợp tác xã, nhân sự và phân quyền (UC09–UC12) 41
3.1 Phạm vi, module và phụ thuộc 41
3.2 Class Diagram 43
3.3 Permission engine 46
3.4 API Endpoints 47
3.5 Request/Response DTO và validation 49
3.6 Authorization, transaction và xử lý lỗi theo lệnh 50
3.7 Data Design 51
3.8 Sequence Diagram – Tạo tài khoản và gán cặp khu – vai trò (UC11) 52
3.9 Sequence Diagram – Sửa vai trò đang có người giữ (UC12) 53
3.10 Sequence Diagram – Khóa tài khoản (UC11) 54
3.11 Sequence Diagram – Kiểm tra quyền và phạm vi khu cho request nghiệp vụ 55
3.12 Thiết kế tương tác của UC09 và UC10 56
3.13 Thiết kế phía client 56
3.14 Traceability 56
4. Quyết định thiết kế và điểm còn mở 57
III. Design for Non-Functional Requirements 58
1. Security Design 58
1.1 Authentication Flow 58
1.2 Authorization & RBAC Implementation 59
1.3 Data Protection 60
2. Performance & Scalability Design 60
2.1 Caching Strategy 60
2.2 Database Query Optimization 60
3. Reliability, Audit & Concurrency Design 61
IV. Other Design Specifications 61
1. Danh mục trạng thái và chuyển trạng thái (BR-29, BR-30) 61

2. Audit trail 61
3. Outbox và tác vụ nền 62
4. Môi trường và cấu hình triển khai 62
5. Kiểm thử cho AUTH và COOP 62
6. Quyết định thiết kế và điểm còn mở 62

Change Log

Date	A* M, D	In charge	Change Description
06/10/2026	A	OMTS project team	Khởi tạo SDS v1.0 theo mẫu Report 4: High Level Design (kiến trúc, package, CSDL); Detailed Code Design cho AUTH (UC01–UC08) và COOP (UC09–UC12); thiết kế NFR. Nguồn yêu cầu: SRS v5.5 (05/10/2026).
06/10/2026	M	OMTS project team	SDS v1.1 theo SRS v5.6 (QĐ-16…QĐ-18): chốt OD-01…OD-14 (Bảng II-30); giá trị OTP, phiên, khóa tạm, mật khẩu, mật khẩu tạm (Bảng II-4); xác minh email và khôi phục ưu tiên email, luôn MSG15, gửi qua outbox (SEQ-AUTH-03); auth.phone_verification đổi thành auth.otp_verification; Xem bắt buộc (CHECK); lý do thu hồi bắt buộc; màn hình COOP trên Mobile. Trạng thái: chờ PM/Technical Lead review.
07/10/2026	M	OMTS project team	SDS v1.2 theo SRS v5.8 (góp ý nhóm về trạng thái): nguồn yêu cầu đổi sang SRS v5.8; danh mục trạng thái seed 47 trạng thái, 44 chuyển (SalesOrder thêm Yêu cầu trả hàng, Đã chấp nhận trả, Đã nhận hàng trả; TracePublicationVersion thêm Cần rà lại, bỏ Đã công bố → Đã thay thế); cách gọi EnsureAllowed cho chuyển do hệ thống (mục IV.1). AUTH theo QĐ-20: UC08 Xác minh email hoặc số điện thoại; đăng ký, đăng nhập bằng email hoặc số điện thoại; khôi phục cho thương lái, Chủ HTX, nhân viên, gửi mã tới đúng định danh đã xác minh người dùng nhập, đổi cách nhận mã qua /auth/recovery/{id}/switch (bỏ /{id}/sms); bỏ đổi số điện thoại ở UC05 (/me/phone-change, CHANGE_PHONE); UNIQUE email đã xác minh, phone_e164 cho phép NULL với thương lái đăng ký bằng email (OD-16); vẽ lại SEQ-AUTH-02, SEQ-AUTH-03, CLS-AUTH-APP, CLS-AUTH-DOM, DB-AUTH-COOP. QĐ-21: mã email dùng OtpOptions như SMS; thương lái đăng ký bằng email và nhân viên phải thêm/xác minh số điện thoại ngay sau đăng nhập (UC02 3a, BR-34): purpose VERIFY_PHONE, /me/phone-verifications, cờ phoneVerificationRequired, bộ lọc 403 MSG67; UC11 đổi số thì xác minh lại; mọi loại tài khoản tự đổi số ở UC05 3b qua cùng API (số cũ giữ tới khi số mới xác minh), nhân viên gửi được số khác ở UC02 3a; thương lái thêm/đổi số thì ICustomerLinkService tự ghép hồ sơ khách offline khớp duy nhất (MSG57 nếu không); chốt OD-05, OD-10, OD-16. QĐ-22 (SRS v5.8): actor Quản lý khu và Kế toán là actor con của Nhân viên, ánh xạ vào vai trò cùng tên (account_type EMPLOYEE, không seed vai trò), bỏ Thu ngân (mục 1.2 Authorization & RBAC Implementation). QĐ-24: UC10, UC11 chỉ Chủ HTX (endpoint OwnerOnly, EMPLOYEE và USER_ACCOUNT không cấp được cho vai trò; IGrantGuard bỏ kiểm ⊆ quyền người cấp; vẽ lại SEQ-COOP-01, CLS-COOP-APP). Rà soát SRS v5.8 (QĐ-26…QĐ-30): đổi tên Dịch vụ SMS (HLD, Bảng II-14); coop.cooperative thêm bank_bin, bank_account_no, bank_account_name cho QR VietQR ở UC48 (CLS-COOP-DOM, DB-AUTH-COOP, PUT /cooperative); UC11 bỏ xóa tài khoản (bỏ DELETE /user-accounts/{id}), nhánh chặn đích Owner/Admin đổi thành 1e. Bảng quyết định của SRS chuyển sang OMTS Decision Log: cột Nguồn QĐ-xx (Bảng II-4) trỏ tới tài liệu này. Theo danh sách lỗi rà soát SRS v5.8 (QĐ-31…QĐ-37): seed 53 trạng thái, 52 chuyển (nhóm SALE_ADJUSTMENT, PAY_RULE; hủy đơn từ Chờ xét, Chờ khách đồng ý, Đang thu hoạch; lần thu đầu; Đạt → Nháp; 8 chuyển do hệ thống); UC11 tạo tài khoản bằng mật khẩu tạm (UserAccountCreatedDto, SEQ-COOP-01, CLS-COOP-APP, CLS-AUTH-APP); đăng nhập MSG68 (mật khẩu tạm quá hạn, UC02 2d), MSG69 (khóa tạm, UC02 2e), SEQ-AUTH-01; dữ liệu chung HTX chỉ grant Toàn bộ khu (Bảng II-3, mục II.3.3, III.1.2); Quản trị hệ thống chỉ mở khóa tài khoản do mình khóa; audit in nhãn QR, sửa kế hoạch thu, điều khoản bán, ngưỡng nước; bảng kỹ thuật theo dõi đồng bộ

			cổng truy xuất quốc gia; bỏ lệnh DeleteUserAccount còn sót; packages/messages MSG01…MSG69 (PKG). Trạng thái: chờ PM/Technical Lead review.

*A - Added M - Modified D - Deleted

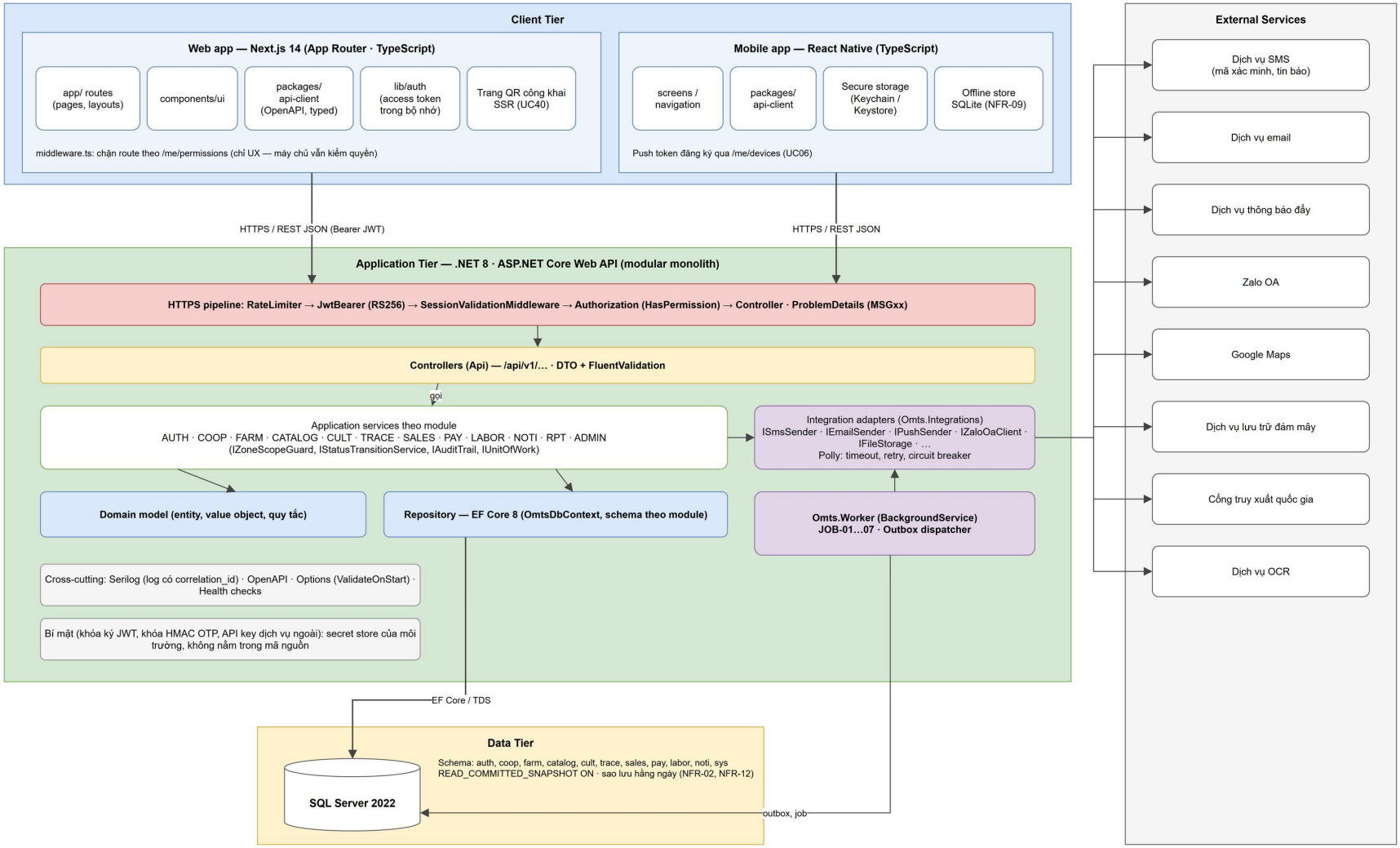
I. High Level Design

1. Software Architecture

OMTS dùng kiến trúc ba tầng với backend dạng modular monolith: một ASP.NET Core Web API (.NET 8) phục vụ Web (Next.js) và Mobile (React Native), một tiến trình Worker cho tác vụ nền, một cơ sở dữ liệu SQL Server chia schema theo module. Lựa chọn này giữ ranh giới package của SRS (mỗi package một module) nhưng triển khai và giao dịch đơn giản cho quy mô một HTX; module giao tiếp qua contract nên có thể tách service sau.

Technology baseline

Thành phần	Công nghệ (baseline)	Ghi chú
Backend API	.NET 8 LTS, ASP.NET Core Web API, EF Core 8, FluentValidation, Polly (Microsoft.Extensions.Http.Resilience), Serilog, OpenAPI	Theo technology baseline của dự án
Xác thực	JwtBearer (RS256), PasswordHasher của ASP.NET Core Identity (PBKDF2), ASP.NET Core RateLimiter	Không dùng toàn bộ Identity store; bảng tài khoản theo ERD OMTS
Worker	.NET 8 BackgroundService (Generic Host)	JOB-01…07, outbox dispatcher
Cơ sở dữ liệu	SQL Server 2022, READ_COMMITTED_SNAPSHOT ON	Một database, schema theo module
Web	Next.js 14 App Router, TypeScript, TanStack Query, React Hook Form + Zod	SSR cho trang QR công khai
Mobile	React Native (TypeScript), react-native-keychain, SQLite	Lưu ngoại tuyến theo NFR-09
Kiểm thử	xUnit, Testcontainers (SQL Server), NetArchTest; Playwright (Web); Jest (Mobile)	Đề xuất



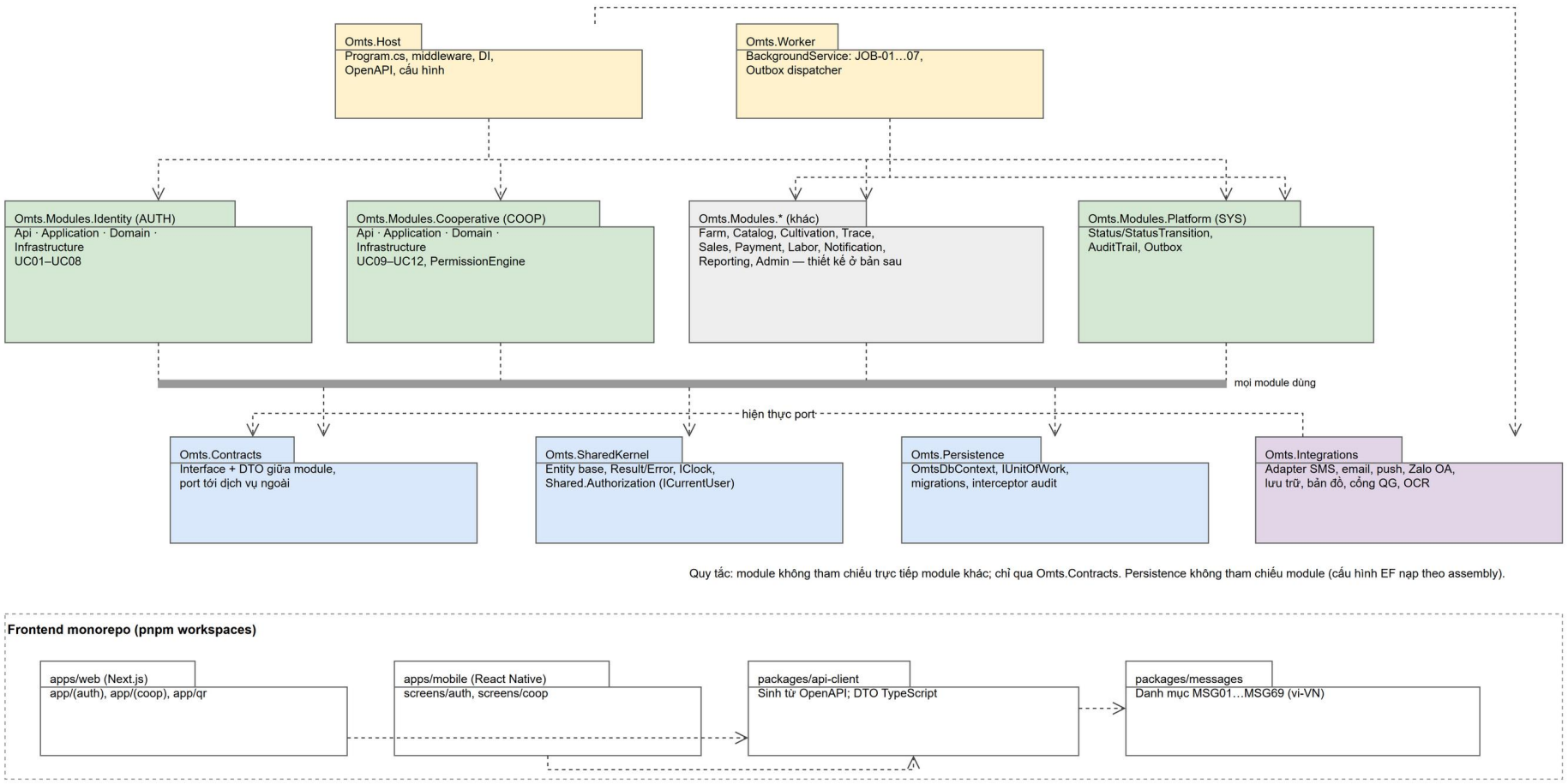
Hình 1. Kiến trúc tổng thể OMTS (ARCH)

Architecture component descriptions

No	Component	Description
Client Tier		
01	Web app (Next.js)	Giao diện trình duyệt cho Chủ HTX, nhân viên văn phòng và Quản trị hệ thống; route group (auth), (coop), (admin) và trang QR công khai render phía máy chủ (UC40). Access token giữ trong bộ nhớ; refresh token ở cookie HttpOnly.
02	Mobile app (React Native)	Ứng dụng cho thương lái và nhân viên hiện trường; refresh token trong Keychain/Keystore; SQLite lưu dữ liệu ghi ngoại tuyến (cân, bàn giao, đo nước) và đồng bộ khi có mạng (NFR-09, OPEN-11); đăng ký push token (UC06).
03	packages/api-client	Client TypeScript sinh từ OpenAPI, dùng chung cho Web và Mobile; interceptor làm mới token và ánh xạ ProblemDetails.
04	packages/messages	Danh mục thông điệp MSG01…MSG69 tiếng Việt; client dịch mã MSG trong phản hồi lỗi thành câu chữ.
Application Tier		
05	HTTPS pipeline	RateLimiter → JwtBearer → SessionValidationMiddleware → Authorization ([HasPermission]) → Controller; ExceptionHandler trả ProblemDetails có mã MSG.
06	Controllers (Api)	Endpoint REST /api/v1 của từng module; DTO và validator; không chứa quy tắc nghiệp vụ.
07	Application services	Service theo use case của 12 module (AUTH, COOP, FARM, CATALOG, CULT, TRACE, SALES, PAY, LABOR, NOTI, RPT, ADMIN); kiểm phạm vi khu, giao dịch, audit, chuyển trạng thái.
08	Domain model	Entity, value object và bất biến nghiệp vụ theo ERD SRS (52 entity).
09	Repository (EF Core 8)	OmtsDbContext với schema theo module, global filter theo HTX, rowversion cho khóa lạc quan.
10	Integration adapters	Hiện thực port gửi SMS OTP, email, push, Zalo OA, lưu trữ tệp, bản đồ, cổng truy xuất quốc gia, OCR; timeout, retry, circuit breaker.
11	Omts.Worker	Chạy JOB-01…07 (SRS 5.3) và gửi outbox; dùng chung module và DbContext với API.
12	Cross-cutting	Log có correlation id (Serilog), OpenAPI, health check, Options kiểm khi khởi động; secret ở secret store của môi trường.
Data Tier		
13	SQL Server 2022	Một database; schema auth, coop, farm, catalog, cult, trace, sales, pay, labor, noti, sys; sao lưu hằng ngày, giữ dữ liệu và audit tối thiểu 5 năm (NFR-02, NFR-12).
14	Lưu trữ tệp	Ảnh, giấy tờ, hóa đơn lưu ở Dịch vụ lưu trữ đám mây; database chỉ giữ khóa tệp (API-06).
External Services		
15	8 hệ thống ngoài	Dịch vụ SMS, email, thông báo đẩy, Zalo OA, Google Maps, lưu trữ đám mây, cổng truy xuất quốc gia, OCR (API-01…11). Chỉ gọi qua adapter; cấu hình kết nối ở UC73; lỗi dịch vụ ngoài không tự tạo hay sửa giao dịch nghiệp vụ.

2. Package Diagram

Solution backend chia theo module tương ứng nhóm chức năng của SRS; frontend là monorepo pnpm. Mũi tên nét đứt là quan hệ phụ thuộc biên dịch.



Hình 2. Package diagram backend và frontend (PKG)

Package descriptions

No	Package	Description
01	Omts.Host	Composition root của API: Program.cs, pipeline middleware, đăng ký DI của mọi module, cấu hình Options, OpenAPI.
02	Omts.Worker	Host tác vụ nền: JOB-01…07 và outbox dispatcher; dùng lại Application/Infrastructure của module.
03	Omts.Modules.Identity (AUTH)	Xác thực và tài khoản cá nhân (UC01–UC08): đăng ký, OTP, đăng nhập, phiên, hồ sơ, tùy chọn thông báo. Schema auth.
04	Omts.Modules.Cooperative (COOP)	Hồ sơ HTX, nhân viên, tài khoản nội bộ, vai trò và permission engine (UC09–UC12). Schema coop.
05	Omts.Modules.Platform (SYS)	Danh mục trạng thái và chuyển trạng thái (E51, E52), audit (E48), outbox. Schema sys.
06	Omts.Modules.Farm / Catalog / Cultivation / Trace / Sales / Payment / Labor / Notification / Reporting / Admin	Các package còn lại của SRS (Bảng I-2); thiết kế chi tiết ở phiên bản sau, dùng cùng quy ước.
07	Omts.Contracts	Interface và DTO module công bố cho nhau; port tới dịch vụ ngoài. Module chỉ phụ thuộc nhau qua package này.
08	Omts.SharedKernel	Lớp nền: Entity base, Result/Error, IClock, PhoneNumber, Shared.Authorization (ICurrentUser, HasPermission).
09	Omts.Persistence	OmtsDbContext, IUnitOfWork, interceptor cột chung, migration; nạp cấu hình EF của module theo assembly.
10	Omts.Integrations	Adapter dịch vụ ngoài (SMS, email, push, Zalo OA, lưu trữ, bản đồ, cổng quốc gia, OCR) có resilience policy.
11	apps/web	Next.js App Router: app/(auth), app/(coop), app/(admin), app/qr; components/ui; lib/auth.
12	apps/mobile	React Native: screens/auth, screens/coop…, store ngoại tuyến SQLite, secure storage.
13	packages/api-client	Client TypeScript sinh từ OpenAPI của Omts.Host.
14	packages/messages	Thông điệp MSG01…MSG69 (vi-VN) dùng chung.

Bảng I-2. Ánh xạ nhóm chức năng SRS → module → schema

Nhóm chức năng SRS	UC	Module	Schema
Xác thực và tài khoản cá nhân	UC01–UC08	Identity (AUTH)	auth
Hợp tác xã và phân quyền	UC09–UC12	Cooperative (COOP)	coop
Vùng nuôi, bè và hồ sơ tuân thủ	UC15, UC18, UC76, UC77	Farm (FARM)	farm
Sản phẩm và nguồn giống	UC20, UC22, UC23	Catalog (CATALOG)	catalog
Nuôi trồng và môi trường	UC24–UC27	Cultivation (CULT)	cult
Thu hoạch và truy xuất	UC30–UC32, UC36–UC41	Trace (TRACE)	trace
Khách hàng, đơn hàng và bán hàng	UC42–UC48	Sales (SALES)	sales
Thanh toán và xử lý sau bán	UC49–UC54	Payment (PAY)	pay
Nhân sự và chi phí lao động	UC55–UC62	Labor (LABOR)	labor
Báo cáo	UC63–UC68	Reporting (RPT)	— (đọc từ schema khác)
Thông báo và liên lạc	UC69–UC71	Notification (NOTI)	noti
Quản trị nền tảng	UC72–UC75	Admin (ADMIN) + Platform (SYS)	sys

Quy ước đặt tên

Đối tượng	Quy ước	Ví dụ
Project .NET	Omts.<Tầng> hoặc Omts.Modules.<Module>.<Layer>	Omts.Modules.Cooperative.Application
Class / interface	PascalCase; interface tiền tố I; service theo use case + Service	IUserAccountService, UserAccountService
DTO	<Hành động><Đối tượng>Request / <Đối tượng>Dto / <Đối tượng>Response	CreateUserAccountRequest, RoleDetailDto
Endpoint	/api/v1/<tài nguyên số nhiều kebab-case>[/{id}[/<lệnh>]]	POST /api/v1/user-accounts/{id}/lock
Schema / bảng / cột SQL	snake_case; bảng số ít; PK <bảng>_id	coop.access_grant.grant_id

Đối tượng	Quy ước	Ví dụ
Ràng buộc / chỉ mục	PK_<bảng>, FK_<bảng>_<bảng đích>, UX_ (unique), IX_, CK_	UX_grant_active, CK_access_grant_scope
Mã quyền chức năng	UPPER_SNAKE theo danh mục FeatureCatalog	USER_ACCOUNT, COOPERATIVE
Mã audit	<ĐỐI_TƯỢNG>.<HÀNH_ĐỘNG>	ACCOUNT.LOCK, ROLE.UPDATE, STATUS.CHANGE
Web route / Mobile screen	kebab-case trong app/(group)/…; <Tên>Screen	app/(coop)/admin/user-accounts, LoginScreen

3. Database Design

Một database SQL Server 2022, schema theo module. Quy ước chung cho mọi bảng:

- Khóa chính `bigint IDENTITY` (bảng nghiệp vụ), `uniqueidentifier` cho dữ liệu kỹ thuật lộ ra client (phiên, lần xác minh), `smallint` seed cho danh mục.
- Thời gian `datetime2(3)` theo UTC; ngày nghiệp vụ (hiệu lực grant) dùng `date` theo giờ Việt Nam.
- Cột chung của bảng nghiệp vụ sửa được: created_at, created_by, updated_at, updated_by, row_version (Bảng I-3). Interceptor của OmtsDbContext tự điền.
- Trạng thái (BR-29): cột `status_id smallint` + cột tính toán hằng `status_group AS '<NHÓM>' PERSISTED`; FK ghép (status_id, status_group) → sys.status(status_id, group_code). Nhờ vậy database chặn gán trạng thái của nhóm khác.
- Không xóa vật lý bản ghi nghiệp vụ đã phát sinh dữ liệu; đổi trạng thái hoặc USAGE (NFR-02). FK mặc định NO ACTION; chỉ bảng con thuần (dòng ngành nghề, tùy chọn thông báo, quyền vai trò) dùng CASCADE.
- Bảng có coop_id được lọc bởi global query filter; chỉ mục bắt đầu bằng coop_id khi truy vấn theo HTX.

Bảng I-3. Cột chung

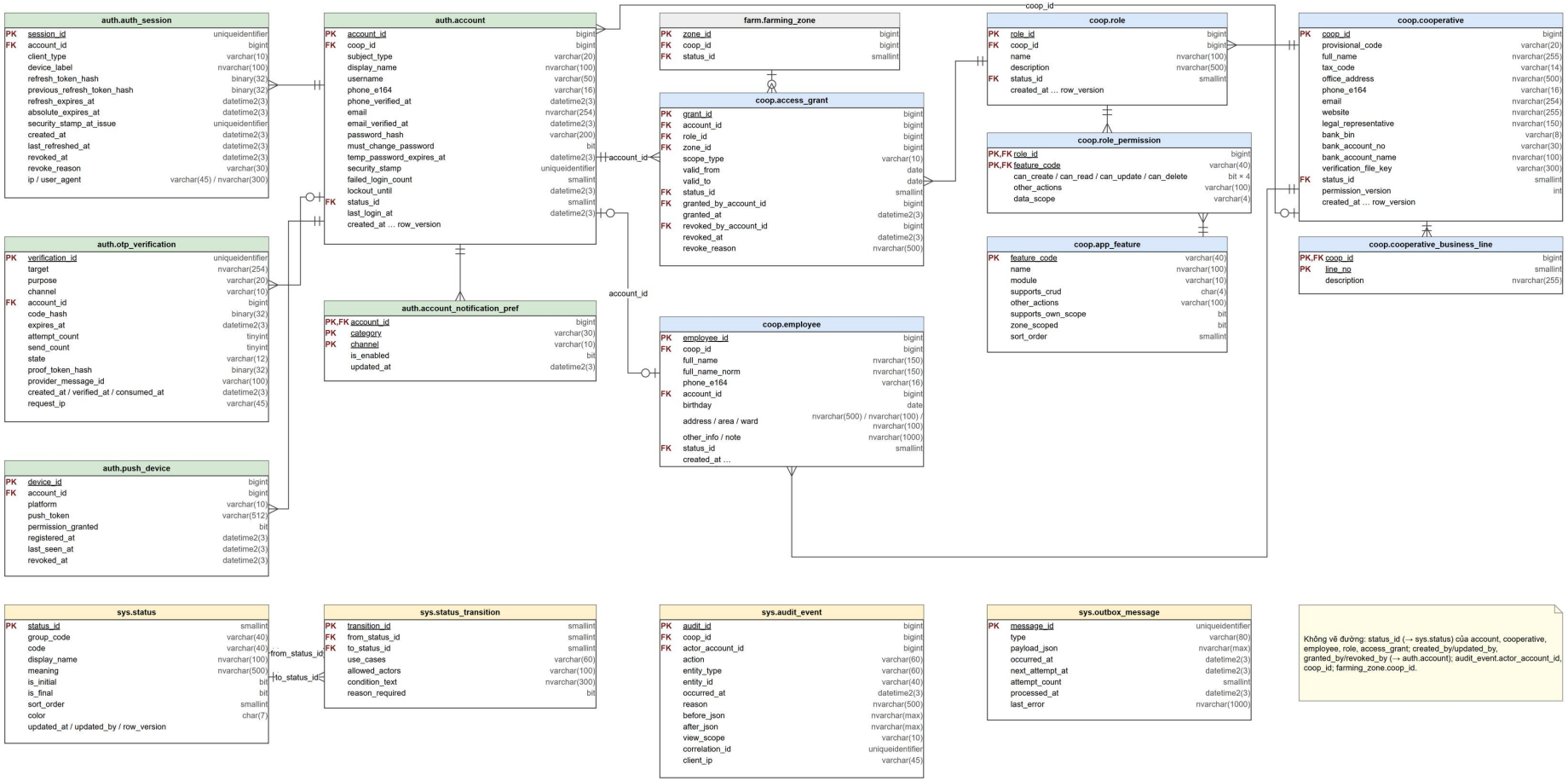
Column	Type	Constraints	Notes
created_at	datetime2(3)	NOT NULL, DEFAULT SYSUTCDATETIME()	UTC
created_by	bigint	NULL → auth.account	NULL = hệ thống / job
updated_at	datetime2(3)	NULL	UTC
updated_by	bigint	NULL → auth.account	
row_version	rowversion	NOT NULL	Khóa lạc quan; ETag/If-Match (NFR-09, MSG06)

Bảng I-4. Ánh xạ 52 entity của SRS → bảng

Entity SRS	Module	Bảng (schema.table)	Mức thiết kế trong v1.2
E01 Cooperative	COOP	coop.cooperative (+ coop.cooperative_business_line)	Chi tiết (mục 3.x)
E02 Account	AUTH	auth.account (+ auth.account_notification_pref)	Chi tiết (mục 3.x)
E03 Employee	COOP	coop.employee	Chi tiết (mục 3.x)
E04 Role	COOP	coop.role	Chi tiết (mục 3.x)
E05 RolePermission	COOP	coop.role_permission	Chi tiết (mục 3.x)
E06 AccessGrant	COOP	coop.access_grant	Chi tiết (mục 3.x)
E07 FarmingZone	FARM	farm.farming_zone	Tên dự kiến
E08 ZoneComplianceDocument	FARM	farm.zone_compliance_document	Tên dự kiến
E09 DocumentZoneScope	FARM	farm.document_zone_scope	Tên dự kiến
E10 Raft	FARM	farm.raft	Tên dự kiến
E11 RaftLayoutVersion	FARM	farm.raft_layout_version	Tên dự kiến
E12 Lane	FARM	farm.lane	Tên dự kiến
E13 OysterSeedType	CATALOG	catalog.oyster_seed_type	Tên dự kiến
E14 SeedSupplier	CATALOG	catalog.seed_supplier	Tên dự kiến
E15 SeedReceiptLot	CATALOG	catalog.seed_receipt_lot	Tên dự kiến
E16 CultivationCycle	CULT	cult.cultivation_cycle	Tên dự kiến

Entity SRS	Module	Bảng (schema.table)	Mức thiết kế trong v1.2
E17 SeedingEvent	CULT	cult.seeding_event	Tên dự kiến
E18 LaneSegment	CULT	cult.lane_segment	Tên dự kiến
E19 CultivationLogEntry	CULT	cult.cultivation_log_entry	Tên dự kiến
E20 WaterMeasurement	CULT	cult.water_measurement	Tên dự kiến
E21 Product	CATALOG	catalog.product	Tên dự kiến
E22 Customer	SALES	sales.customer	Tên dự kiến
E23 SalesOrder	SALES	sales.sales_order	Tên dự kiến
E24 HarvestEvent	TRACE	trace.harvest_event	Tên dự kiến
E25 TraceabilityLot	TRACE	trace.traceability_lot	Tên dự kiến
E26 PortWeighing	SALES	sales.port_weighing	Tên dự kiến
E27 PortHandover	SALES	sales.port_handover	Tên dự kiến
E28 SaleTransaction	SALES	sales.sale_transaction	Tên dự kiến
E29 TracePublicationVersion	TRACE	trace.trace_publication_version	Tên dự kiến
E30 TraceCorrection	TRACE	trace.trace_correction	Tên dự kiến
E31 QualityClaim	PAY	pay.quality_claim	Tên dự kiến
E32 SaleAdjustment	PAY	pay.sale_adjustment	Tên dự kiến
E33 PhysicalReturn	PAY	pay.physical_return	Tên dự kiến
E34 CustomerReceipt	PAY	pay.customer_receipt	Tên dự kiến
E35 ReceiptAllocation	PAY	pay.receipt_allocation	Tên dự kiến
E36 CustomerCredit	PAY	pay.customer_credit	Suy ra (nhóm C) – có thể là view
E37 CustomerRefund	PAY	pay.customer_refund	Tên dự kiến
E38 Contractor	LABOR	labor.contractor	Tên dự kiến
E39 SeasonalWorker	LABOR	labor.seasonal_worker	Tên dự kiến
E40 WorkAssignment	LABOR	labor.work_assignment	Tên dự kiến
E41 AttendanceRecord	LABOR	labor.attendance_record	Tên dự kiến
E42 PayRuleVersion	LABOR	labor.pay_rule_version	Tên dự kiến
E43 PayLine	LABOR	labor.pay_line	Tên dự kiến
E44 LaborSettlement	LABOR	labor.labor_settlement	Tên dự kiến
E45 LaborPayment	LABOR	labor.labor_payment	Tên dự kiến
E46 Notification	NOTI	noti.notification	Nhóm C về trạng thái; vẫn lưu bản ghi
E47 MessageDeliveryAttempt	NOTI	noti.message_delivery_attempt	Tên dự kiến
E48 AuditEvent	SYS	sys.audit_event	Chi tiết (mục 3.x)
E49 RaftMaterialRecord	FARM	farm.raft_material_record	Tên dự kiến
E50 RaftMaterialLine	FARM	farm.raft_material_line	Tên dự kiến
E51 Status	SYS	sys.status	Chi tiết (mục 3.x)
E52 StatusTransition	SYS	sys.status_transition	Chi tiết (mục 3.x)

Ngoài 52 entity, SDS thêm các bảng kỹ thuật SRS giao cho thiết kế: auth.auth_session, auth.otp_verification, auth.push_device, coop.app_feature, sys.outbox_message và view sys.v_security_context (đọc phiên + trạng thái tài khoản + permission_version trong một truy vấn cho mỗi request). Theo dõi đồng bộ cổng truy xuất quốc gia (hàng đợi, lần gửi, phản hồi, mã ngoài; UC41, SCR-25, JOB-04, API-10) là dữ liệu kỹ thuật SRS giao cho SDS: bảng dự kiến trace.portal_sync_attempt, thiết kế chi tiết cùng package TRACE.



Hình 3. ERD vật lý AUTH, COOP và SYS (DB-AUTH-COOP)

3.1 sys.status

Entity: E51 Status. Module: SYS.

Column	Type	Constraints	Notes
status_id	smallint	PK; PRIMARY KEY (seed, không IDENTITY)	Giá trị cố định theo SRS 3.4
group_code	varchar(40)	NOT NULL; UNIQUE(status_id, group_code)	COOPERATIVE, ACCOUNT, EMPLOYEE, ACCESS_GRANT, USAGE, …; khóa đích của FK ghép (BR-29)
code	varchar(40)	NOT NULL; UNIQUE(group_code, code)	Mã cố định (ACTIVE, LOCKED, IN_USE…)
display_name	nvarchar(100)	NOT NULL	Sửa được ở UC73
meaning	nvarchar(500)	NULL	Sửa được ở UC73
is_initial	bit	NOT NULL	
is_final	bit	NOT NULL	
sort_order	smallint	NOT NULL	Sửa được ở UC73
color	char(7)	NULL; CHECK LIKE '#[0-9A-F]…'	Sửa được ở UC73
updated_at / updated_by / row_version			Như cột chung

3.2 sys.status_transition

Entity: E52 StatusTransition. Module: SYS.

Column	Type	Constraints	Notes
transition_id	smallint	PK; PRIMARY KEY (seed)	
from_status_id	smallint	FK; NOT NULL → sys.status	
to_status_id	smallint	FK; NOT NULL → sys.status; UNIQUE(from, to); CHECK from ≠ to	Cùng nhóm: kiểm bằng test seed
use_cases	varchar(60)	NOT NULL	VD: 'UC11,UC74'
allowed_actors	varchar(100)	NOT NULL	COOP_OWNER, EMPLOYEE, SYSTEM_ADMIN, SYSTEM
condition_text	nvarchar(300)	NOT NULL	Điều kiện theo bảng 3.4-2
reason_required	bit	NOT NULL	BR-30

3.3 sys.audit_event

Entity: E48 AuditEvent. Module: SYS.

Column	Type	Constraints	Notes
audit_id	bigint	PK; IDENTITY PRIMARY KEY	
coop_id	bigint	FK; NULL → coop.cooperative	NULL = sự kiện nền tảng
actor_account_id	bigint	FK; NULL → auth.account	NULL = job hệ thống
action	varchar(60)	NOT NULL	ACCOUNT.LOCK, ROLE.UPDATE, STATUS.CHANGE, …
entity_type	varchar(60)	NOT NULL	Loại bản ghi liên quan
entity_id	varchar(40)	NOT NULL	Mã bản ghi (không FK)
occurred_at	datetime2(3)	NOT NULL	UTC
reason	nvarchar(500)	NULL	Bắt buộc khi transition có reason_required
before_json	nvarchar(max)	NULL; CHECK ISJSON	Không chứa mật khẩu, mã OTP, token
after_json	nvarchar(max)	NULL; CHECK ISJSON	
view_scope	varchar(10)	NOT NULL; CHECK IN ('COOP','PLATFORM')	Phạm vi xem (UC75)
correlation_id	uniqueidentifier	NOT NULL	TraceId của request
client_ip	varchar(45)	NULL	

3.4 sys.outbox_message

Entity: — (kỹ thuật). Module: SYS.

Column	Type	Constraints	Notes
message_id	uniqueidentifier	PK; PRIMARY KEY	Cũng là khóa chống trùng khi gửi
type	varchar(80)	NOT NULL	PushNotification, EmailMessage, …
payload_json	nvarchar(max)	NOT NULL; CHECK ISJSON	
occurred_at	datetime2(3)	NOT NULL	Ghi cùng giao dịch nghiệp vụ
next_attempt_at	datetime2(3)	NOT NULL	Lịch thử lại
attempt_count	smallint	NOT NULL DEFAULT 0	
processed_at	datetime2(3)	NULL	
last_error	nvarchar(1000)	NULL	

3.5 auth.account

Entity: E02 Account. Module: AUTH.

Column	Type	Constraints	Notes
account_id	bigint	PK; IDENTITY PRIMARY KEY	
coop_id	bigint	FK; NULL → coop.cooperative	NOT NULL khi subject_type ∈ (COOP_OWNER, EMPLOYEE)
subject_type	varchar(20)	NOT NULL; CHECK IN ('SYSTEM_ADMIN','COOP_OWNER','EMPLOYEE','TRADER')	Loại chủ thể
display_name	nvarchar(100)	NOT NULL	UC05 sửa được
username	varchar(50)	NULL; UNIQUE (lọc NOT NULL); CHECK mẫu [a-z0-9._-]	Bắt buộc với tài khoản nội bộ
phone_e164	varchar(16)	NULL; UNIQUE (lọc NOT NULL); CHECK NULL chỉ khi TRADER có email_verified_at	Số E.164; duy nhất toàn hệ thống (BR-32). NULL với thương lái đăng ký bằng email tới khi thêm số ở UC02 3a (QĐ-21)
phone_verified_at	datetime2(3)	NULL	Đã xác minh bằng mã. NULL ⇒ TRADER/EMPLOYEE phải xác minh ngay sau đăng nhập (UC02 3a, BR-34): nhân viên mới tạo hoặc vừa đổi số ở UC11. Đổi số ở UC05 3b (mọi loại tài khoản): số mới ghi cùng phone_verified_at khi xác nhận đúng mã
email	nvarchar(254)	NULL; UNIQUE (lọc email_verified_at NOT NULL)	Lưu chữ thường. UC01, UC05 chỉ ghi email sau khi xác minh; UC11 có thể nhập email chưa xác minh. Email đã xác minh duy nhất toàn hệ thống (BR-32)
email_verified_at	datetime2(3)	NULL	Có giá trị ⇒ email dùng đăng nhập và nhận mã khi người dùng nhập email này (BR-31)
password_hash	varchar(200)	NOT NULL	PBKDF2 (ASP.NET Core Identity v3) – credential reference
must_change_password	bit	NOT NULL DEFAULT 0	Khi tạo tài khoản và đặt lại mật khẩu (UC11, 1d)
temp_password_expires_at	datetime2(3)	NULL; CHECK chỉ có giá trị khi must_change_password = 1	Mật khẩu tạm hết hạn sau 24 giờ (QĐ-16)
security_stamp	uniqueidentifier	NOT NULL	Đổi khi đổi mật khẩu, khóa → vô hiệu phiên
failed_login_count	smallint	NOT NULL DEFAULT 0	Giới hạn thử sai (kỹ thuật)

Column	Type	Constraints	Notes
lockout_until	datetime2(3)	NULL	Khóa tạm kỹ thuật, không phải trạng thái LOCKED
status_id	smallint	FK; NOT NULL → sys.status (nhóm ACCOUNT)	ACTIVE | LOCKED
status_group	AS 'ACCOUNT' PERSISTED	FK ghép (status_id, status_group) → sys.status(status_id, group_code)	Bảo đảm đúng nhóm trạng thái (BR-29)
last_login_at	datetime2(3)	NULL	
created_at … row_version			Cột chung

3.6 auth.account_notification_pref

Entity: E02 Account (thuộc tính tùy chọn thông báo). Module: AUTH.

Column	Type	Constraints	Notes
account_id	bigint	PK, FK; → auth.account ON DELETE CASCADE	
category	varchar(30)	PK; NOT NULL	Mã danh mục trong NotificationCatalog
channel	varchar(10)	PK; CHECK IN ('IN_APP','PUSH','EMAIL','ZALO')	
is_enabled	bit	NOT NULL	Không có dòng = bật (mặc định)
updated_at	datetime2(3)	NOT NULL	

3.7 auth.push_device

Entity: — (kỹ thuật, UC06). Module: AUTH.

Column	Type	Constraints	Notes
device_id	bigint	PK; IDENTITY PRIMARY KEY	
account_id	bigint	FK; NOT NULL → auth.account	
platform	varchar(10)	CHECK IN ('ANDROID','IOS','WEB')	
push_token	varchar(512)	NOT NULL; UNIQUE	Token của Dịch vụ thông báo đẩy
permission_granted	bit	NOT NULL	Thiết bị cho phép nhận push
registered_at	datetime2(3)	NOT NULL	
last_seen_at	datetime2(3)	NOT NULL	
revoked_at	datetime2(3)	NULL	Khi đăng xuất / token hỏng

3.8 auth.auth_session

Entity: — (kỹ thuật: phiên đăng nhập UC02, UC07). Module: AUTH.

Column	Type	Constraints	Notes
session_id	uniqueidentifier	PK; PRIMARY KEY	Claim sid trong JWT
account_id	bigint	FK; NOT NULL → auth.account	
client_type	varchar(10)	CHECK IN ('WEB','MOBILE')	
device_label	nvarchar(100)	NULL	
refresh_token_hash	binary(32)	NOT NULL; UNIQUE	SHA-256 của refresh token hiện hành
previous_refresh_token_hash	binary(32)	NULL	Phát hiện dùng lại token cũ
refresh_expires_at	datetime2(3)	NOT NULL	Hạn trượt
absolute_expires_at	datetime2(3)	NOT NULL	Hạn tuyệt đối
security_stamp_at_issue	uniqueidentifier	NOT NULL	So với account.security_stamp
created_at	datetime2(3)	NOT NULL	
last_refreshed_at	datetime2(3)	NULL	

Column	Type	Constraints	Notes
revoked_at	datetime2(3)	NULL	
revoke_reason	varchar(30)	NULL	LOGOUT, PASSWORD_CHANGED, RECOVERY, ACCOUNT_LOCKED, …
ip / user_agent	varchar(45) / nvarchar(300)	NULL	

3.9 auth.otp_verification

Entity: — (kỹ thuật: lần xác minh mã SMS/email UC01–UC05, UC08). Module: AUTH.

Column	Type	Constraints	Notes
verification_id	uniqueidentifier	PK; PRIMARY KEY	Trả cho client
target	nvarchar(254)	NOT NULL	Số E.164 hoặc email đích
purpose	varchar(20)	CHECK IN ('REGISTER','RECOVER','CHANGE_PASSWORD','VERIFY_EMAIL','VERIFY_PHONE')	
channel	varchar(10)	CHECK IN ('SMS','EMAIL')	
account_id	bigint	FK; NULL → auth.account	NULL khi REGISTER
code_hash	binary(32)	NULL khi QUEUED	HMAC-SHA256(mã 6 chữ số, khóa bí mật)
expires_at	datetime2(3)	NULL khi QUEUED	Lúc gửi + 5 phút (QĐ-18)
attempt_count	tinyint	NOT NULL DEFAULT 0	
send_count	tinyint	NOT NULL DEFAULT 1	
state	varchar(12)	CHECK IN ('QUEUED','PENDING','SEND_FAILED','VERIFIED','CONSUMED','EXPIRED','LOCKED','CANCELLED')	Trạng thái kỹ thuật (nhóm D), không thuộc sys.status
proof_token_hash	binary(32)	NULL; UNIQUE (lọc NOT NULL)	verificationToken dùng một lần
provider_message_id	varchar(100)	NULL	Đối chiếu nhà cung cấp
created_at / verified_at / consumed_at	datetime2(3)		
request_ip	varchar(45)	NULL	Giới hạn tần suất theo IP

3.10 coop.cooperative

Entity: E01 Cooperative. Module: COOP.

Column	Type	Constraints	Notes
coop_id	bigint	PK; IDENTITY PRIMARY KEY	
provisional_code	varchar(20)	NOT NULL; UNIQUE	Mã sơ bộ (UC72)
full_name	nvarchar(255)	NOT NULL	Hiện trên trang QR
tax_code	varchar(14)	NULL; UNIQUE (lọc NOT NULL); CHECK mẫu 10 số hoặc 10 số-3 số	Bắt buộc để sang COMPLETED
office_address	nvarchar(500)	NULL	Hiện trên trang QR
phone_e164	varchar(16)	NULL	
email	nvarchar(254)	NULL	
website	nvarchar(255)	NULL	
legal_representative	nvarchar(150)	NULL	
bank_bin	varchar(8)	NULL	Mã ngân hàng theo danh sách VietQR (chọn ở SCR-07). Bắt buộc khi lưu hồ sơ ở UC09 (QĐ-29); NULL chỉ khi hồ sơ mới tạo ở UC72
bank_account_no	varchar(30)	NULL	Số tài khoản nhận chuyển khoản; dùng tạo QR VietQR ở UC48; không hiện trên trang QR

Column	Type	Constraints	Notes
bank_account_name	nvarchar(100)	NULL	Tên chủ tài khoản
verification_file_key	varchar(300)	NULL	Ảnh giấy tờ (UC72) trên lưu trữ đám mây
status_id	smallint	FK; NOT NULL → sys.status (nhóm COOPERATIVE)	DRAFT | COMPLETED
status_group	AS 'COOPERATIVE' PERSISTED	FK ghép (status_id, status_group) → sys.status(status_id, group_code)	Bảo đảm đúng nhóm trạng thái (BR-29)
permission_version	int	NOT NULL DEFAULT 0	Tăng khi đổi vai trò/grant/khóa → làm mới cache quyền
created_at … row_version			Cột chung

3.11 coop.cooperative_business_line

Entity: E01 Cooperative (ngành nghề, đa trị). Module: COOP.

Column	Type	Constraints	Notes
coop_id	bigint	PK, FK; → coop.cooperative ON DELETE CASCADE	
line_no	smallint	PK; NOT NULL	Thứ tự hiển thị
description	nvarchar(255)	NOT NULL	Ngành, nghề đã đăng ký

3.12 coop.employee

Entity: E03 Employee. Module: COOP.

Column	Type	Constraints	Notes
employee_id	bigint	PK; IDENTITY PRIMARY KEY	
coop_id	bigint	FK; NOT NULL → coop.cooperative	
full_name	nvarchar(150)	NOT NULL	
full_name_norm	nvarchar(150)	NOT NULL	Chữ thường, bỏ dấu, gộp khoảng trắng (chống trùng)
phone_e164	varchar(16)	NOT NULL; UNIQUE(coop_id, phone_e164, full_name_norm)	MSG03 khi trùng
account_id	bigint	FK; NULL → auth.account; UNIQUE (lọc NOT NULL)	≤ 1 tài khoản (MSG24)
birthday	date	NULL	
address / area / ward	nvarchar(500) / nvarchar(100) / nvarchar(100)	NULL	
other_info / note	nvarchar(1000)	NULL	
status_id	smallint	FK; NOT NULL → sys.status (nhóm EMPLOYEE)	WORKING | LEFT
status_group	AS 'EMPLOYEE' PERSISTED	FK ghép (status_id, status_group) → sys.status(status_id, group_code)	Bảo đảm đúng nhóm trạng thái (BR-29)
created_at … row_version			Cột chung

3.13 coop.role

Entity: E04 Role. Module: COOP.

Column	Type	Constraints	Notes
role_id	bigint	PK; IDENTITY PRIMARY KEY	
coop_id	bigint	FK; NOT NULL → coop.cooperative	
name	nvarchar(100)	NOT NULL; UNIQUE(coop_id, name)	MSG03 khi trùng
description	nvarchar(500)	NULL	
status_id	smallint	FK; NOT NULL → sys.status (nhóm USAGE)	IN_USE | OUT_OF_USE

Column	Type	Constraints	Notes
status_group	AS 'USAGE' PERSISTED	FK ghép (status_id, status_group) → sys.status(status_id, group_code)	Bảo đảm đúng nhóm trạng thái (BR-29)
created_at … row_version			Cột chung

3.14 coop.app_feature

Entity: — (danh mục chức năng cố định của hệ thống). Module: COOP.

Column	Type	Constraints	Notes
feature_code	varchar(40)	PK; PRIMARY KEY	Seed từ FeatureCatalog (code)
name	nvarchar(100)	NOT NULL	
module	varchar(10)	NOT NULL	AUTH, COOP, FARM, …
supports_crud	char(4)	NOT NULL	Cờ C/R/U/D hỗ trợ, VD 'CRU-'
other_actions	varchar(100)	NULL	VD 'EXPORT,IMPORT'
supports_own_scope	bit	NOT NULL	Cho phép phạm vi 'bản ghi của mình'
zone_scoped	bit	NOT NULL	Dữ liệu gắn khu hay toàn HTX
sort_order	smallint	NOT NULL	

3.15 coop.role_permission

Entity: E05 RolePermission. Module: COOP.

Column	Type	Constraints	Notes
role_id	bigint	PK, FK; → coop.role ON DELETE CASCADE	
feature_code	varchar(40)	PK, FK; → coop.app_feature	
can_create / can_read / can_update / can_delete	bit × 4	NOT NULL DEFAULT 0	Chỉ bật quyền chức năng hỗ trợ
other_actions	varchar(100)	NULL	Tập con app_feature.other_actions
data_scope	varchar(4)	NOT NULL; CHECK IN ('OWN','ZONE')	Bản ghi của mình / toàn khu được gán
(ràng buộc bảng)		CK_role_permission_read: can_read = 1 OR (can_create = 0 AND can_update = 0 AND can_delete = 0 AND other_actions IS NULL)	Có quyền khác thì phải có Xem (QĐ-16)

3.16 coop.access_grant

Entity: E06 AccessGrant. Module: COOP.

Column	Type	Constraints	Notes
grant_id	bigint	PK; IDENTITY PRIMARY KEY	
account_id	bigint	FK; NOT NULL → auth.account	
role_id	bigint	FK; NOT NULL → coop.role	
zone_id	bigint	FK; NULL → farm.farming_zone	NULL = Toàn bộ khu
scope_type	varchar(10)	CHECK IN ('ZONE','ALL_ZONES') và khớp zone_id	
valid_from	date	NOT NULL	
valid_to	date	NULL; CHECK ≥ valid_from	"Hết hạn" suy ra, không là trạng thái
status_id	smallint	FK; NOT NULL → sys.status (nhóm ACCESS_GRANT)	EFFECTIVE | REVOKED
status_group	AS 'ACCESS_GRANT' PERSISTED	FK ghép (status_id, status_group) → sys.status(status_id, group_code)	Bảo đảm đúng nhóm trạng thái (BR-29)
granted_by_account_id	bigint	FK; NOT NULL → auth.account	Người cấp
granted_at	datetime2(3)	NOT NULL	
revoked_by_account_id	bigint	FK; NULL → auth.account	
revoked_at	datetime2(3)	NULL	Có giá trị ⇔ REVOKED

Column	Type	Constraints	Notes
revoke_reason	nvarchar(500)	NULL; CHECK revoked_at IS NULL OR revoke_reason IS NOT NULL	Bắt buộc khi thu hồi (QĐ-16)

3.17 Chỉ mục và view

Bảng	Chỉ mục	Mục đích
auth.account	IX_account_coop_status (coop_id, status_id)	Danh sách tài khoản theo HTX/trạng thái (SCR-09)
auth.account	UX_account_username (username) WHERE username IS NOT NULL	Đăng nhập bằng tên đăng nhập
auth.account	UX_account_phone (phone_e164) WHERE phone_e164 IS NOT NULL	Đăng nhập, khôi phục bằng số điện thoại (BR-32)
auth.account	UX_account_email (email) WHERE email_verified_at IS NOT NULL	Đăng nhập, khôi phục bằng email đã xác minh (BR-32)
auth.auth_session	IX_session_account_active (account_id) WHERE revoked_at IS NULL	Thu hồi mọi phiên khi khóa/đổi mật khẩu
auth.otp_verification	IX_otp_target_purpose (target, purpose, created_at DESC)	Giới hạn gửi lại theo số/mục đích
auth.otp_verification	IX_otp_expire (state, expires_at) WHERE state IN ('PENDING','VERIFIED')	JOB-01 quét mã hết hạn
coop.employee	IX_employee_search (coop_id, full_name_norm) INCLUDE (phone_e164, status_id)	Tìm theo tên (UC10 bước 1)
coop.access_grant	IX_grant_account (account_id, status_id) INCLUDE (role_id, zone_id, valid_from, valid_to)	Tính quyền hiệu lực mỗi lần đổi version
coop.access_grant	IX_grant_role (role_id, status_id)	Chặn ngừng dùng vai trò, đếm người giữ (UC12)
coop.access_grant	UX_grant_active (account_id, role_id, zone_id) WHERE revoked_at IS NULL	Không cấp trùng một cặp khu – vai trò còn hiệu lực
sys.audit_event	IX_audit_coop_time (coop_id, occurred_at DESC)	Tra cứu UC75
sys.audit_event	IX_audit_entity (entity_type, entity_id, occurred_at DESC)	Lịch sử một bản ghi
sys.outbox_message	IX_outbox_pending (next_attempt_at) WHERE processed_at IS NULL	Worker lấy việc
sys.v_security_context	View: auth_session ⋈ auth.account ⋈ coop.cooperative (permission_version)	Một truy vấn PK cho SessionValidationMiddleware

II. Detailed Code Design

Mục này thiết kế chi tiết hai package đã đặc tả đủ trong SRS: AUTH (UC01–UC08) và COOP (UC09–UC12). Các package khác (FARM, CATALOG, CULT, TRACE, SALES, PAY, LABOR, NOTI, RPT, ADMIN) dùng cùng quy ước ở mục 1 và sẽ được bổ sung ở các phiên bản sau.

1. Quy ước thiết kế chung cho các package

Mục này cố định các quy ước mà mọi package dùng chung, để phần thiết kế AUTH (mục 2) và COOP (mục 3) chỉ mô tả phần riêng. SRS v5.8 (Report 3) là nguồn yêu cầu; SDS chỉ quyết định cách hiện thực. Giá trị chính sách đã chốt ngày 06/10/2026 (SRS QĐ-16…QĐ-18) nằm trong cấu hình (mục 1.6); điểm còn mở (nhà cung cấp, tên miền) ghi ở mục 4 và không gán giá trị tự đặt.

1.1 Cấu trúc module và trách nhiệm của từng layer

Backend là một modular monolith .NET 8 (một tiến trình ASP.NET Core Web API và một tiến trình Worker), mỗi package nghiệp vụ của SRS là một module độc lập gồm 4 project. Module chỉ gọi nhau qua interface đặt trong `Omts.Contracts`; không module nào tham chiếu project của module khác.

Bảng II-1. Layer của một module backend

Layer / project	Namespace mẫu	Trách nhiệm	Được tham chiếu tới
Api	Omts.Modules.Identity.Api	Controller, DTO request/response, validator (FluentValidation), gắn policy [HasPermission]/[AllowAnonymous], ánh xạ kết quả → HTTP. Không chứa quy tắc nghiệp vụ.	Application, Contracts, SharedKernel
Application	…Identity.Application	Service theo use case (một phương thức = một lệnh/truy vấn), kiểm phạm vi bản ghi (IZoneScopeGuard), mở/đóng giao dịch (IUnitOfWork), gọi contract module khác và port dịch vụ ngoài, ghi audit.	Domain, Contracts, SharedKernel
Domain	…Identity.Domain	Entity, value object, enum, bất biến nghiệp vụ (ví dụ không khóa Owner, quyền vai trò chỉ gồm hành động chức năng hỗ trợ). Không phụ thuộc EF Core hay HTTP.	SharedKernel
Infrastructure	…Identity.Infrastructure	Repository (EF Core 8), cấu hình EF (IEntityTypeConfiguration), hiện thực port nội bộ (ILoginThrottle, IOtpCrypto…), đăng ký DI của module.	Application, Domain, Persistence
Omts.Contracts	Omts.Contracts.Identity …	Interface + DTO công bố cho module khác (IAccountProvisioning, IEffectivePermissionService…) và port dịch vụ ngoài (ISmsSender, IEmailSender…).	SharedKernel
Omts.SharedKernel	Omts.SharedKernel	Entity base, Result/Error, IClock, PhoneNumber, ProblemDetails mapper, Shared.Authorization (ICurrentUser, HasPermissionAttribute, PermissionRequirement).	—
Omts.Persistence	Omts.Persistence	OmtsDbContext duy nhất (schema theo module), IUnitOfWork, interceptor audit cột chung, migration. Nạp cấu hình EF của module theo assembly, không tham chiếu project module.	SharedKernel
Omts.Integrations	Omts.Integrations.Sms …	Adapter dịch vụ ngoài hiện thực port trong Contracts; HttpClient có timeout/retry/circuit breaker (Polly).	Contracts
Omts.Host / Omts.Worker	Omts.Host	Composition root: Program.cs, middleware, DI, cấu hình Options; Worker chạy JOB-01…07 và outbox dispatcher.	Mọi project

Quy tắc phụ thuộc được kiểm bằng test kiến trúc (NetArchTest) trong CI: Domain không tham chiếu EF Core; Api không tham chiếu Infrastructure; module A không tham chiếu bất kỳ project nào của module B.

1.2 Quy ước API

- REST/JSON, tiền tố `/api/v1`; tên tài nguyên số nhiều, kebab-case (`/user-accounts`); JSON camelCase; thời gian ISO-8601 UTC, client hiển thị theo giờ Việt Nam (NFR-07).
- Lệnh đổi trạng thái là sub-resource động từ (`POST /user-accounts/{id}/lock`) vì cần lý do và kiểm chuyển trạng thái (BR-30).
- Bản ghi sửa được trả `ETag` (base64 của rowversion). PUT bắt buộc `If-Match`; thiếu → 428, không khớp → 409 MSG06 (NFR-09).
- Danh sách: `?q=&status=&page=&size=` (size tối đa cấu hình), trả `{items, page, size, total}`.
- Lỗi trả RFC 7807 ProblemDetails mở rộng: `{type, title, status, code: "MSGxx", params, errors: {field: [MSGxx]}, traceId}`. Client dịch code sang câu chữ ở `packages/messages`; máy chủ không ghép câu tiếng Việt.
- OpenAPI sinh từ controller; `packages/api-client` (TypeScript) được sinh lại trong CI, Web và Mobile chỉ gọi API qua gói này.

1.3 Mô hình lỗi và ánh xạ thông điệp

Bảng II-2. Ánh xạ exception → HTTP → MSG

Lỗi trong code	Ném ở đâu	HTTP	Mã MSG	Ghi chú
ValidationException (FluentValidation)	Api (validator) / Application	400	MSG01	errors theo trường
ForbiddenException	Authorization handler / IZoneScopeGuard / IGrantGuard	403	MSG02	Ghi audit SECURITY.DENIED khi cấp quyền Owner/Admin (UC11 4b)
DuplicateException	Application (kiểm trước) + bắt lỗi UNIQUE 2601/2627	409	MSG03 / MSG14 / MSG24	Trả kèm existingId khi được phép xem
ConcurrencyException (DbUpdateConcurrencyException)	IUnitOfWork.CommitAsync	409	MSG06	Kèm người và thời điểm sửa cuối
StatusTransitionDeniedException	IStatusTransitionService.EnsureAllowed	409	MSG61	params: object, current, new, reason
DependencyBlockedException	Application (ngừng dùng vai trò; UC11 không xóa tài khoản)	409	MSG11	params: count, related_list
ExternalServiceUnavailableException	Adapter sau khi hết retry / circuit mở	503	MSG04	params: service_name; dữ liệu OMTS giữ nguyên
AuthenticationFailedException	AuthService	401 / 403 / 429	MSG12 / MSG13 / MSG68 / MSG69	Thông báo chung, không nói sai trường nào; MSG68 mật khẩu tạm quá hạn, MSG69 khóa tạm 15 phút
SessionInvalidException	SessionValidationMiddleware, Refresh	401	MSG19	Client xóa token, về UC02
RateLimitRejected	ASP.NET Core RateLimiter	429	MSG16 (OTP) / —	Header Retry-After
Lỗi không lường trước	ExceptionHandler toàn cục	500	—	Chỉ trả traceId; log chi tiết

1.4 Xác thực, phân quyền và phạm vi dữ liệu

Kiểm quyền đặt ở năm lớp, mỗi lớp có trách nhiệm riêng; lớp sau không thay lớp trước. Thiết kế lớp ở Hình CLS-COOP-AUTHZ và luồng ở SEQ-COOP-04 (mục 3).

Bảng II-3. Các lớp kiểm quyền

#	Lớp (boundary)	Thành phần	Kiểm gì	Kết quả sai
1	Xác thực token	JwtBearer (RS256)	Chữ ký, hạn, issuer/audience của access token	401
2	Phiên	SessionValidationMiddleware + SecurityContextLoader	Phiên chưa thu hồi/hết hạn; security_stamp khớp; tài khoản ACTIVE; nạp permission_version của HTX	401 MSG19
3	Chức năng (endpoint)	[HasPermission(feature, action)] → PermissionAuthorizationHandler; policy OwnerOnly, PlatformAdmin, TraderSelf	Owner: mọi chức năng nghiệp vụ; Admin: chỉ chức năng nền tảng; Nhân viên: có hành động ở ít nhất một cặp khu – vai trò hiệu lực; Thương lái: chỉ API tự phục vụ	403 MSG02
4	Bản ghi (resource)	Service gọi IZoneScopeGuard.EnsureCan(feature, action, zoneId, ownerId); danh sách dùng AllowedZones()	zone_id của bản ghi thuộc khu được gán; dữ liệu chung HTX (không có zone_id) cần grant Toàn bộ khu; data_scope OWN → người tạo/phụ trách là chính mình	403 MSG02
5	Bất biến domain	IGrantGuard, entity	Không cấp vai trò Owner/Admin; không khóa Owner/Admin; không gán vai trò Ngừng dùng	403 MSG02 / 409
+	Tenant	CoopTenantQueryFilter (EF global filter)	Mọi truy vấn bảng có coop_id lọc theo HTX của phiên	404 (không lộ tồn tại)

Quyền không nằm trong JWT. Mỗi request đọc `permission_version` của HTX cùng truy vấn phiên; PermissionSet được cache theo khóa (accountId, permission_version, ngày). Mọi thao tác đổi vai trò, cặp khu – vai trò hoặc khóa tài khoản tăng `permission_version` trong cùng giao dịch, nên request kế tiếp trên mọi instance dùng quyền mới (BR-19, AC-02).

1.5 Giao dịch, đồng thời, audit và outbox

- **Ranh giới giao dịch**: một lệnh của Application = một giao dịch (IUnitOfWork). Ghi AuditEvent và outbox nằm trong cùng giao dịch với thay đổi nghiệp vụ, nên không có thay đổi mà thiếu audit (NFR-02).
- **Gọi dịch vụ ngoài**: không gọi trong giao dịch đang mở. Lệnh cần kết quả ngay (gửi OTP) commit trạng thái chờ trước, gọi adapter, rồi commit kết quả gửi ở giao dịch ngắn thứ hai. Thông báo không cần chờ (push, email thông tin) đi qua outbox do Worker gửi, có thử lại.
- **Đồng thời**: bảng sửa được có cột rowversion; EF dùng làm concurrency token. Database bật READ_COMMITTED_SNAPSHOT để đọc không chặn ghi.
- **Chuyển trạng thái**: luôn qua IStatusTransitionService.EnsureAllowed (bảng sys.status_transition) rồi mới gán status_id; audit `STATUS.CHANGE` có trạng thái cũ, mới và lý do (BR-29, BR-30).
- **Dữ liệu nhạy cảm trong audit**: serializer audit bỏ các thuộc tính đánh dấu [Sensitive] (mật khẩu, hash, mã OTP, token).

1.6 Cấu hình (Options) và giá trị chính sách

Mọi tham số chính sách là lớp Options được kiểm khi khởi động (`ValidateOnStart`). Giá trị đã chốt ngày 06/10/2026 nằm trong `appsettings.json` dùng chung cho mọi môi trường; test cấu hình so giá trị nạp được với bảng dưới để không ai đổi lệch SRS. Cột Nguồn: QĐ-xx = quyết định ghi ở OMTS Decision Log (tách khỏi SRS v5.8 V.3.2 ngày 07/10/2026); "Thiết kế" = giá trị kỹ thuật SDS tự đặt, chờ PM/Technical Lead duyệt cùng tài liệu. Tham số còn chờ chốt không có giá trị mặc định: thiếu cấu hình thì adapter tương ứng không khởi động.

Bảng II-4. Lớp cấu hình dùng bởi AUTH và COOP

Options	Tham số	Dùng ở	Giá trị	Nguồn
OtpOptions	CodeLength, Ttl, MaxVerifyAttempts, MaxSends, ResendCooldown	UC01–UC05, UC08	6 chữ số; 5 phút; 5 lần nhập sai; 3 lần gửi cho một lần xác minh; 60 giây giữa hai lần gửi; cùng giá trị cho SMS và email	QĐ-18, QĐ-21
	ProofTokenTtl	UC01–UC05	10 phút (từ lúc nhập đúng mã tới lúc hoàn tất)	Thiết kế
PasswordPolicyOptions	MinLength, RequireLetter, RequireDigit, MaxLength	UC01, UC03, UC04, UC11	≥ 8 ký tự, có ít nhất một chữ và một chữ số; tối đa 128 ký tự	QĐ-18; MaxLength: Thiết kế
SessionOptions	AccessTokenLifetime; RefreshSlidingLifetime (Web / Mobile); RefreshAbsoluteLifetime (Web / Mobile)	UC02, UC07	15 phút; 7 / 30 ngày; 30 / 90 ngày	QĐ-18
	RevokeOtherSessionsOnPasswordChange	UC04	true (đổi mật khẩu thu hồi các phiên khác)	Thiết kế
LoginThrottleOptions	MaxFailures, LockoutDuration	UC02 2e	5 lần sai liên tiếp → khóa tạm 15 phút	QĐ-18
RateLimiter (policy login, otp)	PermitLimit, Window theo IP; otp thêm theo số điện thoại/email đích	UC01–UC05, UC08	login: 20 yêu cầu/phút/IP; otp: 10 yêu cầu/giờ/IP và 5 yêu cầu/giờ/đích	Thiết kế
TemporaryPasswordOptions	Length, Lifetime	UC11 (tạo tài khoản, 1d)	10 ký tự; hiệu lực 24 giờ; buộc đổi khi đăng nhập	QĐ-16
Kênh ngoài (SmsProvider, EmailProvider, PushProvider)	Endpoint, credential, timeout	API-01…03	Chờ chốt: nhà cung cấp chưa chọn. Secret ở secret store, nhập qua UC73	OD-11

Ba điểm v1.0 dự kiến để cấu hình nay là quy tắc cố định trong code: một khu có nhiều tài khoản cùng vai trò, kể cả Quản lý khu (không có ràng buộc duy nhất theo khu – vai trò, QĐ-16); có Tạo/Sửa/Xóa/khác thì bắt buộc có Xem (RolePermission tự bật Xem, CHECK ở database – mục 3.3, QĐ-16); tài khoản thương lái và nhân viên phải có số điện thoại đã xác minh trước khi dùng chức năng khác (BR-34, QĐ-21 thay ý "nhân viên không xác minh số" của QĐ-16): Chủ HTX nhập số ở UC11, nhân viên xác minh bằng mã SMS ở lần đăng nhập đầu (UC02 3a).

2. AUTH – Xác thực và tài khoản cá nhân (UC01–UC08)

2.1 Phạm vi, module và phụ thuộc

Module `Omts.Modules.Identity` hiện thực UC01–UC08 (SCR-01…SCR-06) và cung cấp contract tài khoản cho COOP (UC11), ADMIN (UC72, UC74). Phiên đăng nhập, lần xác minh OTP và thiết bị nhận push là dữ liệu kỹ thuật SRS giao cho SDS (E02, UC08).

Bảng II-5. Use case của AUTH

UC	Tên	Actor	Service chính	Màn hình
UC01	Đăng ký tài khoản khách hàng	Thương lái	RegistrationService	SCR-01, SCR-02
UC02	Đăng nhập	Admin, Chủ HTX, Nhân viên, Thương lái	AuthService; ProfileService (3a)	SCR-03, SCR-02
UC03	Khôi phục tài khoản tự phục vụ	Thương lái, Chủ HTX, Nhân viên	PasswordRecoveryService	SCR-04, SCR-02
UC04	Đổi mật khẩu	Mọi tài khoản	PasswordService	SCR-05
UC05	Quản lý hồ sơ cá nhân	Mọi tài khoản	ProfileService	SCR-05
UC06	Quản lý tùy chọn thông báo	Mọi tài khoản	NotificationPreferenceService	SCR-06
UC07	Đăng xuất	Mọi tài khoản	AuthService.LogoutAsync	SCR-05
UC08	Xác minh email hoặc số điện thoại	Thương lái, Chủ HTX, Nhân viên, Quản trị hệ thống (UC01, UC03 «include»; «extend» UC02, UC05)	OtpVerificationService	SCR-02

OtpVerificationService hiện thực UC08 cho hai kênh SMS và email, với các mục đích REGISTER (UC01), RECOVER (UC03), VERIFY_EMAIL (UC05 3a), VERIFY_PHONE (UC02 3a, BR-34) và CHANGE_PASSWORD (mã email ở UC04 2a). Theo BR-31 (QĐ-20), mã khôi phục chỉ gửi tới đúng email hoặc số điện thoại đã xác minh mà người dùng nhập, không tự chuyển sang kênh khác; mã đổi mật khẩu gửi qua email đã xác minh. Mã gửi qua email dùng cùng OtpOptions với SMS (QĐ-21).

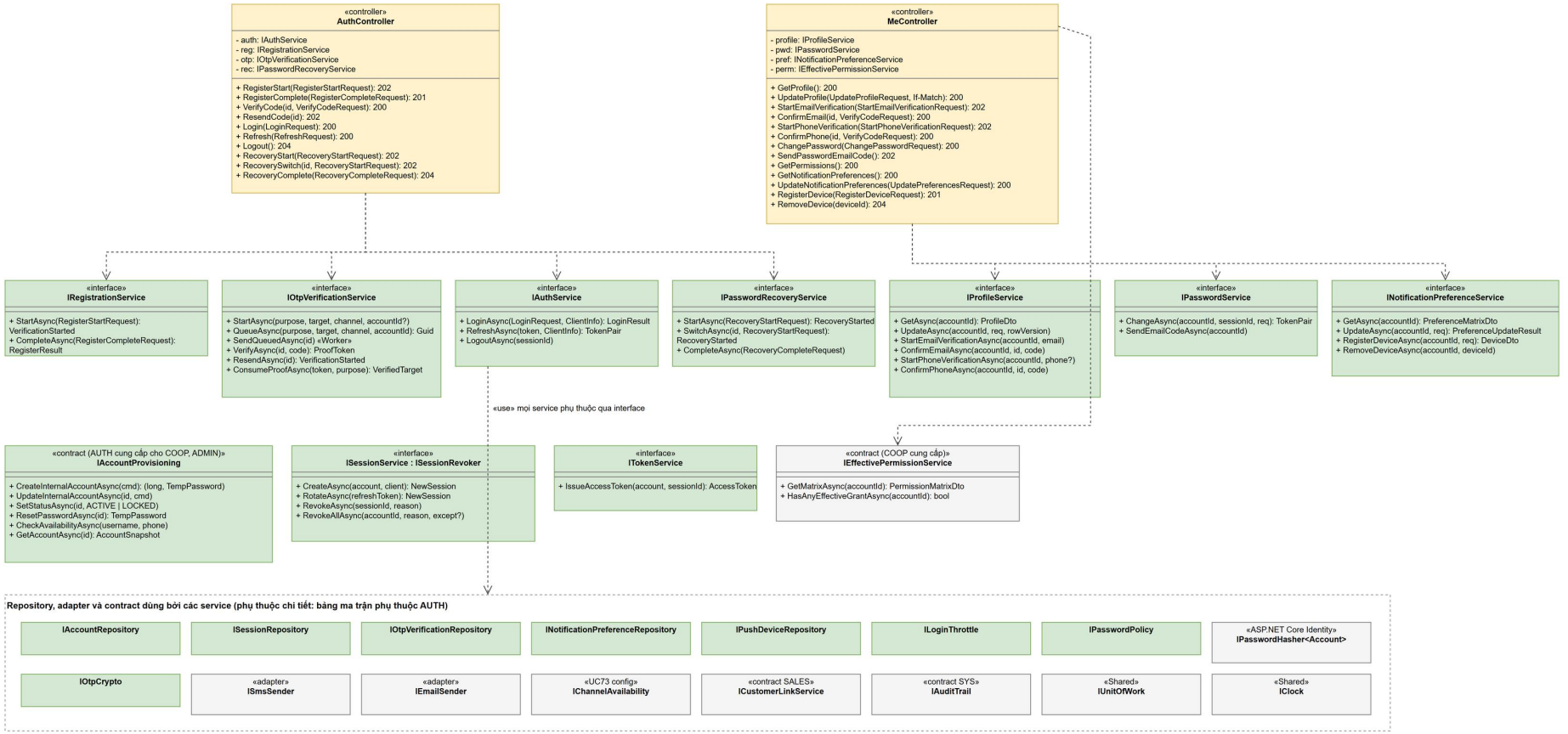
```
src/Modules/Identity/
  Omts.Modules.Identity.Api/             AuthController, MeController, Requests/, Responses/, Validators/
  Omts.Modules.Identity.Application/     Registration/, Login/, Recovery/, Password/, Profile/,
                                         Preferences/, Verification/
  Omts.Modules.Identity.Domain/          Account, AuthSession, OtpVerification,
                                         NotificationPreference, PushDevice, enums
  Omts.Modules.Identity.Infrastructure/  Persistence/ (EF config, repositories), LoginThrottle,
                                         OtpCrypto, AccountProvisioning
src/Contracts/Omts.Contracts/Identity/   IAccountProvisioning, ISessionRevoker, AccountSnapshot
src/Contracts/Omts.Contracts/Messaging/  ISmsSender, IEmailSender, IPushSender
```

Bảng II-6. Phụ thuộc của AUTH

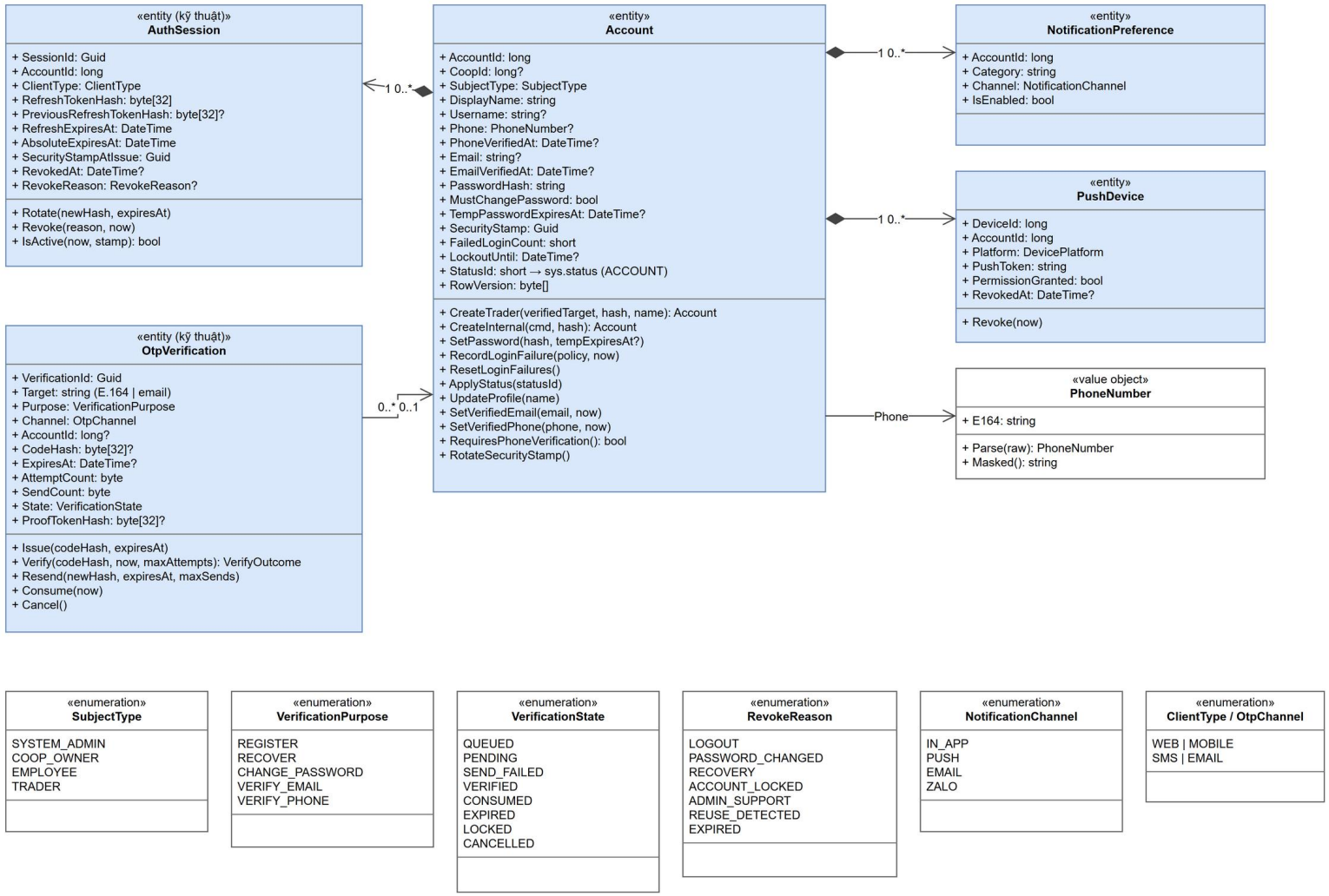
AUTH dùng	Qua interface	Module cung cấp	Để làm gì
Quyền hiệu lực	IEffectivePermissionService	COOP	UC02: chặn nhân viên không còn cặp khu – vai trò (MSG13); /me/permissions
Liên kết khách offline	ICustomerLinkService	SALES	UC01 bước 4, chỉ khi đăng ký bằng số điện thoại: ghép đúng một hồ sơ khách cùng số đã xác minh, hoặc tạo mới; đăng ký bằng email luôn tạo hồ sơ mới (4a). Thương lái thêm số (UC02 3a4) hoặc đổi số (UC05 3b3): ghép hồ sơ offline khớp duy nhất vào hồ sơ khách của tài khoản, không khớp duy nhất → MANUAL_MATCH (MSG57)
Kênh khả dụng	IChannelAvailability	ADMIN (UC73)	UC06: kênh email/Zalo đã cấu hình chưa (MSG21)
Danh mục thông báo	INotificationCatalog	NOTI	UC06: danh mục, mục bắt buộc (cảnh báo nước, đơn mới, QR đã gửi)
Audit, trạng thái	IAuditTrail, IStatusTransitionService	SYS	Ghi sự kiện, kiểm chuyển ACCOUNT
SMS / email	ISmsSender, IEmailSender	Integrations	API-01, API-03

Module khác dùng AUTH	Interface	Mục đích
COOP (UC11)	IAccountProvisioning	Tạo/sửa tài khoản nội bộ, đổi trạng thái, đặt lại mật khẩu, kiểm trùng
COOP (UC11), ADMIN (UC74)	ISessionRevoker	Thu hồi phiên khi khóa tài khoản / hỗ trợ truy cập
ADMIN (UC72)	IAccountProvisioning.CreateOwnerAsync	Tạo tài khoản Chủ HTX đầu tiên
Host (mọi request)	SecurityContextLoader (đọc view sys.v_security_context)	Kiểm phiên, trạng thái tài khoản

2.2 Class Diagram



Hình 4. AUTH – lớp API, application service, contract và port (CLS-AUTH-APP)



Hình 5. AUTH – mô hình domain (CLS-AUTH-DOM)

Bảng II-7. Mô tả class AUTH

Class / interface	Layer	Trách nhiệm	UC
AuthController	Api	Endpoint ẩn danh: đăng ký, xác minh mã, đăng nhập, làm mới token, đăng xuất, khôi phục	UC01–03, 07, 08
MeController	Api	Endpoint của chính người dùng: hồ sơ, xác minh email, xác minh số điện thoại sau đăng nhập, đổi mật khẩu, quyền của tôi, tùy chọn thông báo, thiết bị	UC02, 04–06
RegistrationService	Application	Kiểm email hoặc số điện thoại chưa có tài khoản, mở lần xác minh REGISTER qua kênh tương ứng, tạo Account TRADER sau khi tiêu thụ proof; đăng ký bằng số điện thoại thì gọi ICustomerLinkService	UC01
OtpVerificationService	Application	Tạo mã, lưu HMAC, gửi qua ISmsSender hoặc IEmailSender theo kênh, gửi ngay hoặc qua outbox, kiểm mã/hạn/lượt, phát và tiêu thụ verificationToken	UC08 (dùng bởi UC01, UC02 3a, UC03, UC04 2a, UC05 3a)
AuthService	Application	Đăng nhập (throttle, kiểm mật khẩu, trạng thái, grant), tạo phiên + token kèm cờ mustChangePassword, phoneVerificationRequired; refresh xoay vòng, đăng xuất	UC02, UC07
PasswordRecoveryService	Application	Luôn phản hồi 202 MSG15; nhận email hoặc số điện thoại, chỉ gửi mã tới đúng định danh đó khi đã xác minh và tài khoản đủ điều kiện; đổi cách nhận mã (3a) hủy lần trước; xác minh RECOVER, đặt mật khẩu mới, thu hồi mọi phiên	UC03, BR-31
PasswordService	Application	Đổi mật khẩu bằng mật khẩu hiện tại hoặc mã email; xoay security_stamp; áp chính sách phiên	UC04
ProfileService	Application	Đọc/sửa tên hiển thị; thêm/đổi email bằng mã VERIFY_EMAIL (UC08 «extend», chỉ ghi email sau khi xác minh); thêm (thương lái) hoặc xác minh (nhân viên, có thể nhập số khác) số điện thoại bằng mã VERIFY_PHONE, chỉ ghi phone_verified_at sau khi xác minh (UC02 3a, UC08 «extend» UC02); mọi loại tài khoản tự đổi số của chính mình qua cùng luồng, số cũ giữ tới khi số mới xác minh (UC05 3b); thương lái thêm/đổi số thì gọi ICustomerLinkService (UC02 3a4, UC05 3b3); chặn sửa tên đăng nhập ở UC05 (MSG20); không có API cho Quản trị hệ thống sửa hồ sơ	UC02 3a, UC05, BR-31–BR-34
NotificationPreferenceService	Application	Ma trận danh mục × kênh; kiểm mục bắt buộc, kênh khả dụng, đăng ký thiết bị push	UC06
SessionService (: ISessionRevoker)	Application	Tạo phiên, xoay refresh token, phát hiện dùng lại, thu hồi một/mọi phiên	UC02, 03, 04, 07, 11
TokenService	Infrastructure	Ký JWT RS256 (kid), claims sub, sid, coop, styp	UC02
AccountProvisioning (: IAccountProvisioning)	Infrastructure	Contract cho COOP/ADMIN: tạo, sửa, đổi trạng thái, đặt lại mật khẩu tài khoản nội bộ (mật khẩu tạm 10 ký tự, hạn 24 giờ)	UC11, UC72, UC74
LoginThrottle	Infrastructure	Đếm thất bại theo tài khoản (failed_login_count, lockout_until) và theo IP (RateLimiter)	UC02 2a, 2e
OtpCrypto	Infrastructure	Sinh mã ngẫu nhiên (RandomNumberGenerator), HMAC-SHA256 với khóa bí mật, so sánh thời gian hằng	UC08
Account, AuthSession, OtpVerification, NotificationPreference, PushDevice	Domain	Entity và bất biến (xem Hình CLS-AUTH-DOM)	—

2.3 API Endpoints

Base path `/api/v1`. Cột Quyền: Anonymous = không cần đăng nhập, có rate limit; Authenticated = mọi tài khoản đã đăng nhập (chỉ dữ liệu của chính mình, † trong ma trận quyền SRS).

Bảng II-8. API của AUTH

Method	Path	UC	Quyền	Request → Response	Lỗi / MSG
POST	/auth/register/start	UC01, UC08	Anonymous (rate limit otp)	RegisterStartRequest → 202 VerificationStartedResponse	400 MSG01; 409 MSG14; 429; 503 MSG04
POST	/auth/verifications/{id}/verify	UC08	Anonymous	VerifyCodeRequest → 200 VerificationProofResponse	400 MSG16 (+ remainingAttempts)
POST	/auth/verifications/{id}/resend	UC08 3a	Anonymous (rate limit otp)	— → 202 VerificationStartedResponse	429 MSG16; 503 MSG04 (riêng RECOVER: luôn 202 MSG15)
POST	/auth/register/complete	UC01	Anonymous	RegisterCompleteRequest → 201 RegisterResponse	400 MSG01, MSG16; 409 MSG14
POST	/auth/login	UC02	Anonymous (rate limit login)	LoginRequest → 200 TokenResponse (+ Set-Cookie refresh cho Web)	401 MSG12, MSG68; 403 MSG13; 429 MSG69
POST	/auth/token/refresh	UC02	Refresh token (cookie / body)	RefreshRequest → 200 TokenResponse	401 MSG19
POST	/auth/logout	UC07	Access hoặc refresh token	— → 204 (lặp lại vẫn 204)	—
POST	/auth/recovery/start	UC03	Anonymous (rate limit otp)	RecoveryStartRequest → 202 RecoveryStartedResponse (MSG15)	400 MSG01; 429 (Retry-After). Không có 503 (OD-13)
POST	/auth/recovery/{id}/switch	UC03 3a	Anonymous (rate limit otp)	RecoveryStartRequest → 202 RecoveryStartedResponse (MSG15)	400 MSG01; 429
POST	/auth/recovery/complete	UC03	Anonymous + verificationToken	RecoveryCompleteRequest → 204	400 MSG01, MSG16
GET	/me	UC05	Authenticated	→ 200 ProfileDto + ETag	401 MSG19
PUT	/me	UC05	Authenticated, If-Match	UpdateProfileRequest → 200 ProfileDto	400 MSG01, MSG20; 409 MSG06; 428
POST	/me/email-verifications	UC05 3a, UC08	Authenticated (rate limit otp)	StartEmailVerificationRequest → 202 VerificationStartedResponse (MSG62)	400 MSG01; 429 MSG16; 503 MSG04 (3d)
POST	/me/email-verifications/{id}/confirm	UC05 3a	Authenticated (lần xác minh của chính mình)	VerifyCodeRequest → 200 ProfileDto (emailVerified = true)	400 MSG16 (3c); 409 MSG06
POST	/me/phone-verifications	UC02 3a, UC05 3b, UC08	Authenticated: thêm/xác minh số khi phone_verified_at NULL, hoặc đổi số của chính mình (rate limit otp)	StartPhoneVerificationRequest → 202 VerificationStartedResponse	400 MSG01 (số sai, trùng số hiện tại, đã thuộc tài khoản khác); 429 MSG16; 503 MSG04
POST	/me/phone-verifications/{id}/confirm	UC02 3a, UC05 3b	Authenticated (lần xác minh của chính mình)	VerifyCodeRequest → 200 ProfileDto (phoneVerified = true; thương lái: customerLink = LINKED | NEW | MANUAL_MATCH)	400 MSG16 (UC02 3c, UC05 3e); 409 MSG01 (số vừa bị tài khoản khác dùng); MANUAL_MATCH kèm MSG57 (UC02 3d, UC05 3g)
PUT	/me/password	UC04	Authenticated	ChangePasswordRequest → 200 TokenResponse + MSG18	400 MSG01; 400 MSG17; 401 MSG19
POST	/me/password/email-code	UC04 2a	Authenticated, có email đã xác minh	— → 202 VerificationStartedResponse	409 emailNotVerified → client hiện hướng dẫn 2b; 503 MSG04
GET	/me/permissions	UC02 b3–4	Authenticated	→ 200 PermissionMatrixDto	—
GET	/me/notification-preferences	UC06	Authenticated	→ 200 PreferenceMatrixDto	—
PUT	/me/notification-preferences	UC06	Authenticated	UpdatePreferencesRequest → 200 PreferenceUpdateResult	400 MSG21, MSG23; cảnh báo MSG22
POST	/me/devices	UC06	Authenticated	RegisterDeviceRequest → 201 DeviceDto (upsert theo token)	400 MSG01
DELETE	/me/devices/{deviceId}	UC06, UC07	Authenticated (thiết bị của mình)	→ 204	404

2.4 Request/Response DTO và validation

Bảng II-9. DTO và quy tắc kiểm tra của AUTH

DTO	Trường	Kiểu	Validation (máy chủ)	MSG
RegisterStartRequest	channel, identifier	SMS | EMAIL, string	Bắt buộc; SMS: chuẩn hóa về E.164 (PhoneNumber.Parse, mặc định +84); EMAIL: định dạng email, ≤ 254, lưu chữ thường (UC01 b1)	MSG01
	password, confirmPassword	string	Bắt buộc; PasswordPolicy (≥ 8 ký tự, có chữ và số); hai trường khớp. Chỉ kiểm sớm, không lưu ở bước này	MSG01
VerificationStartedResponse	verificationId, maskedTarget, expiresAt, resendAvailableAt, messageCode?	uuid, string, datetime	maskedTarget dạng +84•••••789 hoặc n•••@example.com	—
VerifyCodeRequest	code	string	Bắt buộc; đúng 6 chữ số (OtpOptions.CodeLength)	MSG01, MSG16
VerificationProofResponse	verificationToken, expiresAt	string, datetime	Token ngẫu nhiên 256 bit, dùng một lần, gắn purpose	—
RegisterCompleteRequest	verificationToken	string	Bắt buộc; còn hạn; purpose REGISTER; chưa tiêu thụ	MSG16
	password, confirmPassword	string	Như trên	MSG01
	displayName	string?	≤ 100 ký tự; mặc định = email hoặc số điện thoại đăng ký ẩn một phần	MSG01
RegisterResponse	accountId, customerLinkStatus, messageCode?	long, enum, string	LINKED | NEW | MANUAL_MATCH (→ MSG57); đăng ký bằng email luôn NEW (UC01 4a)	MSG57
LoginRequest	identifier	string	Bắt buộc; có "@" → email (chỉ khớp email đã xác minh, so chữ thường); chỉ chữ số/+ → số điện thoại; ngược lại là username (UC02 b1)	MSG01
	password	string	Bắt buộc; ≤ 128 ký tự	MSG01
	clientType, deviceLabel	WEB | MOBILE, string?	Bắt buộc clientType	MSG01
TokenResponse	accessToken, expiresIn, refreshToken?, mustChangePassword, phoneVerificationRequired, subjectType	string, int, string?, bool, bool, enum	refreshToken chỉ trả trong body cho MOBILE; Web nhận cookie HttpOnly. phoneVerificationRequired = true khi TRADER/EMPLOYEE chưa có phone_verified_at (BR-34)	MSG67
RecoveryStartRequest	identifier	string	Bắt buộc; email hoặc số điện thoại, nhận dạng như LoginRequest (không nhận username). Kênh = kênh của định danh; máy chủ chỉ gửi mã khi định danh đó đã xác minh (BR-31)	MSG01
RecoveryStartedResponse	verificationId, messageCode = MSG15, resendAvailableAt	uuid, string, datetime	Cùng dạng cho mọi trường hợp: không trả kênh hay địa chỉ che; id ngẫu nhiên kể cả khi không gửi mã (OD-13)	MSG15
RecoveryCompleteRequest	verificationToken, newPassword, confirmPassword	string	Token purpose RECOVER; PasswordPolicy. Sai mật khẩu → giữ token còn hạn (UC03 5a)	MSG01, MSG16
ProfileDto	accountId, displayName, phone? (chỉ đọc, che), phoneVerified, username (chỉ đọc), email, emailVerified, pendingEmail?, subjectType, coopName?, grants (chỉ đọc)		Định danh đã xác minh chỉ đọc; pendingEmail = email đang chờ nhập mã	—
StartPhoneVerificationRequest	phone?	string	Bắt buộc khi thương lái thêm số (UC02 3a) hoặc khi đổi số ở UC05 3b (mọi loại tài khoản); EMPLOYEE ở UC02 3a: bỏ trống để xác minh phone_e164 do UC11 nhập, hoặc gửi số khác. Chuẩn hóa E.164 (PhoneNumber.Parse), khác số đã xác minh hiện tại, chưa thuộc tài khoản khác (BR-32)	MSG01

DTO	Trường	Kiểu	Validation (máy chủ)	MSG
UpdateProfileRequest	displayName	string	Bắt buộc ≤ 100. Có trường username → 400 MSG20; có trường phone → 400 MSG01 (số chỉ đổi qua /me/phone-verifications); email chỉ đổi qua /me/email-verifications	MSG01, MSG20
StartEmailVerificationRequest	email	string	Bắt buộc; định dạng email, ≤ 254; khác email đã xác minh hiện tại. Email cũ giữ nguyên tới khi xác minh xong	MSG01
ChangePasswordRequest	currentPassword? | emailVerificationToken?	string	Đúng một trong hai bằng chứng (UC04 b3, 2a)	MSG01, MSG17
	newPassword, confirmPassword	string	PasswordPolicy; khác mật khẩu hiện tại	MSG01
PermissionMatrixDto	subjectType, isOwner, permissionVersion, scopes[{zoneId?, zoneName, features{code: {c,r,u,d, other[], dataScope}}}]		zoneId null = Toàn bộ khu	—
UpdatePreferencesRequest	items[{category, channel, enabled}]	array	category, channel thuộc danh mục; mục bắt buộc không được tắt; kênh phải khả dụng	MSG21, MSG23
PreferenceUpdateResult	saved[], warnings[{channel, code}]		PUSH không có thiết bị cho phép → warning MSG22, các kênh khác vẫn lưu (UC06 4a)	MSG22
RegisterDeviceRequest	platform, pushToken, permissionGranted	enum, string ≤ 512, bool	Bắt buộc cả ba	MSG01

2.5 Authorization, transaction và xử lý lỗi theo lệnh

Bảng II-10. Kiểm quyền, giao dịch và lỗi của lệnh AUTH

Lệnh	Kiểm quyền / phạm vi	Ranh giới giao dịch	Sau commit	Lỗi đặc biệt
RegisterStart	Anonymous; rate limit theo IP và theo đích	Tx1: tạo OtpVerification PENDING, channel theo cách đăng ký	Gọi ISmsSender hoặc IEmailSender; Tx2 ghi provider_message_id hoặc SEND_FAILED	MSG14 trước khi gửi mã (email hoặc số đã thuộc tài khoản); gửi lỗi → 503 MSG04
VerifyCode	Anonymous; verificationId không đoán được (UUID v4)	Tx: tăng attempt hoặc VERIFIED + proof hash	—	Vượt lượt → LOCKED, MSG16
RegisterComplete	Proof REGISTER hợp lệ	Tx: CONSUMED + Account (số hoặc email đã xác minh) + liên kết khách (đăng ký bằng số) hoặc khách mới (bằng email) + audit ACCOUNT.REGISTER	—	UNIQUE phone/email vi phạm (đăng ký đồng thời) → 409 MSG14
Login	Anonymous; throttle (5 lần sai → khóa tạm 15 phút)	Tx: reset/ghi thất bại; tạo AuthSession; last_login_at	—	Sai → MSG12 (cùng thời gian phản hồi bằng hash giả); lần sai thứ 5 hoặc đang khóa tạm → 429 MSG69 (UC02 2e); mật khẩu tạm quá 24 giờ → 401 MSG68 (UC02 2d); LOCKED/hết grant → MSG13; TRADER/EMPLOYEE chưa xác minh số → 200 với phoneVerificationRequired = true (UC02 3a, MSG67)
Refresh	Refresh token hợp lệ, phiên chưa thu hồi, stamp khớp	Tx: xoay hash; lưu previous	—	Dùng lại token cũ → thu hồi phiên (REUSE_DETECTED), 401 MSG19

Lệnh	Kiểm quyền / phạm vi	Ranh giới giao dịch	Sau commit	Lỗi đặc biệt
Logout	Phiên của chính mình	Tx: revoked_at, LOGOUT	—	Phiên hết hạn vẫn 204
RecoveryStart	Anonymous; rate limit theo IP và theo định danh; không tiết lộ tồn tại	Đủ điều kiện: Tx tạo OtpVerification QUEUED, target = định danh nhập, channel theo định danh (EMAIL hoặc SMS) + outbox SendOtp(verificationId). Không đủ: không ghi gì	Worker sinh mã, lưu HMAC, gửi; lỗi sau retry → SEND_FAILED + log	Luôn 202 MSG15, kể cả không đủ điều kiện hoặc gửi lỗi (OD-13)
RecoverySwitch (UC03 3a)	Anonymous; rate limit	Tx: lần trước (nếu id có thật, chưa dùng) → CANCELLED; định danh mới xử lý như RecoveryStart	Worker gửi qua kênh của định danh mới	Luôn 202 MSG15
RecoveryComplete	Proof RECOVER	Tx: CONSUMED + mật khẩu + security_stamp + thu hồi mọi phiên + audit	—	—
ChangePassword	Phiên hợp lệ; bằng chứng	Tx: mật khẩu + stamp + thu hồi phiên khác (theo SessionOptions) + phiên mới cho thiết bị hiện tại + audit	—	MSG17 không tăng lockout đăng nhập
UpdateProfile	Chỉ chính mình	Tx: Account.display_name (rowversion) + audit ACCOUNT.PROFILE	—	MSG06
StartEmailVerification	Chỉ chính mình; rate limit otp	Tx1: hủy lần VERIFY_EMAIL đang chờ; tạo OtpVerification VERIFY_EMAIL, target = email mới (chưa ghi vào account)	Gọi IEmailSender; Tx2 ghi kết quả gửi	Gửi lỗi → 503 MSG04, email cũ giữ nguyên (UC05 3d)
ConfirmEmail	Chỉ chính mình; lần xác minh thuộc account của phiên	Tx: CONSUMED + email = target, email_verified_at = now + audit ACCOUNT.EMAIL_VERIFIED	—	Sai/hết hạn/vượt 5 lần → MSG16 (UC05 3c)
StartPhoneVerification	Chỉ chính mình; phone_verified_at NULL (UC02 3a), hoặc đổi số (UC05 3b, mọi loại tài khoản); rate limit otp	Tx1: hủy lần VERIFY_PHONE đang chờ; tạo OtpVerification VERIFY_PHONE, channel SMS, target = số người dùng nhập (chưa ghi vào account, số cũ giữ nguyên) hoặc phone_e164 chưa xác minh của nhân viên	Gọi ISmsSender; Tx2 ghi kết quả gửi	Số đã thuộc tài khoản khác → MSG01 trước khi gửi; gửi lỗi → 503 MSG04 (UC02 3c)
ConfirmPhone	Chỉ chính mình; lần xác minh thuộc account của phiên	Tx: CONSUMED + phone_e164 = target, phone_verified_at = now + audit ACCOUNT.PHONE_VERIFIED (số cũ – số mới, che một phần); TRADER: ICustomerLinkService.LinkByPhone trong cùng giao dịch (LINKED / MANUAL_MATCH)	Lời gọi API kế tiếp qua được bộ lọc BR-34	Sai/hết hạn/vượt 5 lần → MSG16 (UC02 3c, UC05 3e); UNIQUE phone vi phạm → 409 MSG01
UpdatePreferences	Chỉ chính mình	Tx: thay toàn bộ dòng tùy chọn của tài khoản	—	MSG21, MSG23

2.6 Data Design

Bảng chi tiết ở I.3. Phần dưới ánh xạ entity SRS sang bảng, quan hệ và cách biểu diễn trạng thái.

Bảng II-11. Ánh xạ entity → bảng của AUTH

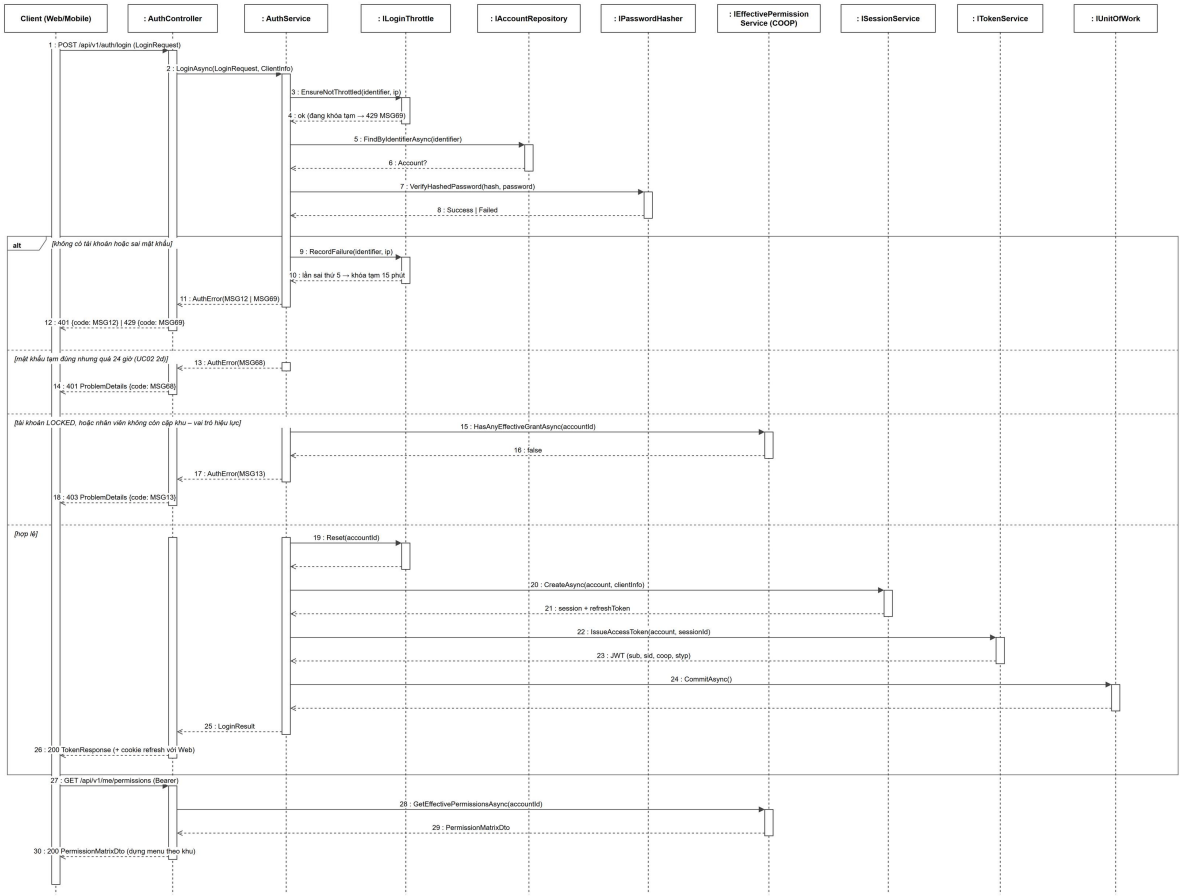
Entity SRS	Bảng	PK	FK / cardinality	Ràng buộc chính	Trạng thái
E02 Account	auth.account	account_id	coop_id → coop.cooperative (N : 0..1); status_id → sys.status	UNIQUE phone_e164 (lọc NOT NULL); UNIQUE email (lọc email_verified_at NOT NULL, BR-32); UNIQUE username (lọc NOT NULL); CHECK: COOP_OWNER/EMPLOYEE phải có coop_id, TRADER/SYSTEM_ADMIN không có; phone_e164 NULL chỉ với TRADER có email đã xác minh	ACCOUNT: ACTIVE, LOCKED (FK ghép đúng nhóm)
E02 (tùy chọn nhận thông báo)	auth.account_notification_pref	(account_id, category, channel)	account 1 : 0..*	Không có dòng = bật mặc định; mục bắt buộc kiểm ở service	—

Entity SRS	Bảng	PK	FK / cardinality	Ràng buộc chính	Trạng thái
Kỹ thuật (phiên)	auth.auth_session	session_id	account 1 : 0..*	UNIQUE refresh_token_hash	revoked_at + revoke_reason
Kỹ thuật (lần xác minh mã SMS/email)	auth.otp_verification	verification_id	account 0..1 : 0..*	CHECK purpose (REGISTER, RECOVER, CHANGE_PASSWORD, VERIFY_EMAIL, VERIFY_PHONE), channel, state	state kỹ thuật (bảng II-12)
Kỹ thuật (thiết bị push)	auth.push_device	device_id	account 1 : 0..*	UNIQUE push_token	revoked_at
E22 Customer (tham chiếu)	sales.customer.account_id	—	customer 0..1 : 0..1 account	Do SALES quản lý; AUTH chỉ gọi ICustomerLinkService	USAGE

Bảng II-12. Vòng đời kỹ thuật của auth.otp_verification

Trạng thái hiện tại	Sự kiện	Trạng thái mới	Ghi chú
(mới)	Start gửi ngay (REGISTER, CHANGE_PASSWORD, VERIFY_EMAIL, VERIFY_PHONE), gửi được	PENDING	Lưu HMAC(mã), expires_at = lúc gửi + 5 phút, send_count = 1
(mới)	Start gửi bất đồng bộ (RECOVER)	QUEUED	Chưa có mã (code_hash NULL); outbox SendOtp(verificationId)
QUEUED	Worker sinh mã và gửi được	PENDING	Mã chỉ tồn tại trong bộ nhớ Worker, không nằm trong outbox
(mới) / QUEUED / PENDING	Nhà cung cấp lỗi / timeout sau retry	SEND_FAILED	Gửi ngay: 503 MSG04. RECOVER: chỉ ghi log, phản hồi người dùng vẫn MSG15
PENDING / SEND_FAILED	Resend sau ≥ 60 giây, send_count < 3	PENDING	Thay code_hash, reset attempt, send_count + 1; mã cũ mất hiệu lực (UC08 3a)
PENDING	Mã sai, còn lượt	PENDING	attempt_count + 1, MSG16
PENDING	Mã sai lần thứ 5	LOCKED	MSG16; UC gọi phải bắt đầu lại (UC08 4b)
PENDING	Mã đúng, còn hạn	VERIFIED	Phát verificationToken (lưu hash)
VERIFIED	UC gọi tiêu thụ proof	CONSUMED	Một lần duy nhất
PENDING / VERIFIED	Quá hạn (kiểm khi dùng; JOB-01 dọn)	EXPIRED	MSG16
QUEUED / PENDING / SEND_FAILED / VERIFIED	Start mới cùng target + purpose, đổi email hoặc số nhận mã giữa chừng (UC08 3b), hoặc đổi cách nhận mã (UC03 3a)	CANCELLED	Không tái dùng mã

2.7 Sequence Diagram – Đăng nhập (UC02)

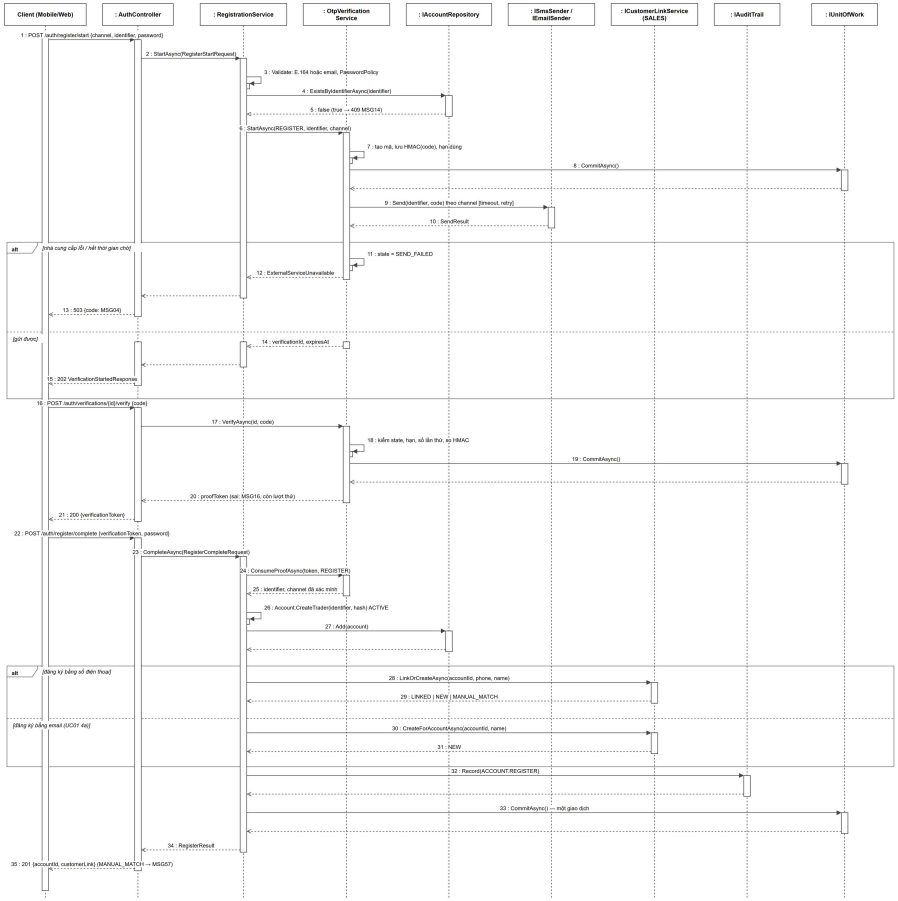


Hình 6. Đăng nhập và nạp quyền hiệu lực (SEQ-AUTH-01)

- Không tìm thấy tài khoản vẫn chạy VerifyHashedPassword với hash giả để thời gian phản hồi như nhau; thông báo chung MSG12 (UC02 2a).
- Khóa tạm do thử sai (lockout_until) là cơ chế kỹ thuật, khác trạng thái LOCKED (Chủ HTX/Admin khóa): khóa tạm trả 429 MSG69 (UC02 2e), LOCKED trả 403 MSG13 khi mật khẩu đúng.
- Nhân viên không còn cặp khu – vai trò hiệu lực bị từ chối MSG13 (UC02 2b), kể cả khi chỉ muốn xem việc, lương của mình (QĐ-16, OD-07).
- Mật khẩu tạm (UC11 khi tạo tài khoản và nhánh 1d) chỉ dùng được trong 24 giờ (temp_password_expires_at); mật khẩu tạm đúng nhưng quá hạn → 401 MSG68 (UC02 2d), phải nhờ Chủ HTX đặt lại. Đăng nhập bằng mật khẩu tạm còn hạn (UC02 2c) trả mustChangePassword = true và mọi API khác ngoài PUT /me/password trả 403 cho tới khi đổi.

- BR-34 (QĐ-21): TRADER, EMPLOYEE chưa có phone_verified_at (thương lái đăng ký bằng email, nhân viên đăng nhập lần đầu hoặc vừa được Chủ HTX đổi số ở UC11) nhận phoneVerificationRequired = true; client hiện MSG67 và mở SCR-02. Bộ lọc của Host đọc phone_verified_at từ sys.v_security_context mỗi request: mọi API ngoài /me/phone-verifications/*, GET /me, /auth/logout, /auth/token/refresh trả 403 MSG67 cho tới khi xác minh xong. Nếu cả hai cờ bật thì đổi mật khẩu tạm trước, xác minh số sau.
- Quyền không đưa vào JWT; client gọi `/me/permissions` để dựng menu (SCR-03 bước 4). Máy chủ vẫn kiểm từng request (SEQ-COOP-04).

2.8 Sequence Diagram – Đăng ký tài khoản khách hàng và xác minh mã (UC01, UC08)

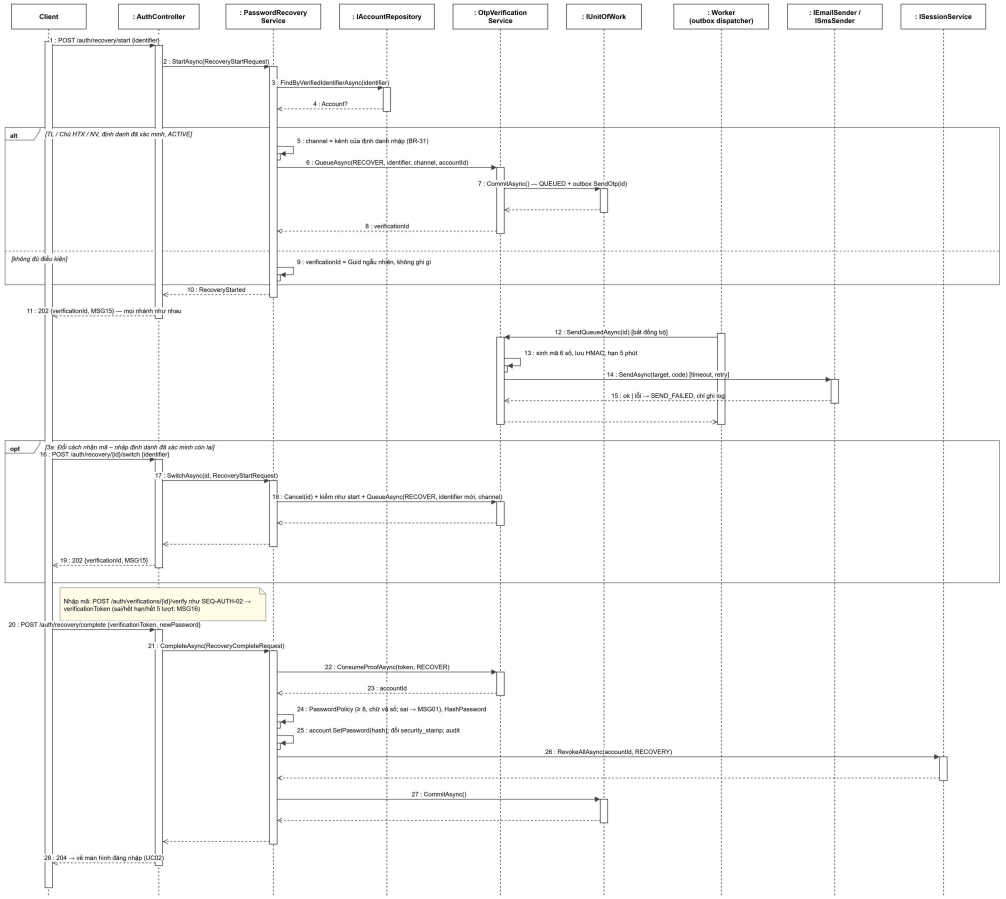


Hình 7. Đăng ký kèm xác minh email hoặc số điện thoại (SEQ-AUTH-02)

- Mật khẩu được kiểm ở bước start để báo lỗi sớm (UC01 2b) nhưng chỉ băm và lưu ở bước complete, sau khi email hoặc số đã xác minh.

- Đăng ký bằng số điện thoại: ICustomerLinkService (SALES) chạy trong cùng giao dịch: đúng một hồ sơ khách offline cùng số → LINKED; không có → NEW (UC01 4a); nhiều hồ sơ/trái nhau → MANUAL_MATCH, tài khoản vẫn tạo nhưng lịch sử cũ bị ẩn, trả MSG57 để Chủ HTX ghép ở UC42 (4b). Đăng ký bằng email: luôn tạo hồ sơ khách mới (NEW, UC01 4a); Chủ HTX ghép với hồ sơ offline (nếu có) ở UC42.
- Mã chỉ gửi tới chính email hoặc số điện thoại đăng ký; không gửi mật khẩu qua kênh nào. Thương lái đăng ký bằng email chưa có số điện thoại (phone_e164 NULL) và phải thêm, xác minh số ngay sau lần đăng nhập đầu qua /me/phone-verifications (UC02 3a, OD-16); khi số được xác minh (thêm ở UC02 3a hoặc đổi ở UC05 3b), ICustomerLinkService ghép hồ sơ khách offline khớp duy nhất cùng số vào hồ sơ khách của tài khoản; nhiều hồ sơ/trái nhau → MANUAL_MATCH (MSG57), Chủ HTX ghép ở UC42.

2.9 Sequence Diagram – Khôi phục tài khoản tự phục vụ (UC03)



Hình 8. Khôi phục tài khoản bằng email hoặc số điện thoại đã xác minh (SEQ-AUTH-03)

- Điều kiện đủ (UC03 bước 2, 2a): định danh nhập khớp phone_e164 có phone_verified_at, hoặc email có email_verified_at; subject_type ∈ {TRADER, COOP_OWNER, EMPLOYEE}; trạng thái ACTIVE. Không đủ thì nhận cùng phản hồi MSG15 nhưng không có mã. Nhân viên khôi phục bằng số điện thoại đã xác minh ở lần đăng nhập đầu (UC02 3a, QĐ-21) hoặc email đã xác minh ở UC05; tài khoản chưa có định danh đã xác minh (nhân viên chưa đăng nhập lần đầu) nhờ Chủ HTX đặt lại mật khẩu ở UC11.
- Kênh = kênh của định danh nhập (email → IEmailSender, số → ISmsSender); không tự chuyển sang kênh khác (BR-31, QĐ-20). Không nhận được mã: người dùng chọn “Đổi cách nhận mã” (3a) và nhập định danh đã xác minh còn lại; POST /auth/recovery/{id}/switch hủy lần trước rồi xử lý như bước start.
- Mọi nhánh trả cùng 202 MSG15 với thời gian như nhau vì việc gửi chạy ở Worker qua outbox; outbox chỉ chứa verificationId, Worker sinh mã lúc gửi nên mã rõ không nằm trong database. Lỗi gửi không đổi phản hồi (OD-13); rate limit theo IP và theo định danh chống dò.
- Hoàn tất khôi phục xoay security_stamp và thu hồi mọi phiên (RECOVERY), ghi audit ACCOUNT.PASSWORD_RECOVERED.

2.10 Thiết kế tương tác của UC04–UC07

Bảng II-13. Tương tác các UC không vẽ sequence

UC	Luồng gọi (Controller → Service → Repository / adapter)	Phiên / quyền	Ghi chú
UC02 3a Xác minh số điện thoại sau đăng nhập	MeController.StartPhoneVerification → ProfileService.StartPhoneVerificationAsync → (TRADER) PhoneNumber.Parse + IAccountRepository.PhoneInUse → IOtpVerificationService.StartAsync(VERIFY_PHONE, số) → ISmsSender; ConfirmPhone → VerifyAsync + ConsumeProof → Account.SetVerifiedPhone → (TRADER) ICustomerLinkService.LinkByPhone → audit → Commit	Phiên của chính mình; phone_verified_at NULL, hoặc đổi số ở UC05 3b	UC08 «extend» UC02 (BR-34, MSG67). Nhân viên xác minh số do Chủ HTX nhập hoặc gửi số khác; Chủ HTX sửa số ở UC11 thì phone_verified_at về NULL
UC04 Đổi mật khẩu	MeController.ChangePassword → PasswordService.ChangeAsync → IAccountRepository.Get → IPasswordHasher.Verify(current) hoặc IOtpVerificationService.ConsumeProofAsync(CHANGE_PASSWORD) → PasswordPolicy → SetPassword + RotateSecurityStamp → ISessionService.RevokeAllAsync(except current) → ISessionService.CreateAsync (thiết bị hiện tại) → IAuditTrail → Commit	Authenticated; phiên hết hạn → 401 MSG19 (4c)	Mã email: POST /me/password/email-code → IEmailSender (UC04 2a, BR-31); chưa có email đã xác minh → client hướng dẫn UC05 / UC03 / nhờ Chủ HTX (2b)
UC05 Hồ sơ cá nhân	MeController.GetProfile/UpdateProfile → ProfileService → IAccountRepository (rowversion) → IAuditTrail (trước – sau) → Commit; không lưu bản sao phiên bản hồ sơ (QĐ-20). Email (UC08 «extend» UC05): StartEmailVerification → IOtpVerificationService.StartAsync(VERIFY_EMAIL, email mới) → IEmailSender (MSG62); ConfirmEmail → VerifyAsync + ConsumeProof → Account.SetVerifiedEmail → audit → Commit	Chỉ account của phiên	Email mới chỉ ghi vào account sau khi nhập đúng mã; email cũ vẫn dùng tới lúc đó (UC05 3a, BR-31). Đổi số (UC05 3b, QĐ-21, mọi loại tài khoản): /me/phone-verifications như UC02 3a, số mới chỉ ghi khi xác nhận đúng mã; thương lái tự ghép hồ sơ khách offline (3b3, 3g); Quản trị hệ thống không sửa hồ sơ (BR-33)
UC06 Tùy chọn thông báo	MeController → NotificationPreferenceService → INotificationCatalog (danh mục, mục bắt buộc), IChannelAvailability (email/Zalo đã cấu hình UC73), IPushDeviceRepository (có thiết bị cho phép) → INotificationPreferenceRepository.ReplaceAll → Commit	Chỉ account của phiên; danh mục lọc theo loại chủ thể	Module NOTI đọc bảng tùy chọn khi phát thông báo; người nhận vẫn kiểm quyền độc lập
UC07 Đăng xuất	AuthController.Logout → AuthService.LogoutAsync → ISessionService.RevokeAsync(LOGOUT) → (Mobile) IPushDeviceRepository.Revoke → Commit	Access token hoặc refresh token	Mất mạng (2b): app xóa token, dữ liệu bảo vệ trong SQLite; lưu sid chờ gọi lại khi có mạng; nếu không gọi được, phiên tự hết theo hạn tuyệt đối

2.11 External integration

Bảng II-14. Tích hợp ngoài của AUTH

Port (Contracts)	Adapter (Integrations)	Dịch vụ ngoài / API	Dùng ở	Timeout / retry	Xử lý lỗi
ISmsSender.SendOtpAsync(phone, code, purpose)	SmsSender (nhà cung cấp chờ chọn)	Dịch vụ SMS / API-01 (QĐ-26)	UC08 kênh SMS (UC01, UC02 3a, UC03)	Timeout ngắn theo cấu hình; retry 1 lần cho lỗi mạng/5xx (idempotency theo verificationId); circuit breaker	SEND_FAILED + 503 MSG04 (UC03: chỉ log, vẫn MSG15); không coi nhà cung cấp nhận yêu cầu là đã xác minh
IEmailSender.SendAsync(EmailMessage)	EmailSender (SMTP/API, chờ chọn)	Dịch vụ email / API-03	UC08 kênh email (UC01, UC03, UC05 3a), UC04 2a	Như trên	503 MSG04 (UC03: chỉ log, vẫn MSG15); mã email cùng bảng otp_verification (channel EMAIL)

Port (Contracts)	Adapter (Integrations)	Dịch vụ ngoài / API	Dùng ở	Timeout / retry	Xử lý lỗi
IPushSender.SendAsync(PushMessage)	PushSender (chờ chọn)	Dịch vụ thông báo đẩy / API-02	UC06 (đăng ký thiết bị); NOTI phát tin	Qua outbox, backoff mũ, tối đa N lần (cấu hình)	Token hỏng → push_device.revoked_at; không ảnh hưởng nghiệp vụ
IChannelAvailability.GetAsync()	Đọc cấu hình UC73 (ADMIN)	—	UC06	Cache ngắn	Kênh chưa cấu hình → MSG21

Adapter ghi log có che số điện thoại/email, không ghi mã OTP. Cấu hình kết nối (endpoint, credential) do Quản trị hệ thống nhập ở UC73 và lưu ở secret store; adapter đọc qua IOptionsMonitor để đổi không cần khởi động lại.

2.12 Thiết kế phía client (Web Next.js, Mobile React Native)

Bảng II-15. Màn hình AUTH trên Web và Mobile

SCR	Web (app/)	Mobile (screens/)	Gọi API / lưu trữ
SCR-01, SCR-02	(auth)/register, (auth)/register/verify	RegisterScreen, OtpScreen	register/start (chọn email hoặc số điện thoại) → verify → register/complete
SCR-03, SCR-02	(auth)/login, (auth)/verify-phone	LoginScreen, OtpScreen	login; phoneVerificationRequired → hiện MSG67, /me/phone-verifications → /{id}/confirm; sau đó /me/permissions để dựng menu
SCR-04	(auth)/recover	RecoverScreen, OtpScreen	recovery/start (email hoặc số) → verify → recovery/complete; nút "Đổi cách nhận mã" → recovery/{id}/switch
SCR-05	(coop)/account, (coop)/account/password	AccountScreen, ChangePasswordScreen	/me, /me/password, /me/email-verifications/*, /me/phone-verifications/* (đổi số)
SCR-06	(coop)/settings/notifications	NotificationSettingsScreen	/me/notification-preferences, /me/devices

- Web: access token chỉ trong bộ nhớ (React context); refresh token ở cookie HttpOnly, Secure, SameSite=Strict, path `/api/v1/auth`. `middleware.ts` chặn route theo kết quả /me/permissions chỉ để UX; máy chủ vẫn kiểm.
- Mobile: refresh token trong Keychain/Keystore (react-native-keychain); access token trong bộ nhớ; đăng xuất xóa cả SQLite dữ liệu bảo vệ (UC07).
- Interceptor của api-client: 401 MSG19 → gọi refresh một lần, thất bại → về màn đăng nhập; 403 MSG02 → trang không đủ quyền.

2.13 Traceability

Bảng II-16. Truy vết AUTH: UC → API → service → bảng

UC	BR / NFR	API	Service / class	Bảng	Sơ đồ
UC01	BR-31, BR-32, NFR-01, 08, 11	/auth/register/start, /complete; /auth/verifications/*	RegistrationService, OtpVerificationService, ICustomerLinkService	auth.account, auth.otp_verification, sales.customer	SEQ-AUTH-02
UC02	BR-19, BR-32, BR-34, NFR-01	/auth/login, /auth/token/refresh, /me/permissions, /me/phone-verifications/*	AuthService, LoginThrottle, SessionService, TokenService, IEffectivePermissionService, ProfileService, ICustomerLinkService (3a)	auth.account, auth.auth_session, auth.otp_verification, coop.access_grant, sales.customer	SEQ-AUTH-01, SEQ-COOP-04, Bảng II-13

UC	BR / NFR	API	Service / class	Bảng	Sơ đồ
UC03	BR-31, NFR-01, 08	/auth/recovery/start, /{id}/switch, /complete	PasswordRecoveryService, OtpVerificationService, IEmailSender, ISmsSender, ISessionService, outbox	auth.account, auth.otp_verification, auth.auth_session, sys.outbox_message	SEQ-AUTH-03
UC04	BR-31, NFR-01	PUT /me/password, /me/password/email-code	PasswordService, IEmailSender	auth.account, auth.auth_session, auth.otp_verification	Bảng II-13
UC05	BR-31, BR-32, BR-33, BR-34, NFR-11	GET/PUT /me, /me/email-verifications/*, /me/phone-verifications/*	ProfileService, OtpVerificationService, IEmailSender, ISmsSender, ICustomerLinkService	auth.account, auth.otp_verification, sales.customer	Bảng II-13
UC06	—	/me/notification-preferences, /me/devices	NotificationPreferenceService, IChannelAvailability	auth.account_notification_pref, auth.push_device	Bảng II-13
UC07	NFR-01	/auth/logout	AuthService, SessionService	auth.auth_session, auth.push_device	Bảng II-13
UC08	BR-31, BR-34, NFR-08	/auth/verifications/{id}/verify, /resend; /me/email-verifications/*, /me/phone-verifications/*	OtpVerificationService, OtpCrypto, ISmsSender, IEmailSender, JOB-01	auth.otp_verification	SEQ-AUTH-02

3. COOP – Hợp tác xã, nhân sự và phân quyền (UC09–UC12)

3.1 Phạm vi, module và phụ thuộc

Module `Omts.Modules.Cooperative` hiện thực UC09–UC12 (SCR-07…SCR-10) và permission engine dùng chung cho mọi module (IEffectivePermissionService, IZoneScopeGuard). Thao tác trên tài khoản đăng nhập đi qua IAccountProvisioning của AUTH; COOP không ghi trực tiếp bảng auth.*.

Bảng II-17. Use case của COOP

UC	Tên	Actor (ma trận SRS)	Service chính	Màn hình
UC09	Quản lý hồ sơ hợp tác xã	Chủ HTX (Full); người được cấp Xem	CooperativeProfileService	SCR-07
UC10	Quản lý hồ sơ nhân viên	Chủ HTX (QĐ-24)	EmployeeService	SCR-08
UC11	Quản lý tài khoản người dùng và phân quyền theo khu	Chủ HTX (QĐ-24)	UserAccountService, GrantGuard	SCR-09
UC12	Quản lý vai trò và quyền hạn	Chủ HTX	RoleService, FeatureCatalog	SCR-10

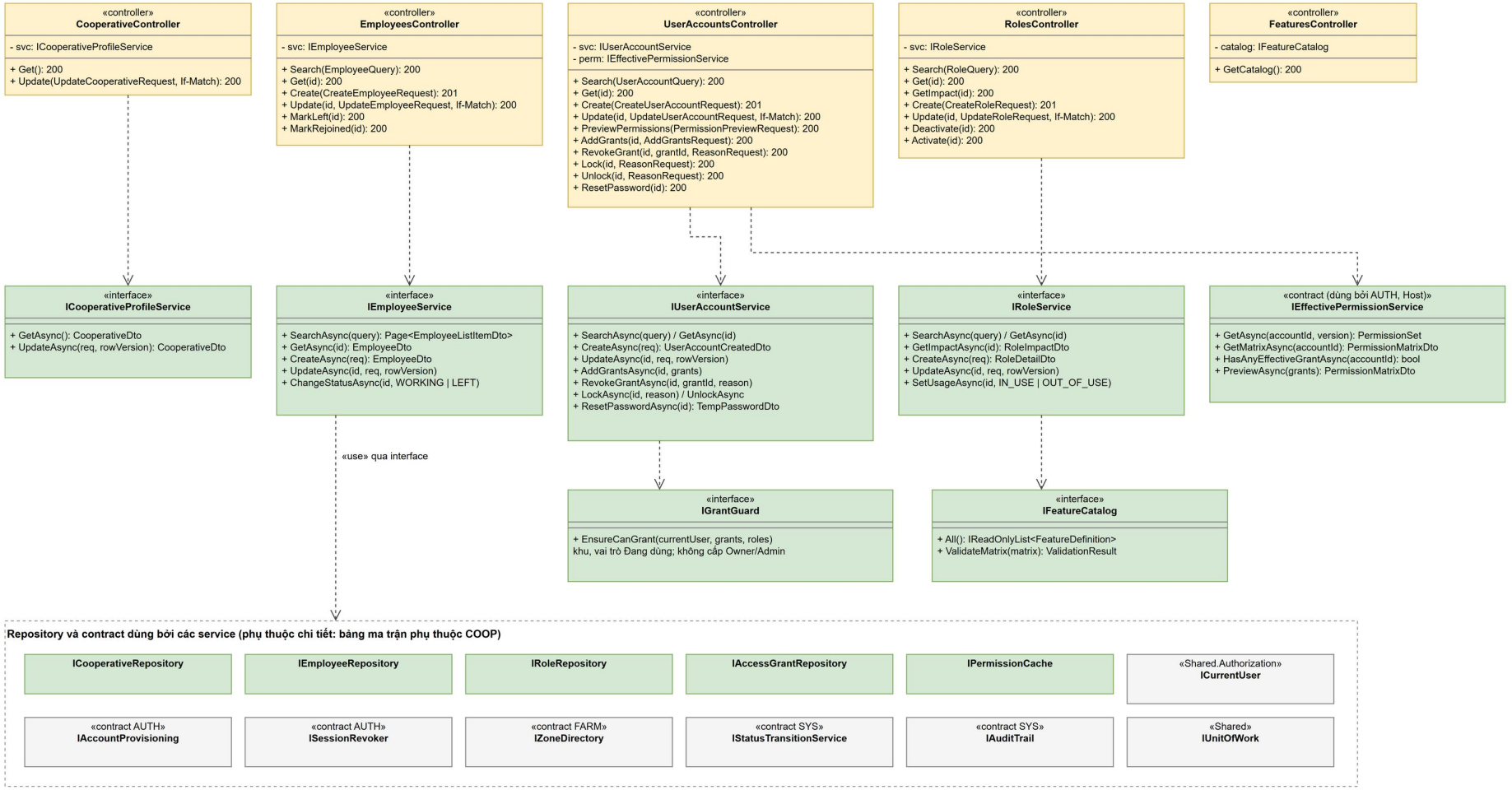
```
src/Modules/Cooperative/            (project Omts.Modules.Cooperative.<Layer>)
  .Api/              CooperativeController, EmployeesController, UserAccountsController,
                     RolesController, FeaturesController
  .Application/      Profile/, Employees/, UserAccounts/, Roles/,
                     Permissions/ (EffectivePermissionService, ZoneScopeGuard, GrantGuard)
  .Domain/           Cooperative, CooperativeBusinessLine, Employee, Role, RolePermission,
                     AccessGrant, PermissionSet, FeatureCatalog
  .Infrastructure/   Persistence/ (EF config, repositories), PermissionCache (IMemoryCache)
src/Contracts/Omts.Contracts/Cooperative/
                     IEffectivePermissionService, IZoneScopeGuard, ICooperativeDirectory,
                     ICooperativeProvisioning
```

Bảng II-18. Phụ thuộc của COOP

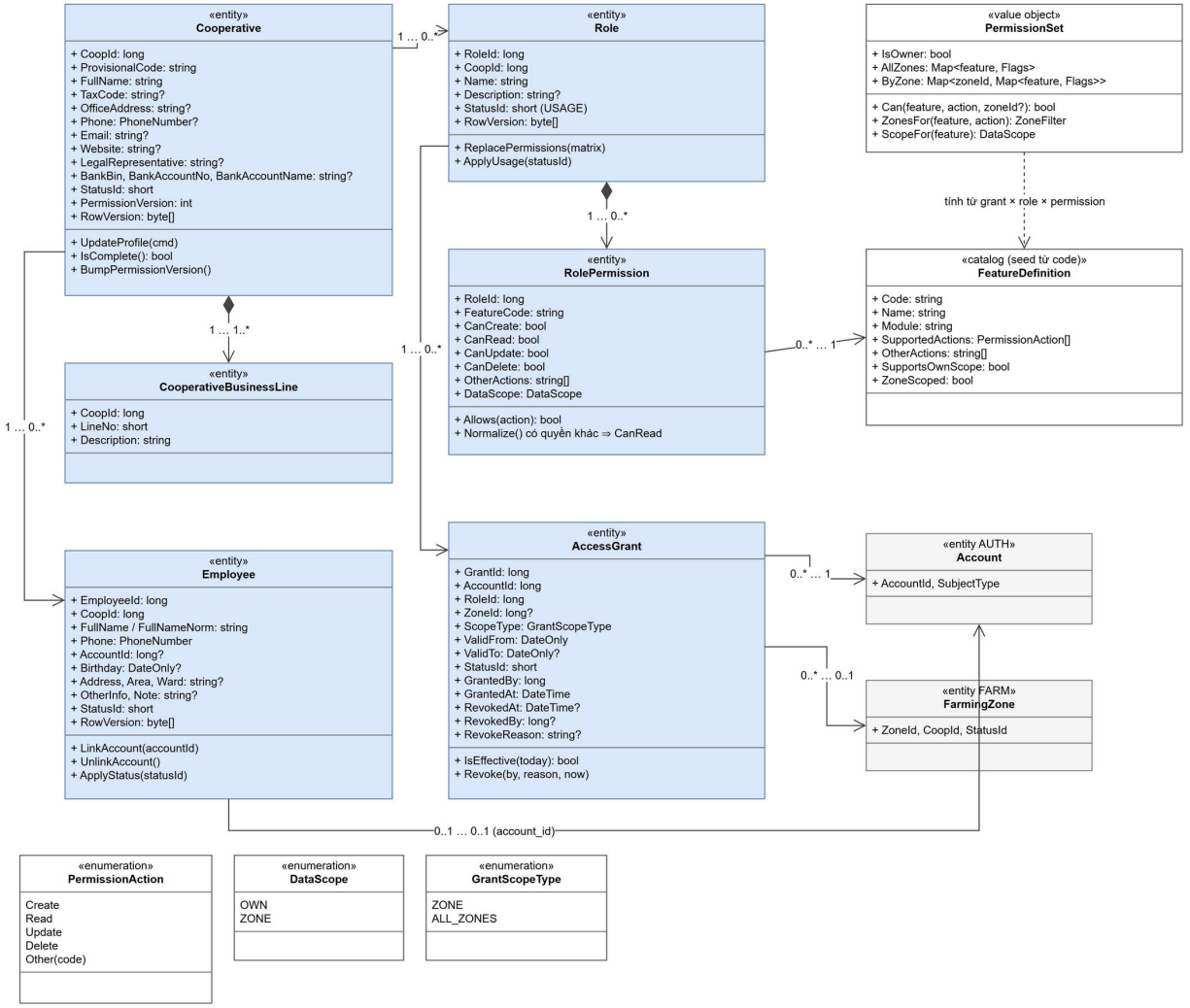
COOP dùng	Interface	Module cung cấp	Để làm gì
Tài khoản đăng nhập	IAccountProvisioning, ISessionRevoker	AUTH	UC11: tạo/sửa/khóa/đặt lại mật khẩu; thu hồi phiên
Danh sách khu	IZoneDirectory	FARM	UC11: khu còn Đang dùng của HTX; tên khu cho bảng xem trước quyền
Trạng thái, audit	IStatusTransitionService, IAuditTrail	SYS	BR-29, BR-30, NFR-02
Lịch sử	IAuditQuery	SYS	UC09 Xem lịch sử; tab Lịch sử thay đổi SCR-08

Module khác dùng COOP	Interface	Mục đích
Host / mọi module	IEffectivePermissionService, ICurrentUser, IZoneScopeGuard	Kiểm quyền chức năng và phạm vi khu (lớp 3, 4)
AUTH (UC02)	IEffectivePermissionService.HasAnyEffectiveGrantAsync, GetMatrixAsync	Chặn đăng nhập khi hết quyền; /me/permissions
ADMIN (UC72)	ICooperativeProvisioning.CreateProvisionalAsync	Tạo HTX sơ bộ (DRAFT) kèm mã sơ bộ, ảnh giấy tờ
TRACE (UC32, UC40)	ICooperativeDirectory.GetPublicInfoAsync	Tên, địa chỉ HTX để chụp vào bản công bố
LABOR (UC56–UC62)	IEmployeeDirectory	Nhân viên WORKING để giao việc, chấm công, lương

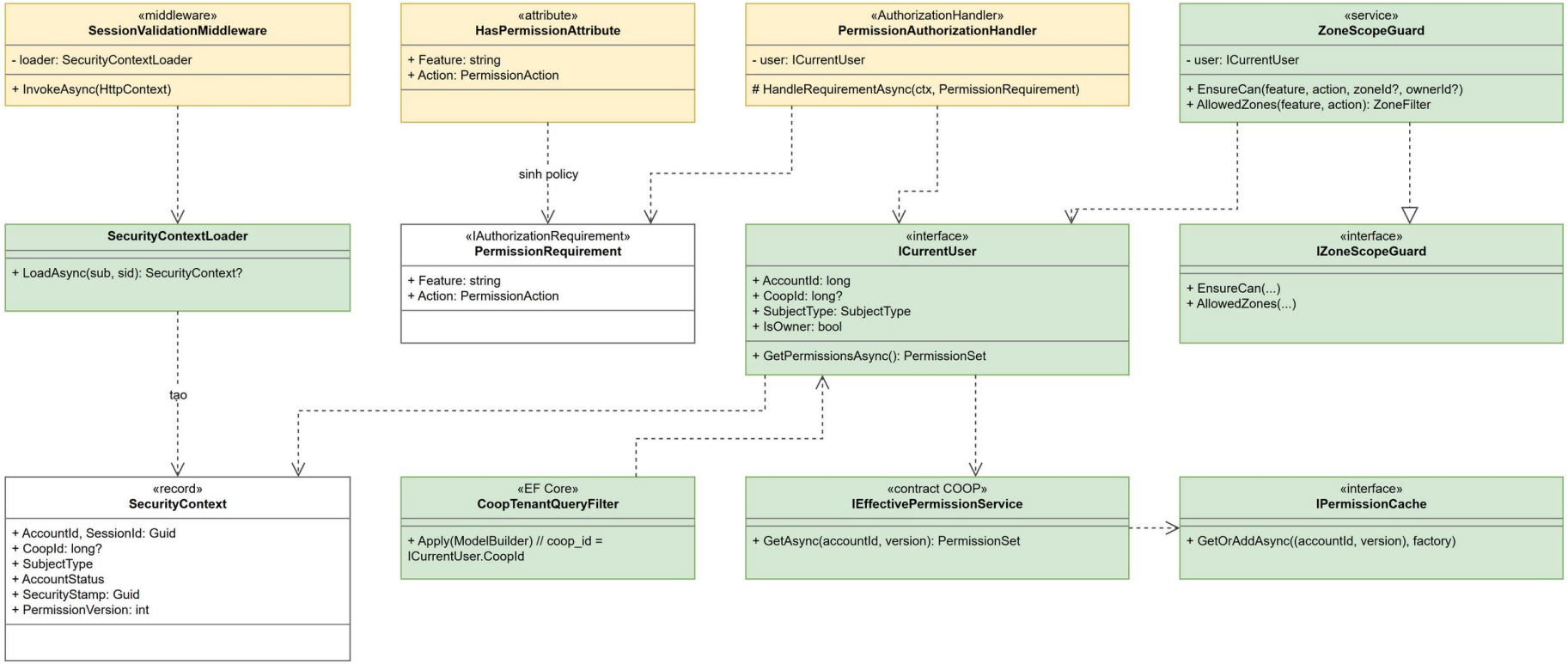
3.2 Class Diagram



Hình 9. COOP – lớp API, application service và contract (CLS-COOP-APP)



Hình 10. COOP – mô hình domain (CLS-COOP-DOM)



Hình 11. Lớp xác thực phiên, phân quyền và phạm vi khu (CLS-COOP-AUTHZ)

Bảng II-19. Mô tả class COOP

Class / interface	Layer	Trách nhiệm	UC / BR
CooperativeController / ICooperativeProfileService	Api / Application	Đọc, sửa hồ sơ HTX; chuyển DRAFT → COMPLETED khi đủ trường bắt buộc (gồm tài khoản ngân hàng nhận chuyển khoản, QĐ-29); cung cấp tài khoản này cho UC48 tạo QR VietQR, không trả ra trang truy xuất	UC09
EmployeesController / IEmployeeService	Api / Application	Tìm, tạo, sửa hồ sơ; chống trùng (họ tên chuẩn hóa + số điện thoại); gắn tài khoản; đổi WORKING/LEFT	UC10
UserAccountsController / IUserAccountService	Api / Application	Tạo/sửa tài khoản nội bộ qua IAccountProvisioning; thêm/thu hồi grant; khóa/mở khóa; đặt lại mật khẩu; xem trước quyền	UC11, BR-01, BR-19
RolesController / IRoleService	Api / Application	Tạo, sao chép, sửa ma trận quyền, ngừng/dùng lại vai trò; đánh giá ảnh hưởng	UC12, BR-19
FeaturesController / IFeatureCatalog	Api / Domain	Danh mục chức năng cố định (seed từ code) và hành động hỗ trợ; kiểm ma trận	UC12
IGrantGuard (GrantGuard)	Application	Kiểm khi cấp: khu và vai trò còn Đang dùng, không cấp vai trò Owner/Admin, chặn đích Owner/Admin	UC11 4b, 1e
IEffectivePermissionService (EffectivePermissionService)	Application (contract)	Tính PermissionSet = hợp quyền vai trò theo khu; cache theo version	BR-19, NFR-01
IZoneScopeGuard (ZoneScopeGuard)	Application (contract)	Kiểm bản ghi thuộc khu được gán, data scope OWN/ZONE; trả ZoneFilter cho truy vấn danh sách	BR-01, NFR-01
SessionValidationMiddleware, SecurityContextLoader	Host / SharedKernel	Kiểm phiên và nạp SecurityContext mỗi request	NFR-01, AC-02
PermissionAuthorizationHandler, HasPermissionAttribute	SharedKernel	Policy theo (feature, action) ở endpoint	NFR-01
CoopTenantQueryFilter	Persistence	Global query filter coop_id	NFR-01
PermissionSet	Domain (value object)	Can(feature, action, zoneId), ZonesFor(feature, action), ScopeFor(feature)	BR-19
Cooperative, Employee, Role, RolePermission, AccessGrant	Domain	Entity và bất biến (Hình CLS-COOP-DOM)	E01, E03–E06

3.3 Permission engine

Quyền thực tế của nhân viên là hợp quyền của các vai trò được gán, giới hạn trong khu tương ứng (BR-19, UC11 Postconditions). EffectivePermissionService tính PermissionSet như sau:

1. Đọc tài khoản (subject_type, coop_id, status). SYSTEM_ADMIN → chỉ chức năng nền tảng (policy PlatformAdmin). TRADER → không có quyền chức năng; API tự phục vụ dùng policy TraderSelf và lọc theo customer liên kết. COOP_OWNER → IsOwner = true, mọi chức năng nghiệp vụ trên mọi khu của HTX.
2. Với EMPLOYEE: lấy các AccessGrant có status EFFECTIVE và valid_from ≤ ngày hiện tại (giờ Việt Nam) ≤ valid_to (hoặc valid_to null); chỉ lấy vai trò IN_USE.
3. Mỗi grant đóng góp ma trận RolePermission của vai trò vào: AllZones nếu zone_id null (Toàn bộ khu), ngược lại ByZone[zone_id]. Gộp bằng phép OR trên từng hành động (Tạo/Xem/Sửa/Xóa/khác); data_scope gộp theo phạm vi rộng hơn (ZONE > OWN).
4. Can(feature, action, zoneId) = AllZones có hành động, hoặc ByZone[zoneId] có hành động. Với chức năng không gắn khu (app_feature.zone_scoped = 0, dữ liệu chung HTX như nhà cung cấp giống, lô giống, khách hàng, phiếu thu, người nhận khoán, lao động thời vụ, chấm công, mức lương và đơn giá, quyết toán lao động) chỉ xét AllZones: vai trò gán ở một khu cụ thể không thao tác trên dữ liệu này (dấu * ở ma trận quyền SRS). Riêng Xem hồ sơ HTX (COOPERATIVE) chỉ cần hành động ở bất kỳ grant nào.

5. ZonesFor(feature, action) trả ZoneFilter {All | Set(zoneIds) | None} để repository thêm điều kiện `zone_id IN (…)` cho danh sách.
6. Quy tắc Xem bắt buộc (UC12 3a, QĐ-16) được bảo đảm khi ghi, không phải khi tính: RolePermission.Normalize() đặt can_read = 1 khi có Tạo/Sửa/Xóa/khác; CHECK `CK_role_permission_read` ở database chặn dữ liệu sai đi đường khác. Vì vậy engine không cần suy Xem từ quyền khác.
7. Kết quả cache khóa `perm:{accountId}:{permission_version}:{yyyyMMdd}`. Ngày nằm trong khóa để grant hết hạn theo valid_to không cần job.

Bảng II-20. Danh mục chức năng (AUTH/COOP theo SDS v1.2; các package khác bổ sung khi thiết kế – OD-08)

Feature code	Tên	Module	C R U D	Khác	Phạm vi OWN	Gắn khu	Ghi chú
COOPERATIVE	Hồ sơ HTX	COOP	-RU-		Không	Không	Chỉ Xem cấp được cho nhân viên; Sửa chỉ Chủ HTX (UC09)
EMPLOYEE	Hồ sơ nhân viên	COOP	—		—	—	Không cấp được: chỉ Chủ HTX (UC10, QĐ-24); toàn HTX, không gắn khu (QĐ-16)
USER_ACCOUNT	Tài khoản người dùng	COOP	—		—	—	Không cấp được: chỉ Chủ HTX (UC11, QĐ-24); khóa, mở khóa, thu hồi grant có lý do (QĐ-16)
ROLE	Vai trò và quyền hạn	COOP	—		—	—	Không cấp được: chỉ Chủ HTX (UC12)
RAFT, CULTIVATION_CYCLE, WATER_MEASUREMENT, SALES_ORDER, …	Chức năng các package khác	FARM, CULT, SALES, …	theo package	EXPORT, IMPORT…	theo package	Có	Chốt khi thiết kế package tương ứng (OD-08)

Danh mục nằm trong code (FeatureCatalog) và được seed vào coop.app_feature bằng migration, nên Chủ HTX không tạo được chức năng mới (E05). Thêm chức năng = đổi code + migration.

3.4 API Endpoints

Base path `/api/v1`. Mọi endpoint yêu cầu đăng nhập; HTX lấy từ phiên, không truyền coopId trên URL. Cột Quyền ghi policy ở lớp 3; kiểm phạm vi lớp 4 ghi ở Bảng II-23.

Bảng II-21. API của COOP

Method	Path	UC	Quyền (endpoint)	Request → Response	Lỗi / MSG
GET	/cooperative	UC09	HasPermission(COOPERATIVE, Read)	→ 200 CooperativeDto + ETag (kèm tracePreview)	403 MSG02
PUT	/cooperative	UC09	OwnerOnly, If-Match	UpdateCooperativeRequest (gồm bankBin, bankAccountNo, bankAccountName) → 200 CooperativeDto	400 MSG01; 409 MSG03 (MST), MSG06; 403 MSG02 (1a)
GET	/cooperative/history	UC09	OwnerOnly	→ 200 Page<AuditEntryDto>	—
GET	/employees	UC10	OwnerOnly (QĐ-24)	EmployeeQuery → 200 Page<EmployeeListItemDto>	—
GET	/employees/{id}	UC10	OwnerOnly (QĐ-24)	→ 200 EmployeeDto + ETag	404

Method	Path	UC	Quyền (endpoint)	Request → Response	Lỗi / MSG
POST	/employees	UC10	OwnerOnly (QĐ-24)	CreateEmployeeRequest → 201 EmployeeDto	400 MSG01; 409 MSG03 (+existingId), MSG24
PUT	/employees/{id}	UC10	OwnerOnly (QĐ-24), If-Match	UpdateEmployeeRequest → 200 EmployeeDto	409 MSG03, MSG06, MSG24
POST	/employees/{id}/leave | /rejoin	UC10 3b	OwnerOnly (bảng 3.4-2, QĐ-16)	— → 200 EmployeeDto (+ accountLockSuggested)	403 MSG02 (3c); 409 MSG61
GET	/employees/linkable-accounts	UC10 b3	OwnerOnly (QĐ-24)	→ 200 AccountOptionDto[] (nội bộ, chưa gắn)	—
GET	/user-accounts	UC11	OwnerOnly (QĐ-24)	UserAccountQuery → 200 Page<UserAccountListItemDto>	—
GET	/user-accounts/{id}	UC11	OwnerOnly (QĐ-24)	→ 200 UserAccountDetailDto + ETag	404
POST	/user-accounts	UC11	OwnerOnly (QĐ-24)	CreateUserAccountRequest → 201 UserAccountCreatedDto (UserAccountDetailDto + TempPasswordDto)	400 MSG01; 409 MSG03; 403 MSG02
PUT	/user-accounts/{id}	UC11 1a	OwnerOnly (QĐ-24), If-Match	UpdateUserAccountRequest → 200	409 MSG03, MSG06; 403 MSG02
POST	/user-accounts/permission-preview	UC11 b5	OwnerOnly (QĐ-24)	PermissionPreviewRequest → 200 PermissionMatrixDto	—
POST	/user-accounts/{id}/grants	UC11 1a	OwnerOnly (QĐ-24)	AddGrantsRequest → 200 UserAccountDetailDto	403 MSG02; 409 MSG03 (grant trùng)
POST	/user-accounts/{id}/grants/{grantId}/revoke	UC11 1a	OwnerOnly (bảng 3.4-2, QĐ-16)	ReasonRequest (bắt buộc) → 200 UserAccountDetailDto	400 MSG01; 403 MSG02; 409 MSG61
POST	/user-accounts/{id}/lock | /unlock	UC11 1b, 1c	OwnerOnly (bảng 3.4-2, QĐ-16)	ReasonRequest (bắt buộc) → 200 UserAccountDetailDto	400 MSG01; 403 MSG02 (1e); 409 MSG61
POST	/user-accounts/{id}/reset-password	UC11 1d	OwnerOnly (QĐ-24)	— → 200 TempPasswordDto (hiện một lần; 10 ký tự, hạn 24 giờ)	403 MSG02
GET	/roles/options	UC11	OwnerOnly (QĐ-24)	→ 200 RoleOptionDto[] (IN_USE)	—
GET	/roles | /roles/{id}	UC12	OwnerOnly	RoleQuery → 200 Page<RoleListItemDto> | RoleDetailDto + ETag	—
GET	/roles/{id}/impact	UC12 1b	OwnerOnly	→ 200 RoleImpactDto	—
POST	/roles	UC12, 1a	OwnerOnly	CreateRoleRequest (copyFromRoleId?) → 201 RoleDetailDto + warnings	400 MSG01; 409 MSG03
PUT	/roles/{id}	UC12 1b	OwnerOnly, If-Match	UpdateRoleRequest (confirmImpact) → 200 RoleDetailDto	409 MSG03, MSG06; 409 MSG09 khi thiếu xác nhận
POST	/roles/{id}/deactivate | /activate	UC12 1c	OwnerOnly	— → 200	409 MSG11 (+ danh sách tài khoản)
GET	/features	UC12	OwnerOnly	→ 200 FeatureDefinitionDto[]	—

3.5 Request/Response DTO và validation

Bảng II-22. DTO và quy tắc kiểm tra của COOP

DTO	Trường	Validation (máy chủ)	MSG
UpdateCooperativeRequest	fullName, taxCode, officeAddress, phone, legalRepresentative	Bắt buộc; taxCode 10 số hoặc 10 số-3 số, duy nhất toàn hệ thống; phone E.164	MSG01, MSG03
	email?, website?	Nếu nhập phải đúng định dạng (email RFC 5322 đơn giản, URL http/https)	MSG01
	businessLines[]	≥ 1 dòng, mỗi dòng ≤ 255 ký tự	MSG01
CooperativeDto	… + status (DRAFT|COMPLETED), tracePreview{name, address}	tracePreview chỉ tên và địa chỉ (UC09, NFR-03)	—
CreateEmployeeRequest / UpdateEmployeeRequest	fullName, phone	Bắt buộc; fullName ≤ 150; chống trùng theo (fullNameNorm, phone) trong HTX	MSG01, MSG03
	accountId?	Tài khoản EMPLOYEE cùng HTX, chưa gắn hồ sơ khác	MSG24
	birthday?, address?, area?, ward?, otherInfo?, note?	Tùy chọn; birthday không ở tương lai	MSG01
EmployeeQuery	q, status, page, size	q tìm theo full_name_norm (tiền tố) hoặc số điện thoại	—
CreateUserAccountRequest	displayName, phone, username	Bắt buộc; username [a-z0-9._-] 3–50; phone E.164, duy nhất toàn hệ thống (BR-32, CheckAvailabilityAsync); người thao tác không xác minh; phone_verified_at để trống, nhân viên xác minh ở lần đăng nhập đầu (UC02 3a, BR-34, QĐ-21)	MSG01, MSG03
	email?	Định dạng email; lưu với email_verified_at = null, chủ tài khoản tự xác minh ở UC05 (BR-31)	MSG01
	(không có trường mật khẩu)	Máy chủ sinh mật khẩu tạm như đặt lại (TempPasswordDto); Chủ HTX không đặt mật khẩu cho nhân viên	—
	grants[{zoneId?, roleId, validFrom, validTo?}]	≥ 1 dòng; zoneId null = Toàn bộ khu; khu IN_USE của HTX; vai trò IN_USE; validTo ≥ validFrom; không trùng (zone, role) trong cùng tài khoản. Không giới hạn số tài khoản cùng vai trò trong một khu (QĐ-16)	MSG01, MSG02, MSG03
UpdateUserAccountRequest	displayName, phone, email?, username	Như trên; đổi phone thì phone_verified_at = NULL, chủ tài khoản xác minh lại ở lần đăng nhập kế tiếp (UC11 1a1, BR-34); không đổi subject_type	MSG01, MSG03
ReasonRequest	reason	Bắt buộc, ≤ 500 ký tự với lock, unlock và revoke (reason_required = 1 trong sys.status_transition, QĐ-16)	MSG01
UserAccountDetailDto	account{…, status}, grants[{grantId, zone, role, validFrom, validTo, status, grantedBy, revokedAt?}], employee?	Không bao giờ chứa mật khẩu/hash	—
TempPasswordDto	temporaryPassword, expiresAt, mustChangePassword = true	10 ký tự ngẫu nhiên (RandomNumberGenerator, có chữ và số), hạn 24 giờ; hiện một lần cho người thao tác (tạo tài khoản, đặt lại 1d); không gửi qua kênh nào	—
UserAccountCreatedDto	account (UserAccountDetailDto), temporaryPassword (TempPasswordDto)	Trả một lần khi tạo; GET sau đó không có mật khẩu	—
CreateRoleRequest / UpdateRoleRequest	name, description?	name bắt buộc ≤ 100, duy nhất trong HTX	MSG01, MSG03
	permissions[{featureCode, create, read, update, delete, otherActions[], dataScope}]	featureCode thuộc catalog; chỉ hành động chức năng hỗ trợ; OWN chỉ khi hỗ trợ; ROLE không cấp được. Có create/update/delete/otherActions → máy chủ đặt read = true (UC12 3a, QĐ-16)	MSG01
	confirmImpact (Update)	Bắt buộc true khi vai trò còn người giữ (UC12 1b)	MSG09
RoleDetailDto	… + permissions đã chuẩn hóa	Trả ma trận sau khi tự bật Xem để client hiển thị đúng ô bị khóa	—
RoleImpactDto	holderCount, zones[], accounts[]	Đếm grant EFFECTIVE của vai trò	—

3.6 Authorization, transaction và xử lý lỗi theo lệnh

Bảng II-23. Kiểm quyền, giao dịch và lỗi của lệnh COOP

Lệnh	Kiểm phạm vi / bất biến (lớp 4–5)	Ranh giới giao dịch	Tác động phân quyền	Lỗi đặc biệt
UpdateCooperative	Chủ HTX của chính HTX	Tx: cooperative + business_line (thay toàn bộ) + audit COOP.UPDATE (before/after); nếu đủ trường và đang DRAFT → EnsureAllowed(DRAFT→COMPLETED, UC09, COOP_OWNER) + STATUS.CHANGE	—	Thông tin đã công bố QR không đổi: TRACE chụp lại khi công bố (UC09 4a)
Create/UpdateEmployee	OwnerOnly (QĐ-24); hồ sơ toàn HTX (QĐ-16); account cùng HTX	Tx: employee + audit EMPLOYEE.CREATE/UPDATE	—	UNIQUE(coop, phone, name_norm) → MSG03; UNIQUE account_id → MSG24
Leave/Rejoin	OwnerOnly	Tx: EnsureAllowed(EMPLOYEE) + status + audit	—	Trả gợi ý khóa tài khoản (UC10 3b2)
CreateUserAccount	OwnerOnly (QĐ-24); IGrantGuard: khu thuộc HTX và Đang dùng, vai trò Đang dùng, không cấp vai trò Owner/Admin; chỉ tạo subject EMPLOYEE	Tx: Account với mật khẩu tạm (must_change_password = 1, temp_password_expires_at = now + 24 giờ; qua IAccountProvisioning, cùng DbContext) + AccessGrant × n + permission_version++ + audit ACCOUNT.CREATE, GRANT.ADD	Version tăng	Cấp vai trò Owner/Admin → 403 MSG02 + audit SECURITY.DENIED
UpdateUserAccount / AddGrants	OwnerOnly; như trên; tài khoản đích là tài khoản nội bộ của HTX, không phải Owner/Admin	Tx: account/grant + version++ + audit	Version tăng	Grant trùng còn hiệu lực → MSG03
RevokeGrant	OwnerOnly; reason bắt buộc	Tx: EnsureAllowed(EFFECTIVE→REVOKED, reason) + revoked_at/by/reason + version++ + audit	Không ảnh hưởng grant khác (AC-02)	Cấp lại tạo grant mới (BR-19)
Lock / Unlock	OwnerOnly; đích không phải Owner/Admin	Tx: EnsureAllowed(ACCOUNT) + status + security_stamp + RevokeAll (LOCK) + version++ + audit STATUS.CHANGE	Phiên bị vô hiệu ngay	Unlock chỉ mở lại grant còn hiệu lực (UC11 1c)
ResetPassword	OwnerOnly; đích là tài khoản nhân viên của HTX, không phải Owner/Admin	Tx: hash tạm + must_change_password + temp_password_expires_at (now + 24 giờ) + stamp + RevokeAll + audit (không chứa mật khẩu)	—	Mật khẩu tạm 10 ký tự (QĐ-16); quá hạn → đặt lại lần nữa
Create/UpdateRole	OwnerOnly; FeatureCatalog.ValidateMatrix; RolePermission.Normalize (tự bật Xem)	Tx: role + role_permission (thay toàn bộ) + version++ + audit ROLE.UPDATE (before/after)	Áp dụng ngay cho mọi người giữ (BR-19)	Thiếu confirmImpact → 409 MSG09
Deactivate/ActivateRole	OwnerOnly	Tx: kiểm còn grant EFFECTIVE → chặn; status USAGE + audit	Version tăng	MSG11 kèm danh sách tài khoản (UC12 1c)

IAccountProvisioning do AUTH hiện thực nhưng chạy trên cùng OmtsDbContext/IUnitOfWork của request, nên tạo tài khoản và grant nằm trong một giao dịch SQL Server; khi tách module thành service riêng, contract này đổi sang outbox + bù trừ.

3.7 Data Design

Bảng II-24. Ánh xạ entity → bảng của COOP

Entity SRS	Bảng	PK	FK / cardinality	Ràng buộc chính	Trạng thái
E01 Cooperative	coop.cooperative	coop_id	status_id → sys.status	UNIQUE provisional_code; UNIQUE tax_code (lọc NOT NULL)	COOPERATIVE: DRAFT, COMPLETED
E01 (ngành nghề)	coop.cooperative_business_line	(coop_id, line_no)	cooperative 1 : 1..* (≥ 1 khi COMPLETED)	description NOT NULL	—
E03 Employee	coop.employee	employee_id	coop 1 : 0..*; account 0..1 : 0..1	UNIQUE(coop_id, phone_e164, full_name_norm); UNIQUE account_id (lọc NOT NULL)	EMPLOYEE: WORKING, LEFT
E04 Role	coop.role	role_id	coop 1 : 0..*	UNIQUE(coop_id, name)	USAGE: IN_USE, OUT_OF_USE
E05 RolePermission	coop.role_permission	(role_id, feature_code)	role 1 : 0..*; app_feature 1 : 0..*	CHECK data_scope; trigger/test bảo đảm cờ ⊆ supports_crud	—
E06 AccessGrant	coop.access_grant	grant_id	account 1 : 0..*; role 1 : 0..*; zone 0..1 : 0..*	CHECK scope_type khớp zone_id; valid_to ≥ valid_from; UNIQUE(account, role, zone) WHERE revoked_at IS NULL	ACCESS_GRANT: EFFECTIVE, REVOKED; "hết hạn" suy ra
(danh mục hệ thống)	coop.app_feature	feature_code	—	Seed từ FeatureCatalog	—

Bảng II-25. Chuyển trạng thái do COOP thực hiện

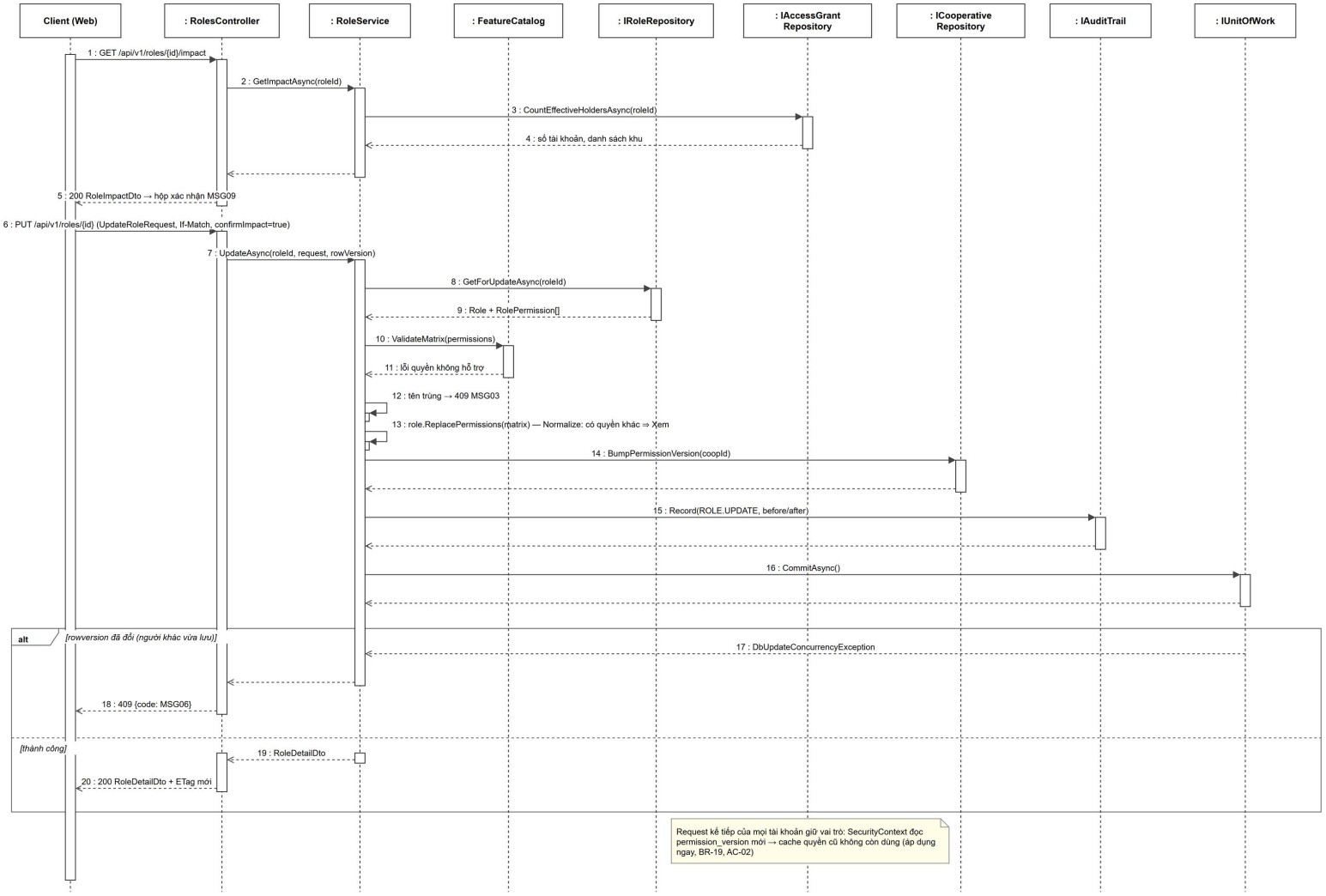
Chuyển (bảng 3.4-2 SRS)	UC	Actor được phép (code)	Lý do	Gọi từ
COOPERATIVE: DRAFT → COMPLETED	UC09	COOP_OWNER	Không	CooperativeProfileService.UpdateAsync (tự động khi đủ trường)
ACCOUNT: ACTIVE → LOCKED	UC11, UC74	COOP_OWNER, SYSTEM_ADMIN	Có	UserAccountService.LockAsync; ADMIN SupportService
ACCOUNT: LOCKED → ACTIVE	UC11, UC74	COOP_OWNER, SYSTEM_ADMIN	Có	UserAccountService.UnlockAsync; ADMIN SupportService: SYSTEM_ADMIN chỉ mở tài khoản mà lần khóa gần nhất do SYSTEM_ADMIN (đọc STATUS.CHANGE trong sys.audit_event)
EMPLOYEE: WORKING ↔ LEFT	UC10	COOP_OWNER	Không	EmployeeService.ChangeStatusAsync
ACCESS_GRANT: EFFECTIVE → REVOKED	UC11	COOP_OWNER	Có (QĐ-16)	UserAccountService.RevokeGrantAsync
USAGE: IN_USE ↔ OUT_OF_USE (Role)	UC12	COOP_OWNER	Không	RoleService.SetUsageAsync

3.8 Sequence Diagram – Tạo tài khoản và gán cặp khu – vai trò (UC11)



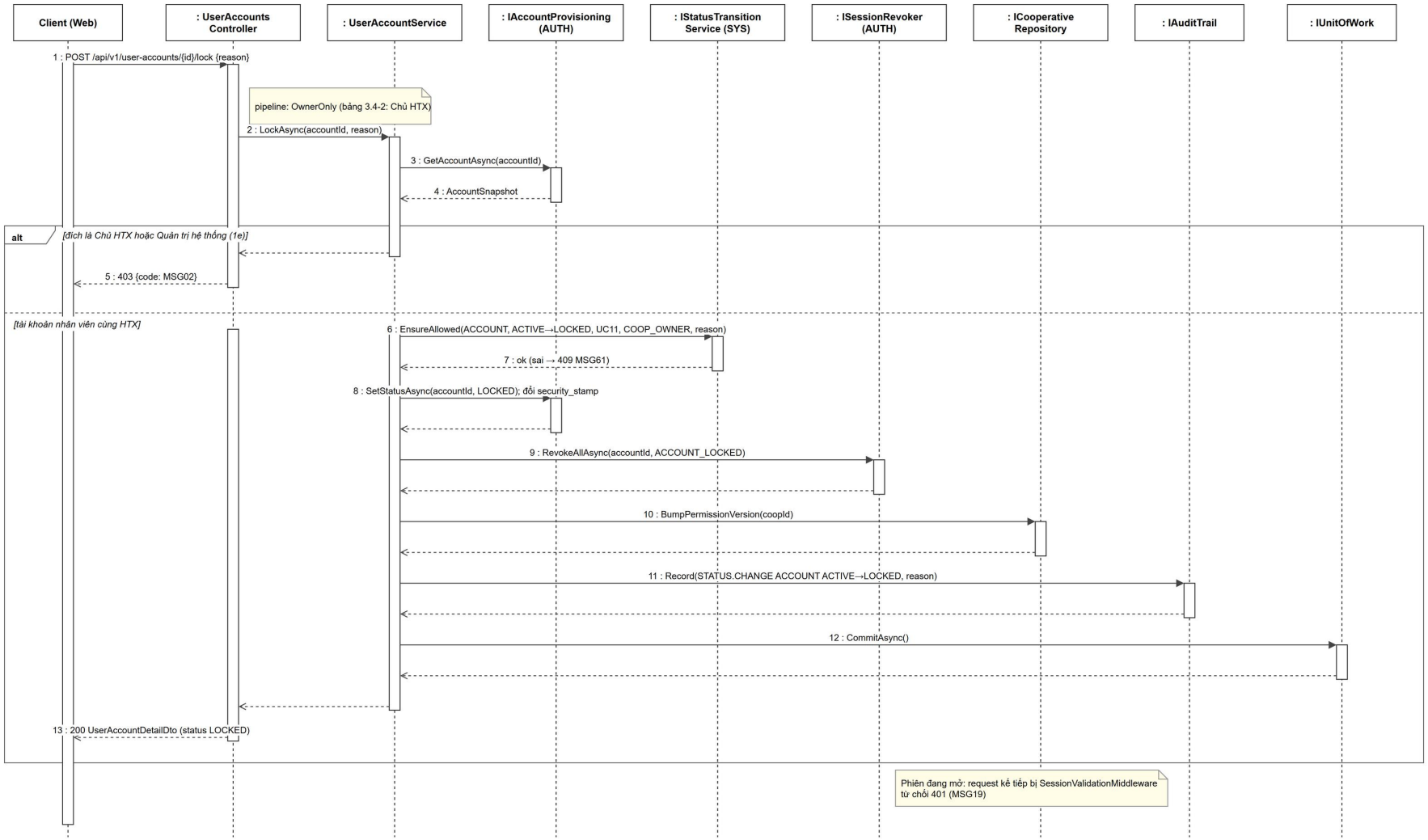
Hình 12. Tạo tài khoản nội bộ và gán cặp khu – vai trò (SEQ-COOP-01)

3.9 Sequence Diagram – Sửa vai trò đang có người giữ (UC12)



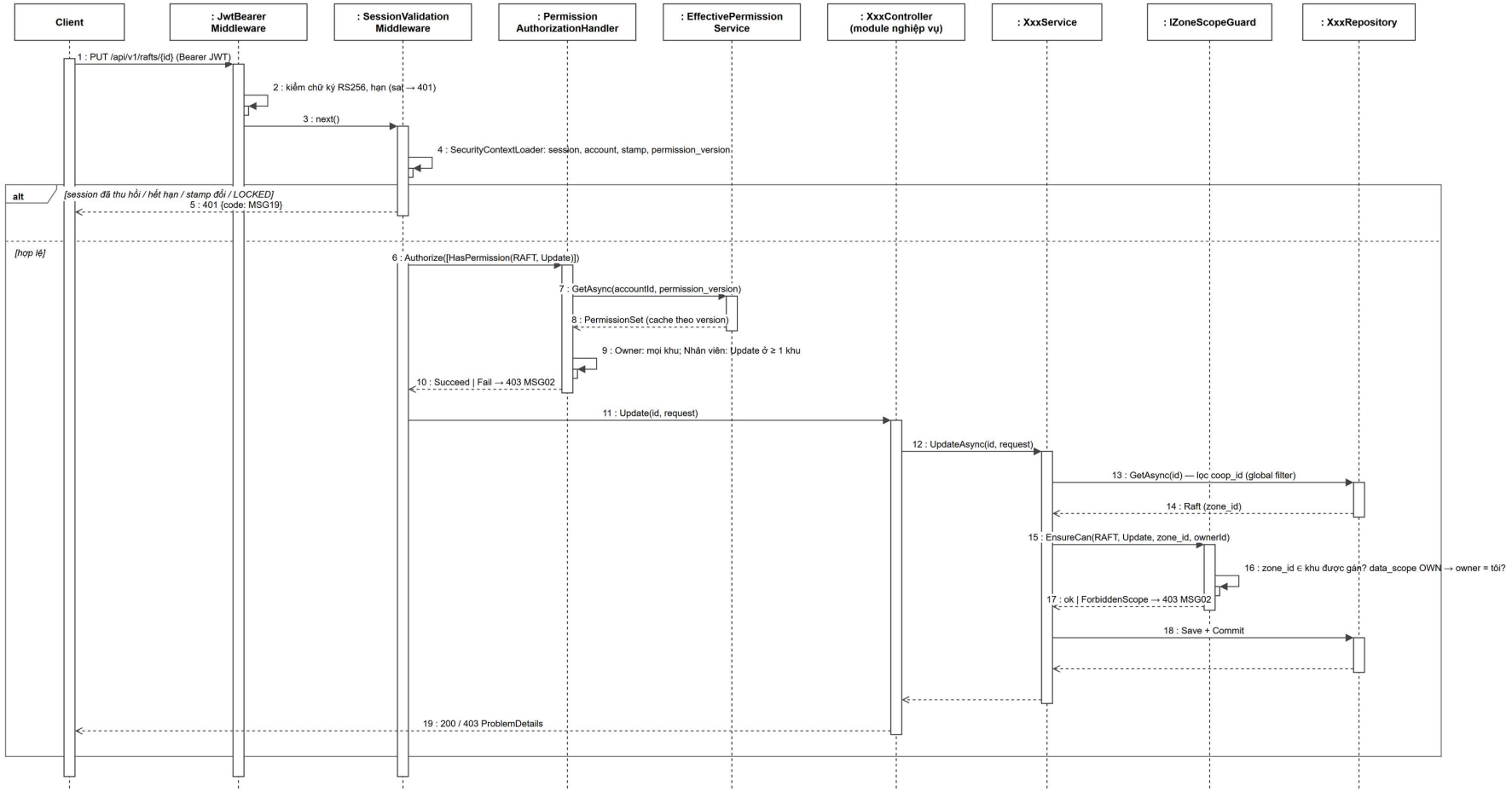
Hình 13. Sửa quyền của vai trò, áp dụng ngay (SEQ-COOP-02)

3.10 Sequence Diagram – Khóa tài khoản (UC11)



Hình 14. Khóa tài khoản và vô hiệu phiên đang mở (SEQ-COOP-03)

3.11 Sequence Diagram – Kiểm tra quyền và phạm vi khu cho request nghiệp vụ



Hình 15. Pipeline xác thực, quyền chức năng và phạm vi khu (SEQ-COOP-04)

SEQ-COOP-04 dùng thao tác sửa bè (FARM) làm ví dụ để chỉ cách mọi module nghiệp vụ dùng permission engine của COOP: controller khai báo [HasPermission(RAFT, Update)], service gọi IZoneScopeGuard với zone_id của bản ghi. Quyền theo bè kế thừa khu, không có grant riêng từng bè (BR-01).

3.12 Thiết kế tương tác của UC09 và UC10

Bảng II-26. Tương tác UC09, UC10

UC	Luồng gọi	Ghi chú
UC09	CooperativeController.Update → CooperativeProfileService.UpdateAsync(req, rowVersion) → ICooperativeRepository.GetForUpdate → Cooperative.UpdateProfile + ReplaceBusinessLines → nếu IsComplete() và DRAFT: IStatusTransitionService.EnsureAllowed → ApplyStatus → IAuditTrail.Record(COOP.UPDATE, before, after) → IUnitOfWork.Commit	Không lưu bản sao phiên bản; lịch sử thay đổi = chuỗi audit before/after (UC09 b4, QĐ-20); bản công bố QR tự chụp thông tin HTX
UC10	EmployeesController.Create → EmployeeService.CreateAsync → chuẩn hóa tên (bỏ dấu, chữ thường, gộp khoảng trắng) → IEmployeeRepository.FindDuplicate(coop, phone, nameNorm) → nếu có: 409 MSG03 + existingId (UC10 4a) → nếu có accountId: IAccountProvisioning.GetAccountAsync (EMPLOYEE, cùng HTX) + IEmployeeRepository.IsAccountLinked (MSG24) → Add → audit → Commit	Gắn tài khoản không tự cấp quyền (UC10 Postconditions)

3.13 Thiết kế phía client

Bảng II-27. Màn hình COOP trên Web và Mobile

SCR	Web (app/(coop)/…)	Mobile (screens/coop/…)	Thành phần chính	Ghi chú
SCR-07	settings/cooperative	CooperativeScreen	CooperativeForm, BusinessLinesEditor, TracePreviewCard	Chủ HTX sửa; người có Xem chỉ đọc
SCR-08	hr/employees, hr/employees/[id]	EmployeeListScreen, EmployeeDetailScreen	EmployeeTable / EmployeeList, EmployeeForm, AccountPicker, HistoryTab	Gợi ý trùng khi gõ tên/số (GET /employees?q=); nút Đã nghỉ chỉ hiện với Chủ HTX
SCR-09	admin/user-accounts, admin/user-accounts/[id]	UserAccountListScreen, UserAccountDetailScreen	UserAccountForm, GrantRowsEditor, PermissionPreviewMatrix, LockDialog (MSG09, lý do bắt buộc)	Xem trước quyền gọi /permission-preview mỗi khi đổi dòng grant; khóa/thu hồi chỉ hiện với Chủ HTX
SCR-10	admin/roles, admin/roles/[id]	RoleListScreen, RoleDetailScreen	RoleForm, PermissionMatrixEditor (feature × C/R/U/D/khác/phạm vi), ImpactConfirmDialog	Ô không hỗ trợ bị khóa theo /features; tích quyền khác thì ô Xem tự bật và khóa

SCR-07…SCR-10 có trên cả Web và Mobile (OD-12). Hai bên dùng chung packages/api-client, packages/messages và lớp kiểm form (Zod) nên quy tắc nhập giống nhau. Trên Mobile, bảng nhiều dòng hiển thị dạng danh sách thẻ; ma trận quyền (SCR-09 xem trước, SCR-10) hiển thị theo từng chức năng dạng mở/gập thay cho bảng rộng. Nút dành riêng Chủ HTX bị ẩn với nhân viên chỉ để dễ dùng; máy chủ vẫn kiểm.

3.14 Traceability

Bảng II-28. Truy vết COOP

UC / BR	API	Service / class	Bảng	Sơ đồ
UC09, NFR-02, BR-29/30	GET/PUT /cooperative, /cooperative/history	CooperativeProfileService, IStatusTransitionService, IAuditTrail	coop.cooperative, coop.cooperative_business_line, sys.audit_event	Bảng II-26
UC10, NFR-11	/employees*	EmployeeService	coop.employee	Bảng II-26
UC11, BR-01, BR-19, AC-01, AC-02	/user-accounts*	UserAccountService, GrantGuard, IAccountProvisioning, ISessionRevoker, EffectivePermissionService	auth.account, coop.access_grant, coop.cooperative.permission_version	SEQ-COOP-01, SEQ-COOP-03
UC12, BR-19, AC-02	/roles*, /features	RoleService, FeatureCatalog	coop.role, coop.role_permission, coop.app_feature	SEQ-COOP-02

UC / BR	API	Service / class	Bảng	Sơ đồ
NFR-01, BR-01 (mọi module)	[HasPermission] trên mọi endpoint	SessionValidationMiddleware, PermissionAuthorizationHandler, ZoneScopeGuard, CoopTenantQueryFilter	sys.v_security_context	SEQ-COOP-04, CLS-COOP-AUTHZ

Bảng II-29. Truy vết entity → bảng

Entity	Bảng / thành phần	Module
E01 Cooperative	coop.cooperative, coop.cooperative_business_line	COOP
E02 Account	auth.account, auth.account_notification_pref (+ kỹ thuật: auth_session, otp_verification, push_device)	AUTH
E03 Employee	coop.employee	COOP
E04 Role	coop.role	COOP
E05 RolePermission	coop.role_permission (+ coop.app_feature)	COOP
E06 AccessGrant	coop.access_grant	COOP
E48 AuditEvent	sys.audit_event (IAuditTrail)	SYS
E51 Status, E52 StatusTransition	sys.status, sys.status_transition (IStatusTransitionService)	SYS

4. Quyết định thiết kế và điểm còn mở

Ngày 06/10/2026 các điểm mở OD-01…OD-14 của SDS v1.0 đã được quyết và ghi vào SRS v5.6 (V.3.2, QĐ-16…QĐ-18). Bảng giữ lại để truy vết thiết kế. Còn mở: nhà cung cấp SMS, email, thông báo đẩy (OD-11), danh mục chức năng của các package khác (OD-08), tên miền triển khai (OD-15). Ngày 07/10/2026 QĐ-21 chốt thêm OD-05 (tham số mã email), OD-10 (nhân viên xác minh số) và OD-16 (số điện thoại của thương lái đăng ký bằng email). PM/Technical Lead rà bảng này trước khi đánh dấu Done.

Bảng II-30. Quyết định thiết kế và điểm còn mở

ID	Nội dung	Thiết kế hiện hành	Trạng thái
OD-01	Lý do khi thu hồi cặp khu – vai trò.	Bắt buộc. Seed reason_required = 1 cho ACCESS_GRANT EFFECTIVE → REVOKED; ReasonRequest bắt buộc; access_grant.revoke_reason có CHECK.	Đã chốt (QĐ-16)
OD-02	Ai khóa/mở khóa tài khoản và thu hồi grant.	Chỉ Chủ HTX (Quản trị hệ thống hỗ trợ ở UC74): endpoint OwnerOnly, allowed_actors trong seed; nhân viên → 403 MSG02 (QĐ-24: toàn bộ UC11 chỉ Chủ HTX).	Đã chốt (QĐ-16)
OD-03	Ai đổi tình trạng làm việc của nhân viên.	Chỉ Chủ HTX: /employees/{id}/leave | /rejoin OwnerOnly (QĐ-24: toàn bộ UC10 chỉ Chủ HTX).	Đã chốt (QĐ-16)
OD-04	Trường người dùng tự sửa ở UC05.	Tên hiển thị, email và số điện thoại; Account không có cột địa chỉ; email đổi qua /me/email-verifications, số điện thoại đổi qua /me/phone-verifications (VERIFY_PHONE, QĐ-21) cho mọi loại tài khoản (không dùng lại /me/phone-change, CHANGE_PHONE); tên đăng nhập không sửa (MSG20).	Đã chốt (QĐ-17, QĐ-20, QĐ-21)
OD-05	Luồng xác minh email; kênh gửi mã.	/me/email-verifications (purpose VERIFY_EMAIL, MSG62; UC08 «extend» UC05). Mã khôi phục gửi tới đúng email hoặc số đã xác minh người dùng nhập; đổi cách nhận mã qua /auth/recovery/{id}/switch; mã đổi mật khẩu gửi email đã xác minh (BR-31). Mã email dùng OtpOptions như SMS.	Đã chốt (QĐ-17, QĐ-20, QĐ-21)
OD-06	Phạm vi chức năng EMPLOYEE.	Toàn HTX: app_feature.zone_scoped = 0.	Đã chốt (QĐ-16)
OD-07	Nhân viên không còn grant hiệu lực.	Không đăng nhập được (UC02 2b, MSG13), kể cả để xem việc/lương của mình.	Đã chốt (QĐ-16)
OD-08	Danh mục chức năng và quyền khác.	AUTH/COOP theo Bảng II-20; các package khác bổ sung khi thiết kế package đó.	Một phần: chờ thiết kế package khác
OD-09	Xem có bắt buộc khi đã có Tạo/Sửa/Xóa/khác.	Bắt buộc: máy chủ tự bật Xem (Normalize) và CHECK CK_role_permission_read; bỏ cảnh báo READ_MISSING.	Đã chốt (QĐ-16)
OD-10	Mật khẩu tạm; OTP cho số nhân viên; nhiều Quản lý khu.	Mật khẩu tạm 10 ký tự, hạn 24 giờ, buộc đổi; nhân viên xác minh số do Chủ HTX nhập bằng mã SMS ở lần đăng nhập đầu (VERIFY_PHONE, QĐ-21 thay ý không xác minh của QĐ-16); một khu nhiều tài khoản cùng vai trò. Là quy tắc cố định, không còn cờ cấu hình.	Đã chốt (QĐ-16, QĐ-21)

ID	Nội dung	Thiết kế hiện hành	Trạng thái
OD-11	Giá trị OTP, phiên, khóa tạm, quy tắc mật khẩu; nhà cung cấp SMS/email/push.	Giá trị theo Bảng II-4 (QĐ-18). Nhà cung cấp: Options không có giá trị mặc định, môi trường Development dùng adapter giả.	Giá trị đã chốt (QĐ-18); nhà cung cấp chờ chọn
OD-12	SCR-07…SCR-10 trên Web hay cả Mobile.	Cả Web và Mobile, chung api-client (Bảng II-27).	Đã chốt 06/10/2026
OD-13	Lỗi gửi mã ở UC03 có làm lộ email hoặc số có tài khoản không.	Luôn trả 202 MSG15; gửi bất đồng bộ qua outbox nên thời gian phản hồi như nhau; rate limit theo IP và theo định danh.	Đã chốt (QĐ-17)
OD-14	Số điện thoại và email đã xác minh duy nhất toàn hệ thống.	UNIQUE phone_e164 (lọc NOT NULL) và UNIQUE email (lọc email_verified_at NOT NULL) toàn bảng auth.account (BR-32).	Đã chốt (QĐ-16, QĐ-20, BR-32)
OD-15	Tên miền triển khai (CORS Staging, Production).	Giữ placeholder ở III.1.1 b; cấu hình theo môi trường, không đặt trong code.	Chờ chốt
OD-16	Số điện thoại của thương lái đăng ký bằng email.	phone_e164 NULL tới khi thương lái thêm số. Đăng nhập trả phoneVerificationRequired = true; mọi API khác trả 403 MSG67 tới khi xác minh qua /me/phone-verifications (VERIFY_PHONE). Áp dụng cả nhân viên chưa xác minh số (BR-34). Mọi loại tài khoản đổi số đã xác minh qua cùng API (UC05 3b); thương lái thêm/đổi số thì ICustomerLinkService ghép hồ sơ khách offline khớp duy nhất (MSG57 nếu không).	Đã chốt (QĐ-21)

III. Design for Non-Functional Requirements

Thiết kế dưới đây hiện thực NFR-01…NFR-13 của SRS cho phạm vi AUTH/COOP và các cơ chế dùng chung. Giá trị chính sách đã chốt ngày 06/10/2026 (SRS v5.6, QĐ-16…QĐ-18, Bảng II-4); giá trị ghi "thiết kế" là lựa chọn kỹ thuật của SDS chờ PM/Technical Lead duyệt; mục ghi "chờ chốt" (nhà cung cấp, tên miền) không đặt trong code.

1. Security Design

1.1 Authentication Flow

OMTS dùng access token JWT ngắn hạn kèm refresh token xoay vòng gắn với một phiên lưu ở auth.auth_session. Phiên là nguồn sự thật: mỗi request kiểm phiên còn hiệu lực, nên khóa tài khoản, đổi hoặc khôi phục mật khẩu vô hiệu ngay các phiên đang mở (AC-02, UC03, UC04). Web giữ access token trong bộ nhớ và refresh token trong cookie HttpOnly; Mobile giữ refresh token trong Keychain/Keystore.

a. Token Design

Aspect	Design Decision
Access token	JWT ký RS256 (khóa riêng ở secret store, header kid để xoay khóa). Claims: sub (account_id), sid (session_id), coop, styp (subject type), iat, exp, iss, aud. Không chứa quyền. Thời hạn: 15 phút (QĐ-18).
Refresh token	Chuỗi ngẫu nhiên 256 bit, chỉ lưu SHA-256 (refresh_token_hash). Xoay mỗi lần dùng, giữ previous hash để phát hiện dùng lại (→ thu hồi phiên REUSE_DETECTED). Hạn trượt 7 ngày (Web) / 30 ngày (Mobile), hạn tuyệt đối 30 / 90 ngày (QĐ-18).
Lưu trữ phía client	Web: access token trong bộ nhớ; refresh ở cookie HttpOnly, Secure, SameSite=Strict, path /api/v1/auth. Mobile: refresh trong Keychain/Keystore; không lưu token trong SQLite.
Thu hồi	Đăng xuất (UC07), đổi mật khẩu (UC04 – thu hồi phiên khác theo SessionOptions), khôi phục (UC03 – mọi phiên), khóa tài khoản (UC11, UC74 – mọi phiên). security_stamp đổi kèm để token cũ bị từ chối ở lần kiểm kế tiếp.
Kiểm tra mỗi request	JwtBearer kiểm chữ ký/hạn; SessionValidationMiddleware đọc sys.v_security_context theo (sid, sub): phiên chưa thu hồi, chưa quá hạn tuyệt đối, stamp khớp, tài khoản ACTIVE → nếu sai trả 401 MSG19.
Chống dò mật khẩu	Giới hạn thất bại theo tài khoản (failed_login_count, lockout_until) và theo IP (RateLimiter); thông báo chung MSG12. Khóa tạm 15 phút sau 5 lần sai liên tiếp (QĐ-18, MSG69); theo IP 20 yêu cầu/phút (thiết kế).
Mật khẩu	PasswordHasher (PBKDF2-HMAC-SHA256, salt riêng, số vòng mặc định của .NET 8). Quy tắc: tối thiểu 8 ký tự, có chữ và số (QĐ-18). Mật khẩu tạm (UC11 khi tạo tài khoản và nhánh 1d): 10 ký tự, hạn 24 giờ, buộc đổi (QĐ-16); quá hạn → MSG68.

Aspect	Design Decision
OTP	Mã số ngẫu nhiên từ RandomNumberGenerator; lưu HMAC-SHA256 với khóa bí mật; so sánh thời gian hằng; 6 chữ số, hiệu lực 5 phút, tối đa 5 lần nhập sai, 3 lần gửi, cách nhau 60 giây (QĐ-18). Mã khôi phục gửi tới đúng email hoặc số điện thoại đã xác minh người dùng nhập; mã đổi mật khẩu gửi email đã xác minh (BR-31). Mã email dùng cùng giá trị (QĐ-21).

b. CORS Configuration

Web chạy khác origin với API nên cần CORS có credentials (cookie refresh). Mobile gọi trực tiếp, không áp CORS.

Environment	Allowed Origins	Allowed Methods	Allow Credentials	Max Age
Development	http://localhost:3000	GET, POST, PUT, DELETE, OPTIONS	true	600 s
Staging	https://staging.<tên miền OMTS> (chờ chốt)	GET, POST, PUT, DELETE, OPTIONS	true	600 s
Production	https://app.<tên miền OMTS> (chờ chốt)	GET, POST, PUT, DELETE, OPTIONS	true	3600 s

Header cho phép: Authorization, Content-Type, If-Match, X-Requested-With; header lộ ra: ETag, Retry-After. Endpoint dùng cookie (refresh, logout) kiểm thêm Origin và X-Requested-With để chống CSRF.

1.2 Authorization & RBAC Implementation

Aspect	Decision
Mô hình	RBAC do Chủ HTX định nghĩa (Role × Feature × Create/Read/Update/Delete/khác + data scope) gán theo cặp khu – vai trò (AccessGrant). Quyền thực tế = hợp quyền vai trò trong khu tương ứng (BR-19).
Actor nhân viên	Theo SRS QĐ-22, Quản lý khu và Kế toán là actor con của Nhân viên. Thiết kế không thêm loại tài khoản: cả ba dùng account_type EMPLOYEE (allowed_actors của status_transition giữ EMPLOYEE); khác biệt nằm ở vai trò cùng tên do Chủ HTX tạo, chỉnh quyền ở UC12 và gán theo khu ở UC11. Không seed vai trò mặc định; HTX không có vai trò Thu ngân. Theo QĐ-24, UC10 và UC11 chỉ Chủ HTX: endpoint /employees*, /user-accounts* dùng policy OwnerOnly, chức năng EMPLOYEE và USER_ACCOUNT không cấp được cho vai trò (Bảng II-20).
Lớp endpoint	[HasPermission(feature, action)] sinh PermissionRequirement; PermissionAuthorizationHandler kiểm có hành động ở ít nhất một khu. Policy riêng: OwnerOnly, PlatformAdmin, TraderSelf, Authenticated.
Lớp bản ghi	Service gọi IZoneScopeGuard.EnsureCan với zone_id của bản ghi (bè kế thừa khu – BR-01); danh sách dùng AllowedZones để lọc. Kiểm ở Application, không ở controller, vì chỉ service biết bản ghi thuộc khu nào. Dữ liệu chung HTX không có zone_id (nhà cung cấp giống, lô giống, khách hàng, phiếu thu, người nhận khoán, lao động thời vụ, chấm công, mức lương và đơn giá, quyết toán lao động) chỉ thao tác được với grant Toàn bộ khu (zone_id null).
Đa HTX (tenant)	Global query filter coop_id = ICurrentUser.CoopId cho mọi entity có coop_id; truy vấn bỏ filter chỉ ở ADMIN có PlatformAdmin.
Áp dụng ngay	permission_version tăng trong cùng giao dịch khi đổi vai trò, grant, khóa; cache theo version nên mọi instance dùng quyền mới ở request kế tiếp (AC-02).
Chống leo thang	Chỉ Chủ HTX cấp quyền (UC11 OwnerOnly, QĐ-24); IGrantGuard: khu và vai trò còn Đang dùng, không cấp vai trò Owner/Admin; không tạo/khóa/đặt lại mật khẩu Owner, Admin (UC11 4b, 1e).
Client	Menu và route dựng từ /me/permissions chỉ để hiển thị; mọi quyết định ở máy chủ.
Kiểm thử	Bộ test ma trận quyền: với mỗi endpoint, sinh tài khoản Owner / nhân viên có quyền khu A / nhân viên khu B / thương lái và kiểm 200/403.

1.3 Data Protection

Data Category	At Rest	In Transit	Notes
Mật khẩu	Hash PBKDF2 có salt; không lưu dạng rõ	TLS 1.2+	Không ghi log, audit; mật khẩu tạm chỉ hiện một lần, hết hạn sau 24 giờ (UC11 tạo tài khoản, 1d)
Mã OTP, verificationToken, refresh token	Chỉ lưu HMAC/SHA-256	TLS 1.2+	Không ghi log; outbox chỉ chứa verificationId, Worker sinh mã lúc gửi; hết hạn theo Bảng II-4
Dữ liệu cá nhân (tên, số điện thoại, email, địa chỉ, ngày sinh)	SQL Server TDE (khi môi trường hỗ trợ); sao lưu mã hóa	TLS 1.2+	Log che số điện thoại/email; chỉ hiện cho người có quyền (NFR-11); pháp lý OPEN-13
Ảnh giấy tờ HTX (UC72)	Lưu trữ đám mây, bucket riêng tư; DB giữ khóa tệp	URL ký có hạn ngắn	Chỉ Admin/Chủ HTX xem
Audit (before/after JSON)	Bảng sys.audit_event chỉ thêm, không sửa/xóa qua ứng dụng	—	Bỏ thuộc tính [Sensitive]; lưu ≥ 5 năm (NFR-02)
Secret (khóa ký JWT, khóa HMAC OTP, API key)	Secret store của môi trường (ví dụ Key Vault); không nằm trong repo	—	Xoay khóa theo kid; UC73 hiển thị dạng che

2. Performance & Scalability Design

Mục tiêu NFR-10: thao tác thông thường dưới 3 giây trên 4G. Baseline không có Redis; cache trong tiến trình (IMemoryCache) đủ cho một HTX. Khi chạy nhiều instance, cache vẫn đúng vì khóa chứa version đọc từ database.

2.1 Caching Strategy

What is Cached	Cache Key (IMemoryCache)	TTL	Invalidation Trigger	NFR
PermissionSet của tài khoản	perm:{accountId}:{permissionVersion}:{yyyyMMdd}	Trượt 10 phút (thiết kế)	permission_version tăng (đổi vai trò, grant, khóa); sang ngày mới	NFR-01, NFR-10, AC-02
Danh mục trạng thái và chuyển trạng thái	status:catalog	Đến khi đổi	UC73 sửa nhãn → xóa khóa (một instance) + version catalog trong DB cho instance khác	BR-29, BR-30
FeatureCatalog	Bộ nhớ tĩnh (code)	Suốt vòng đời tiến trình	Deploy phiên bản mới	NFR-10
Khóa công khai JWT	jwks:{kid}	Đến khi xoay khóa	Xoay khóa ký	NFR-01
Kênh khả dụng (UC73)	channels:availability	60 s (thiết kế)	Lưu cấu hình UC73	UC06

2.2 Database Query Optimization

- Hot path mỗi request là một truy vấn PK trên sys.v_security_context; PermissionSet chỉ tính lại khi version đổi (IX_grant_account).
- Chỉ mục ở I.3: tìm nhân viên theo tên chuẩn hóa (IX_employee_search), danh sách tài khoản theo HTX/trạng thái, grant theo tài khoản/vai trò, audit theo HTX/thời gian.
- Truy vấn danh sách dùng projection sang DTO (Select), AsNoTracking, phân trang offset với size tối đa cấu hình; không nạp graph entity.
- Unique có lọc (username, tax_code, account_id của employee, grant đang hiệu lực) thay cho kiểm trùng bằng đọc trước, tránh race condition.
- READ_COMMITTED_SNAPSHOT để đọc không chặn ghi; giao dịch ngắn, không gọi dịch vụ ngoài trong giao dịch.
- Command timeout và pool kết nối cấu hình; log truy vấn chậm vượt ngưỡng để rà định kỳ.

3. Reliability, Audit & Concurrency Design

NFR	Thiết kế
NFR-02 Audit, lưu trữ	IAuditTrail ghi sys.audit_event cùng giao dịch cho mọi thay đổi quyền, chuyển trạng thái nhóm A, nhãn trạng thái; không có API xóa audit. Sao lưu full hằng ngày + log backup; lưu giữ ≥ 5 năm.
NFR-04, NFR-08 Chống trùng	Lệnh có tác dụng tiền (UC48, UC49, UC54) dùng Idempotency-Key lưu kèm kết quả (thiết kế ở package SALES/PAY). Với AUTH: tạo tài khoản dựa trên UNIQUE phone; OTP gửi lại dùng verificationId làm khóa idempotent với nhà cung cấp.
NFR-09 Đồng thời	rowversion + If-Match/ETag; xung đột trả 409 MSG06 kèm người và thời điểm sửa gần nhất. Quy tắc ưu tiên quyền khi đồng bộ ngoại tuyến thiết kế ở package có dữ liệu ngoại tuyến.
NFR-12 Khôi phục	RPO ≤ 24 giờ bằng sao lưu hằng ngày; thử khôi phục định kỳ trên môi trường staging.
Dịch vụ ngoài lỗi	Timeout + retry có giới hạn + circuit breaker; lỗi trả 503 MSG04, dữ liệu OMTS giữ nguyên (NFR-08); thông báo không gấp đi qua outbox có thử lại.

IV. Other Design Specifications

1. Danh mục trạng thái và chuyển trạng thái (BR-29, BR-30)

- sys.status và sys.status_transition được seed bằng migration từ một tệp `status-catalog.json` duy nhất; source generator sinh hằng `StatusIds.Account.Active`… để code không dùng số trần. Không có API thêm/xóa mã hay chuyển (UC73 1b).
- IStatusTransitionService.EnsureAllowed(group, fromId, toId, useCase, actorType, reason) tra bảng chuyển (cache), kiểm UC, actor, lý do bắt buộc; sai → StatusTransitionDeniedException (409 MSG61). Sau khi gán trạng thái, service gọi IAuditTrail.RecordStatusChange.
- Nội dung seed theo SRS v5.8 mục 3.4: 53 trạng thái (51 của 15 nhóm vòng đời ở Bảng 3.4-1 và 2 của nhóm USAGE) và 52 chuyển (50 ở Bảng 3.4-2 và 2 của USAGE). Mỗi chuyển lưu UC, người thực hiện, sự kiện kích hoạt và cờ bắt buộc lý do đúng như bảng.
- Chuyển có sự kiện kích hoạt "Hệ thống" (8 chuyển, ví dụ Đạt → Nháp khi dữ liệu nguồn của lô đổi sau rà, Đã công bố → Cần rà lại khi UC39 đính chính nội dung đã công bố, Cần rà lại → Đã thay thế khi UC32 công bố bản mới) được gọi EnsureAllowed với actorType = SYSTEM trong cùng giao dịch của lệnh gây ra; chuyển theo thời gian (Đang gửi → Thất bại) do Worker gọi. Package nghiệp vụ kiểm trạng thái hiện tại trước lệnh, ví dụ không bàn giao (UC45) hay đồng bộ (UC41) khi bản công bố ở Cần rà lại; chỉ SaleAdjustment (SALE_ADJUSTMENT) và PayRuleVersion (PAY_RULE) ở Đã duyệt mới trừ công nợ hoặc dùng để tính tiền; thiết kế chi tiết thuộc package TRACE, SALES, PAY, LABOR khi tới lượt.
- UC73 chỉ sửa display_name, meaning, sort_order, color (có lý do, audit); client hiển thị nhãn từ GET /status-catalog.
- Trạng thái kỹ thuật (phiên, OTP, outbox) không thuộc sys.status vì SRS xếp chúng ngoài 15 nhóm vòng đời.

2. Audit trail

Hành động (action)	Khi nào	before/after
ACCOUNT.REGISTER, ACCOUNT.CREATE, ACCOUNT.UPDATE, ACCOUNT.PROFILE, ACCOUNT.EMAIL_VERIFIED, ACCOUNT.PHONE_VERIFIED	UC01, UC02 3a, UC11, UC05	Không chứa mật khẩu/hash
ACCOUNT.PASSWORD_CHANGED, ACCOUNT.PASSWORD_RECOVERED, ACCOUNT.PASSWORD_RESET	UC04, UC03, UC11 1d	Chỉ ghi sự kiện
STATUS.CHANGE	Mọi chuyển trạng thái nhóm A (COOPERATIVE, ACCOUNT, EMPLOYEE, ACCESS_GRANT…)	Trạng thái cũ/mới, lý do, loại người thực hiện (UC74: Quản trị hệ thống chỉ mở tài khoản do mình khóa)
GRANT.ADD, GRANT.REVOKE	UC11	Khu, vai trò, hiệu lực

Hành động (action)	Khi nào	before/after
ROLE.CREATE, ROLE.UPDATE, ROLE.USAGE	UC12	Ma trận quyền trước/sau
COOP.UPDATE, EMPLOYEE.CREATE, EMPLOYEE.UPDATE	UC09, UC10	Trường đổi
SECURITY.DENIED	Cấp vai trò Owner/Admin (UC11 4b)	Yêu cầu bị từ chối
TRACE_LABEL.PRINT, TRACE_LABEL.VOID, TRACE_LABEL.REPRINT	UC32 (in, hủy lần in lỗi, in lại nhãn QR)	Lô, bản công bố, số nhãn, lý do; không có bảng lịch sử in riêng
HARVEST_PLAN.UPDATE, SALE_TERMS.UPDATE, WATER_THRESHOLD.UPDATE	UC30, UC48, UC26 (sửa kế hoạch thu, điều khoản bán, ngưỡng nước)	Trước – sau; không lưu phiên bản

3. Outbox và tác vụ nền

- sys.outbox_message ghi cùng giao dịch nghiệp vụ; Worker lấy theo IX_outbox_pending, gửi qua adapter, đánh dấu processed_at; lỗi tăng attempt_count và lùi next_attempt_at theo backoff mũ; message_id là khóa idempotent với nhà cung cấp.
- Outbox SendOtp (UC03): Worker nạp lần xác minh QUEUED, sinh mã, lưu HMAC, gửi qua IEmailSender/ISmsSender; hết retry → SEND_FAILED, chỉ ghi log.
- JOB-01 (AUTH): định kỳ chuyển lần xác minh PENDING/VERIFIED quá hạn sang EXPIRED và dọn phiên đã hết hạn tuyệt đối lâu hơn thời gian lưu cấu hình. Kiểm hạn khi dùng vẫn là cơ chế chính, job chỉ dọn dẹp.
- JOB-02…07 thuộc các package khác; lịch chạy chờ chốt (SRS 5.3).

4. Môi trường và cấu hình triển khai

Môi trường	Mục đích	Ghi chú
Development	Máy lập trình viên: API + Worker + SQL Server (container), adapter giả cho SMS/email/push	Mã OTP ghi ra log dev, không bao giờ ở staging/production
Staging	Kiểm thử tích hợp và UAT với nhà cung cấp thật (tài khoản thử)	Dữ liệu giả; cùng cấu hình bảo mật production
Production	Vận hành HTX	Secret store; sao lưu hằng ngày; giám sát health check và log

5. Kiểm thử cho AUTH và COOP

- Unit test domain: OtpVerification (bảng II-12), PermissionSet (hợp quyền, khu, data scope, ngày hiệu lực), GrantGuard.
- Integration test với SQL Server (Testcontainers): ràng buộc unique, FK ghép trạng thái, concurrency rowversion, giao dịch tạo tài khoản + grant.
- API test: ma trận quyền (III.1.2), ProblemDetails đúng mã MSG cho mọi nhánh lỗi của UC01–UC12.
- Test kiến trúc: quy tắc phụ thuộc module (II.1.1).

6. Quyết định thiết kế và điểm còn mở

Xem Bảng II-30 (mục II.4): OD-01…OD-14 đã chốt ngày 06/10/2026; còn mở nhà cung cấp SMS/email/push, danh mục chức năng của package khác và tên miền triển khai. PM/Technical Lead review trước khi đánh dấu Done.